

UNIVERSIDAD PRIVADA ANTENOR ORREGO

FACULTAD DE INGENIERÍA

**PROGRAMA DE ESTUDIO DE INGENIERÍA DE
COMPUTACIÓN Y SISTEMAS**



**TESIS PARA OPTAR EL TÍTULO PROFESIONAL DE INGENIERO DE
COMPUTACIÓN Y SISTEMAS**

**Auditoria a la seguridad del sistema de gestión de análisis clínicos de IMEQSA
S.A.C. en el periodo 2024**

**Línea de investigación: Robótica, automatización avanzada y sistemas
inteligentes**

Sub línea de investigación: Sistemas de Información

Autores:

Briceño Díaz, Anderson Junior
Moreno Sánchez, Neisser Arilson

Jurado evaluador:

Presidente	Huapaya Escobedo, Jorge Lorenzo
Secretario	Piminchumo Flores, Jorge Luis
Vocal	Calderón Sedano, José Antonio

Asesor:

Díaz Sánchez, Jaime Eduardo
Código Orcid: <https://orcid.org/0000-0002-8652-0247>

Trujillo–Perú
2026

DECLARACION DE ORIGINALIDAD

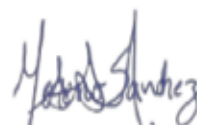
Yo, **Jaime Eduardo Díaz Sánchez**, docente del Programa de Estudio de Pregrado de la Universidad Privada Antenor Orrego, asesor de la tesis titulada “**Auditoria a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024**”, de los autores **Anderson Junior Briceño Díaz** y **Neisser Arilson Moreno Sánchez**.

- El mencionado documento tiene un índice de puntuación de similitud del 9%. Así lo consigna el reporte de similitud emitido por el software Turnitin el día 29 de abril del 2026.
- He revisado con detalle dicho reporte de la tesis “**Auditoria a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024**” y no se advierte indicios de plagio.
- Las citas a otros autores y sus respectivas referencias cumplen con las normas establecidas por la Universidad

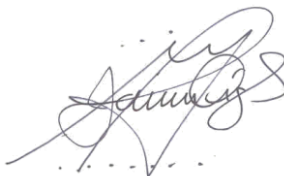
Trujillo, 29 de abril del 2026



Anderson Junior Briceño Díaz
DNI:71424176



Neisser Arilson Moreno Sánchez
DNI: 70369866



Jaime Eduardo Díaz Sánchez
DNI:19210676
ORCID: 0000-0002-8652-0247

UNIVERSIDAD PRIVADA ANTENOR ORREGO

FACULTAD DE INGENIERÍA

PROGRAMA DE ESTUDIO DE INGENIERÍA DE

COMPUTACIÓN Y SISTEMAS



TESIS PARA OPTAR EL TÍTULO PROFESIONAL DE INGENIERO DE

COMPUTACIÓN Y SISTEMAS

Auditoria a la seguridad del sistema de gestión de análisis clínicos de IMEQSA

S.A.C. en el periodo 2024

Línea de investigación: Robótica, automatización avanzada y sistemas

inteligentes

Sub línea de investigación: Sistemas de Información

Autores:

Briceño Díaz, Anderson Junior

Moreno Sánchez, Neisser Arilson

Asesor:

Díaz Sánchez, Jaime Eduardo



Ing. Jaime Eduardo Díaz Sánchez
CIP 73304 - ID 000000861

Código Orcid: <https://orcid.org/0000-0002-8652-0247>

Trujillo-Perú

2026

Anderson Junior Briceño Díaz

Informe de Tesis - Anderson Briceño y Neisser Moreno_290426

 Tesis (nuevo)

Detalles del documento

Identificador de la entrega

trn:old::3117:584796096

Fecha de entrega

29 abr 2026, 22:50 GMT-5

Fecha de descarga

29 abr 2026, 23:00 GMT-5

Nombre del archivo

Informe de Tesis - Anderson Briceño y Neisser Moreno_290426.docx

Tamaño del archivo

7.2 MB

91 páginas

16.533 palabras

95.906 caracteres



Ing. Jaime Eduardo Díaz Sánchez
CIP 73304 - ID 000000861

9% Similitud general

El total combinado de todas las coincidencias, incluidas las fuentes superpuestas, para la...

Filtrado desde el informe

- Bibliografía
- Coincidencias menores (menos de 15 palabras)

Exclusiones

- N.º de coincidencias excluidas



Ing. Jaime Eduardo Díaz Sánchez
CIP 73304 - ID 000000861

Fuentes principales

- 8%  Fuentes de Internet
- 0%  Publicaciones
- 6%  Trabajos entregados (trabajos del estudiante)

Marcas de integridad

N.º de alertas de integridad para revisión

Los algoritmos de nuestro sistema analizan un documento en profundidad para buscar inconsistencias que permitirían distinguirlo de una entrega normal. Si advertimos algo extraño, lo marcamos como una alerta para que pueda revisarlo.

Una marca de alerta no es necesariamente un indicador de problemas. Sin embargo, recomendamos que preste atención y la revise.

Fuentes principales

- 8% Fuentes de Internet
- 0% Publicaciones
- 6% Trabajos entregados (trabajos del estudiante)

Ing. Jaime Eduardo Díaz Sánchez
CIP 73304 - ID 000000861

Fuentes principales

Las fuentes con el mayor número de coincidencias dentro de la entrega. Las fuentes superpuestas no se mostrarán.

1	Internet	repositorio.upn.edu.pe	3%
2	Internet	docs.bvsalud.org	<1%
3	Internet	www.diresajunin.gob.pe	<1%
4	Internet	www.coursehero.com	<1%
5	Internet	es.slideshare.net	<1%
6	Internet	1library.co	<1%
7	Trabajos del estudiante	Universidad Científica del Sur on 2022-11-06	<1%
8	Trabajos del estudiante	uniminuto on 2023-12-09	<1%
9	Internet	docs.microsoft.com	<1%
10	Internet	hdl.handle.net	<1%
11	Trabajos del estudiante	Universidad Cesar Vallejo on 2021-12-03	<1%

12 Trabajos del estudiante
DEMO2 on 2025-10-20 <1%

13 Trabajos del estudiante
consultoriadeserviciosformativos on 2023-04-04 <1%

14 Internet
repositorio.ucv.edu.pe <1%

15 Internet
static.legis.pe <1%

16 Internet
web-assets.esetstatic.com <1%

17 Internet
autosmediterraneo.com <1%

18 Trabajos del estudiante
Universidad Internacional de la Rioja on 2021-10-19 <1%

19 Trabajos del estudiante
Universidad Privada Antenor Orrego 2025 on 2025-11-03 <1%

20 Internet
wiki2.org <1%

21 Trabajos del estudiante
Universidad TecMilenio on 2025-01-18 <1%

22 Internet
solucionesenlaweb.com <1%

23 Trabajos del estudiante
Universidad Politécnica Estatal de Carchi on 2024-05-28 <1%

24 Trabajos del estudiante
Universidad de Burgos UBUCEV on 2026-01-16 <1%

25 Internet
ita.edu.co <1%


Ing. Jaime Eduardo Díaz Sánchez
CIP 73304 - ID 000000861

26 Trabajos del estudiante
Universidad Privada Antenor Orrego 2025 on 2025-09-09 <1%

27 Internet
idese.es <1%

28 Internet
repositorio.unprg.edu.pe <1%

29 Trabajos del estudiante
Centro Europeo de Postgrado - CEUPE on 2023-08-14 <1%

30 Trabajos del estudiante
Universidad Nacional Federico Villarreal on 2024-11-20 <1%

31 Trabajos del estudiante
Universidad Peruana de Ciencias Aplicadas on 2025-07-14 <1%

32 Trabajos del estudiante
Universitat Oberta de Catalunya on 2026-03-05 <1%

33 Internet
www.unp.gov.co <1%

34 Trabajos del estudiante
Uniagustiniana on 2017-05-15 <1%

35 Trabajos del estudiante
Universitat Oberta de Catalunya on 2026-03-06 <1%

36 Trabajos del estudiante
Universitat Oberta de Catalunya on 2026-03-07 <1%

37 Internet
repositorio.uees.edu.ec <1%

38 Trabajos del estudiante
Universidad Americana on 2019-04-11 <1%

39 Internet
docplayer.es <1%


Ing. Jaime Eduardo Diaz Sanchez
CIP 73304 - ID 000000861

DEDICATORIA

A Jehová Dios por guiar mi vida, darme salud y sabiduría para alcanzar mis metas (Salmo 22:10), mis hijos Yareli Priscila Briceño Meza y Levi Sanderson Briceño Meza, quienes son mis pilares para salir adelante; y mis padres Santos Briceño y Emérita Diaz, quienes con su sacrificio y esfuerzo me dieron educación; a mis familiares y amigos quiénes con sus consejos y apoyo pude siempre salir adelante en cada etapa de mi vida.

Anderson Briceño

A mis padres Mariano Moreno y Martha Sanchez, quienes fueron mi motivación en todo momento; a mis familiares quiénes con sus consejos y apoyo pude siempre salir adelante en cada etapa de mi vida y sobre todo a Dios por brindarme salud, perseverancia y sabiduría para nunca rendirme, logrando así alcanzar mis objetivos trazados.

Neisser Moreno

AGRADECIMIENTO

Quiero tomar un momento para agradecer de corazón a nuestras familias. Su amor, comprensión y apoyo incondicional han sido nuestro pilar en cada paso de este camino académico. También quiero mencionar a nuestros docentes y asesores; su orientación, paciencia y esos conocimientos tan valiosos nos han dado las herramientas que necesitábamos para llevar a cabo esta investigación.

No puedo dejar de lado a la institución que nos apoyó durante el estudio. Gracias por facilitar la recolección de información y por brindarnos acceso a los recursos necesarios. Y por supuesto, un agradecimiento especial a todos los que, ya sea de forma directa o indirecta, aportaron su tiempo, esfuerzo y palabras de aliento para hacer posible este trabajo de tesis. ¡Ustedes son parte fundamental de este logro!

RESUMEN

El presente estudio tuvo como objetivo determinar el nivel de cumplimiento del Sistema de Información para la Gestión de Análisis Clínicos (SIGAC) de la empresa IMEQSA S.A.C., conocida comercialmente como Inovalab, respecto a los controles y lineamientos establecidos en la Norma Técnica de Salud 139-MINSA-2018 y la Norma Técnica Peruana ISO/IEC 27002:2022. La investigación se desarrolló bajo un enfoque de auditoría de seguridad de la información, empleando una metodología basada en listas de verificación, así como técnicas de recolección de datos como la revisión documental, entrevistas y observación directa. Los resultados evidenciaron que el sistema presenta un nivel de cumplimiento parcial, identificándose deficiencias en los controles de acceso, ausencia de mecanismos de firma digital, duplicidad de registros y limitaciones en la trazabilidad de las operaciones realizadas por los usuarios. Se concluye que, si bien el SIGAC cuenta con una infraestructura tecnológica basada en servicios en la nube, existen brechas en la gestión de la seguridad de la información que requieren ser fortalecidas para garantizar la confidencialidad, integridad y disponibilidad de los datos clínicos conforme a las normativas vigentes.

Palabras clave: Auditoría de seguridad, SIGAC, NTS 139-MINSA-2018, ISO/IEC 27002:2022, confidencialidad, integridad, disponibilidad.

ABSTRACT

The purpose of this study was to determine the level of compliance of the Clinical Analysis Management Information System (SIGAC) of IMEQSA S.A.C., commercially known as Inovalab, with the controls and guidelines established in Technical Health Standard 139-MINSA-2018 and the Peruvian Technical Standard ISO/IEC 27002:2022. The research was conducted under an information security audit approach, using a methodology based on a verification checklist, as well as data collection techniques such as document review, interviews, and direct observation. The results showed that the system presents a partial level of compliance, identifying deficiencies in access controls, absence of digital signature mechanisms, duplication of records, and limitations in the traceability of user operations. It is concluded that, although SIGAC has a cloud-based technological infrastructure, there are gaps in information security management that need to be strengthened to ensure the confidentiality, integrity, and availability of clinical data in accordance with current regulations.

Keywords: Security audit, SIGAC, NTS 139-MINSA-2018, ISO/IEC 27002:2022, confidentiality, integrity, availability.

PRESENTACIÓN

Señores

Miembros del Jurado Evaluador

Es un privilegio dirigirme a ustedes para presentar el informe final de la investigación titulada “Auditoría de la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. durante el periodo 2024”, elaborado como parte de los requisitos para obtener el título profesional de Ingeniero de Computación y Sistemas.

El presente trabajo ha sido desarrollado con dedicación y responsabilidad, cumpliendo con los lineamientos establecidos por la institución.

Sin otro particular, agradezco de antemano su atención y consideración.

Atentamente,

Anderson Junior Briceño Díaz

Neisser Arilson Moreno Sánchez

ÍNDICE DE CONTENIDO

PORTADA	I
DECLARACION DE ORIGINALIDAD	II
DEDICATORIA	V
AGRADECIMIENTO.....	VI
RESUMEN	VII
ABSTRACT	VIII
PRESENTACIÓN	IX
1. INTRODUCCIÓN	19
1.1. Contexto y Antecedentes	19
1.2. Descripción y justificación del estudio.....	20
1.3. Organización del documento	21
2. PLANTEAMIENTO DEL ESTUDIO	22
2.1. Descripción y delimitación del Problema	22
2.1.1. Formulación del Problema.....	22
2.1.2. Problema central del Estudio	24
2.2. Objetivos de la investigación	24
2.2.1. Objetivo General.....	24
2.2.2. Objetivos Específicos.....	24
2.3. Importancia del Estudio	25
2.4. Justificación del Estudio.....	25
2.5. Limitaciones del Estudio	26
3. MARCO TEÓRICO	26
3.1. Marco Histórico	26
3.1.1. La Auditoria y la seguridad de la información	26
3.1.2. Auditoria de Sistema Informático de Historias Clínicas.....	27
3.2. Antecedentes.....	28
3.2.1. Internacionales	28
3.2.2. Nacionales	29

3.2.3. Locales	31
3.3. Base teórica.....	32
3.3.1. Seguridad de la información	32
3.3.2. Seguridad de la información en Sistemas de Salud	33
3.3.3. Sistema de Información de Historias Clínicas.....	35
3.3.4. Modelo de Madurez de Capacidades Integrado (CMMI V2.2)	36
3.4. Definición de términos básicos	37
4. MARCO METODOLÓGICO	39
4.1. Tipo de investigación	39
4.2. Nivel de madurez tecnológica.....	39
4.3. Método de investigación	40
4.4. Diseño de Estudio.....	40
4.5. Población y Muestra	40
4.6. Técnicas e instrumentos de recolección datos	40
4.7. Procedimiento de ejecución del estudio.....	41
4.8. Técnicas de procesamiento y análisis de datos.....	41
5. PRESENTACIÓN DE RESULTADOS	42
5.1. Informe de Auditoria.....	42
5.2. Resultados.....	45
5.2.1. Nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C:	45
5.2.2. Cumplimiento de confiabilidad de la gestión de las historias clínicas informatizadas	46
5.2.3. Cumplimiento de la Integridad en la gestión de las historias clínicas informatizadas:	47
5.2.4. Cumplimiento de la disponibilidad en la gestión de las historias clínicas informatizadas:	48
5.2.5. Recomendaciones en la gestión de historias clínicas informatizadas:	49
6.3. Discusión de Resultados	50
6.4. Conclusiones	53
6.5. Recomendaciones	54
6.5.1. Recomendaciones dirigidas a la empresa IMEQSA S.A.C.	54
6.5.2. Recomendaciones dirigidas a futuras investigaciones	55
7. REFERENCIAS BIBLIOGRAFICAS.....	55

8. ANEXOS.....	61
ANEXO N.º 1: MATRIZ DE CONSISTENCIA.....	61
ANEXO N.º 2: INFORMACIÓN SOBRE IMEQSA S.A.C.....	62
ANEXO N.º 3: CARTA N.º 01/AJBD-NAMS	72
ANEXO N.º 4: APROBACION DE APLICACIÓN DE TESIS	73
ANEXO N.º 5: VALIDACION DE INSTRUMENTO POR EXPERTOS.....	74
ANEXO N.º 6: ACTA DE REUNION DE AUDITORIA.....	89
ANEXO N.º 7: INFORME DE AUDITORIA	90

ÍNDICE DE TABLAS

Tabla 1: Procedimiento del diseño de investigación.....	37
Tabla 2: Resultados del CheckList de Cumplimiento de NTS 139-2018 MINSA Y NTP ISO/IEC 27002:2022 (Anexo 9.2.1).....	41
Tabla 3: Resultados confidencialidad del checklist de cumplimiento de NTS 139-2018 MINSA y NTP ISO/IEC 27002:2022 (anexo 9.2.1)	42
Tabla 4: Resultados integridad del checklist de cumplimiento de NTS 139-2018 MINSA y ISO 27001:2022 (anexo 9.2.1)	43
Tabla 5: Resultados disponibilidad del checklist de cumplimiento de NTS 139-2018 MINSA y ISO 27001:2022 (anexo 9.2.1)	44
Tabla 6: Recomendaciones de acuerdo a aspectos de seguridad	46
Tabla 7: Correlación de la norma técnica de salud 139-MINSA-2018 y norma técnica peruana ISO/IEC 27002:2022	63

ÍNDICE DE ILUSTRACIONES

Ilustración 1: Organigrama de IMEQSA S.A.C.	58
Ilustración 2: Plan de auditoria en formato de IMEQSA S.A.C.	6367

1. INTRODUCCIÓN

1.1 Contexto y Antecedentes

La presente investigación tiene como propósito evaluar la seguridad del Sistema de Información para la Gestión de Análisis Clínicos (SIGAC) de la empresa IMEQSA S.A.C., mediante la aplicación de criterios establecidos en la Norma Técnica de Salud NTS 139-MINSA-2018 (MINSA, 2018), y la Norma Técnica Peruana ISO/IEC 27002:2022 (Dirección de Normalización – INACAL, 2022), con el fin de determinar su nivel de cumplimiento y proponer mejoras que contribuyan a la protección de la información clínica.

Actualmente, el área de la salud se enfrenta a grandes retos debido a la transformación digital y al uso intensivo de sistemas informáticos en la gestión de datos clínicos. La adopción de Sistemas de Información en Salud (SIS), y en especial, de Historias Clínicas Electrónicas (HCE), ha facilitado el incremento de la eficiencia en los procesos y la optimización de la atención sanitaria. No obstante, este progreso tecnológico también ha aumentado los riesgos relacionados con la seguridad, integridad, confidencialidad y disponibilidad de la información clínica.

Varios estudios internacionales destacan la relevancia de salvaguardar los datos confidenciales de los pacientes y de asegurar la interoperabilidad entre sistemas de salud. Mallqui (2022) enfatiza que la digitalización en sí misma no basta sin la aplicación de robustas medidas de privacidad y seguridad de datos, mientras que Azzolini et al. (2019) muestran que llevar a cabo auditorías internas regulares es fundamental para asegurar la fiabilidad de los registros médicos y evitar inconsistencias. De igual manera, Mazorra (2019) evidencia que implementar Sistemas de Gestión de Seguridad de la Información (SGSI) fundamentados en ISO/IEC 27001 disminuye considerablemente los riesgos vinculados a las infracciones de privacidad y refuerza las políticas institucionales de resguardo de datos.

En el ámbito nacional, la situación es comparable. Dávila y Dextre (2021) y Lara (2020) revelan que la mayoría de las instituciones de salud no cuentan con estrategias eficaces para gestionar vulnerabilidades y controlar riesgos, lo que afecta la continuidad del negocio y la calidad del servicio. De igual manera, Niquen (2019) sugiere un modelo para la protección de datos fundamentado en

la ISO/IEC 27001, evidenciando que la adopción de medidas de seguridad ayuda a disminuir riesgos y a adherirse a las políticas de resguardo de información estipuladas por la legislación peruana.

A nivel local, estudios como los de Poma (2019) y Calixto & Gonzáles (2019) han evidenciado la eficacia de crear planes de seguridad y metodologías de auditoría que combinen estándares internacionales y regulaciones nacionales, como la NTS 139-MINSA-2018, para optimizar la integridad, disponibilidad y confidencialidad de la información clínica.

En este contexto, la empresa IMEQSA S.A.C., que opera comercialmente como Inovalab, desempeña un papel relevante en la oferta de servicios clínicos en la ciudad de Trujillo. La entidad posee acreditación oficial y gestiona datos confidenciales de pacientes mediante su Sistema de Información para la Gestión de Análisis Clínicos (SIGAC), una solución personalizada y alojada en la nube de Azure.

No obstante, a pesar de su importancia, se ha determinado que ese sistema no cumple totalmente con los lineamientos señalados en la Norma Técnica de Salud 139-MINSA-2018 ni con los controles establecidos en la Norma Técnica Peruana ISO/IEC 27002:2022. Esta circunstancia genera debilidades específicas, tales como la ausencia de controles adecuados de acceso a la información, deficiencias en el registro y trazabilidad de las operaciones realizadas en el sistema, y limitaciones en los procesos de verificación y validación de los datos clínicos.

En este sentido, es fundamental revisar el grado de cumplimiento regulatorio e identificar áreas de mejora en la administración de la seguridad de la información. Esto facilitará no solo la adecuada protección de los datos clínicos, sino también la disminución de riesgos legales y el fortalecimiento de la capacidad de respuesta ante posibles amenazas cibernéticas.

1.2. Descripción y justificación del estudio

El estudio actual se enfoca en evaluar el grado de concordancia del Sistema de Información para la Gestión de Análisis Clínicos (SIGAC) de IMEQSA S.A.C., comercialmente conocida como Inovalab, con los lineamientos indicados en la Norma Técnica de Salud 139-MINSA-2018 y en la Norma Técnica Peruana ISO/IEC 27002:2022. Se utilizaron herramientas de auditoría

de seguridad de la información que facilitaron la evaluación de la integridad, confidencialidad y disponibilidad de los datos clínicos gestionados por el sistema, además de identificar vulnerabilidades, riesgos y potenciales mejoras.

La razón del estudio se basa en la necesidad de mejorar la seguridad de la información en el ámbito de la salud, donde los expedientes clínicos electrónicos son un recurso esencial para la atención sanitaria y la defensa de los derechos de los pacientes. La observancia de las normas citadas no solo asegura la fiabilidad de los procesos clínicos y administrativos, sino que también ayuda a reducir los riesgos legales, técnicos y éticos vinculados a la administración de datos sensibles. De igual manera, este estudio enriquece el saber académico al presentar datos empíricos sobre la implementación de auditorías de seguridad en clínicas privadas, sugiriendo recomendaciones que pueden funcionar como guía para futuras certificaciones y aplicaciones en seguridad de la información.

1.3. Organización del documento

El presente documento se organiza en cinco etapas. En la etapa I se expone el planteamiento del estudio, que incluye la delimitación y formulación del problema, los objetivos, la importancia, la justificación y las limitaciones de la investigación.

En la etapa II desarrolla el marco teórico, en el que se presentan los antecedentes internacionales, nacionales y locales, así como la base teórica-científica relacionada con la seguridad de la información, la auditoría y los sistemas de información en salud.

En la etapa III se desarrolla el marco metodológico, donde se detallan el tipo y diseño del estudio, la población y la muestra, así como las técnicas e instrumentos para recolectar datos, el procedimiento seguido y los métodos de análisis aplicados.

Finalmente, en la etapa IV se presentan las referencias bibliográficas empleadas para sustentar teórica y metodológicamente la investigación.

2. PLANTEAMIENTO DEL ESTUDIO

2.1. Descripción y delimitación del Problema

2.1.1 Formulación del Problema

De acuerdo con Jañero y Arratibel (2024), los problemas más comunes en la seguridad de la información en el ámbito sanitario son: mala configuración de seguridad (68%), errores humanos o insiders en la operación (16%), y phishing/ingeniería social en un 4%. En otro sentido, la Organización Panamericana de la Salud (2023) y la Organización Mundial de la Salud mencionan que la información a proteger no solo es considerada un bien, sino que implica aspectos éticos, legales y técnicos que deben ser defendidos. De acuerdo con Gomero (2024), los daños financieros y la pérdida de reputación online debido a ciberataques pueden exceder los 155,000 dólares.

Según IBM Seguridad (2024), el 40 % de las filtraciones de datos ocurrieron en información almacenada en diferentes entornos. Los datos expuestos almacenados en nubes públicas ocasionaron el costo promedio más alto por filtración, alcanzando USD 5,17 millones.

Según la empresa Progreso en seguridad digital en su Reporte de Seguridad Latinoamericana (2024), el 28% de las empresas considera que la ciberseguridad es un asunto de máxima preocupación. Para entender el papel crucial de la ciberseguridad en las empresas de América Latina, se ha analizado el nivel de inquietud frente a riesgos como accesos no autorizados a sistemas, interrupción de servicios esenciales, extorsiones, pérdida o filtración de datos, y el uso indebido de recursos e infraestructura. Según la percepción de los encuestados, el 28% considera que estos riesgos son de máxima preocupación, mientras que el 42% los clasifica como de preocupación alta. De acuerdo con los encuestados, el 28% percibe estos riesgos como altamente preocupantes, y un 42% los considera de gran preocupación. En cuanto a las prácticas y políticas de ciberseguridad más implementadas, la política de seguridad destaca como la medida de gestión más común, con el 83% de las empresas reportando su uso. Otras prácticas incluyen los planes de respuesta a incidentes, aplicados en un 52% de las

organizaciones, y los planes de continuidad del negocio, adoptados por el 46%.

De acuerdo con la MINSA (2018), el incumplimiento de las normativas vigentes puede resultar en inconsistencias y pérdida de información clínica, afectando negativamente la calidad y la seguridad de la atención al paciente. En nuestro país, la Norma Técnica de Salud de Historias Clínicas (NTS No. 139-MINSA/2018/DGAIN) (MINSA, 2018) establece que todo Sistema de Información de Historias Clínicas Electrónicas (SIHCE) debe estar acreditado por la Dirección de Salud, la Dirección Regional de Salud o la autoridad correspondiente, conforme a lo establecido en la Ley N° 30024, que crea el Registro Nacional de Historias Electrónicas – RENHICE, y su reglamento; la Norma Técnica Peruana ISO/IEC 27002:2022 establece controles de seguridad que las organizaciones pueden adoptar para proteger su información. Sin embargo, el estudio realizado por Gomero (2024), muestra que muchas instituciones privadas o públicas no cumplen con estas normativas, comprometiendo la integridad, confidencialidad y disponibilidad de la información clínica.

IMEQSA S.A.C., operando bajo el nombre comercial Inovalab, es un laboratorio clínico autorizado según la Resolución Gerencial Regional N° 1021-2022-GRLL-GGR-GRSS y Código IPRESS (Instituciones Prestadoras de Servicios de Salud) N° 00031559, situado en la ciudad de Trujillo. Dedicado a la ejecución de exámenes de Hematología, Bioquímica, Inmunología, Microbiología, Coagulometría, Citología Molecular, Genética e Histología, entre otros. La información generada es procesada mediante el sistema de información para la gestión de análisis clínicos (SIGAC) alojado en Azure, desarrollado a medida que cubre los procesos de Admisión y facturación, Pre-Analítica y Post-Analítica utilizado desde el 2019; en la actualidad, las actualizaciones del sistema son gestionadas por un tercero; no cumple con los lineamientos de la Norma Técnica de Salud 139-MINSA-2018 ni con los controles de la Norma Técnica Peruana ISO/IEC 27002:2022. El administrador de Inovalab manifiesta que ha identificado algunos hechos negativos respecto al sistema de información de gestión de análisis clínicos:

- Los usuarios tienen como práctica compartir sus accesos y desconoce si pueden identificarse al usuario que realiza el registro o consulta de información.
- No se cuenta con un responsable para la administración de los perfiles de acceso que garantice la privacidad de la información.
- No se cuenta con un registro y firma digital de los usuarios que validan los resultados de los exámenes.
- Los usuarios han manifestado que existe duplicidad en la lista de registros de exámenes clínicos.

Por lo expuesto, este proyecto tiene como finalidad identificar las fortalezas, débiles y oportunidades de mejora del Sistema de Gestión de Análisis Clínicos de IMEQSA S.A.C respecto a los principios de integridad, confidencialidad y disponibilidad según la Norma Técnica de Salud 139-MINSA-2018 y la Norma Técnica Peruana ISO/IEC 27002:2022, que tienen el carácter de cumplimiento obligatorio en todo establecimiento de gestión de datos personales y clínicos de los peruanos.

2.1.2 Problema central del Estudio

¿Cómo determinar el nivel de cumplimiento del sistema de información de gestión de análisis clínicos de IMEQSA S.A.C. respecto a la Norma Técnica de Salud 139-MINSA-2018 y la Norma Técnica Peruana ISO/IEC 27002:2022?

2.2 Objetivos de la investigación

2.2.1 Objetivo General

Determinar el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.

2.2.2 Objetivos Específicos

- Determinar el grado de cumplimiento de los lineamientos establecidos en la NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022 en el SIGAC en cuanto a la confiabilidad de la gestión de las historias clínicas informatizadas.

- Determinar los controles de seguridad implementados en el SIGAC respecto a las recomendaciones de la NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022, con especial énfasis en la protección de la integridad de las historias clínicas informatizadas.
- Verificar la capacidad operativa del SIGAC para gestionar la disponibilidad de la historia clínica conforme a los requisitos indicados tanto en NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022.
- Proponer recomendaciones de mejora para el SIGAC, derivadas del análisis realizado durante la auditoría de seguridad.

2.3 Importancia del Estudio

El presente estudio es relevante porque aborda la seguridad del sistema de información utilizado para la gestión de análisis clínicos, un aspecto crítico en instituciones de salud. En el contexto actual, donde el uso de tecnologías para el manejo de historias clínicas informatizadas es cada vez más frecuente, garantizar la protección de los datos personales y sensibles de los pacientes se vuelve indispensable. Además, la auditoría permitirá identificar oportunidades de mejora en el sistema de información, con el fin de reforzar la seguridad y reducir la vulnerabilidad de los datos de los pacientes. Esto también puede facilitar que la organización esté mejor preparada para obtener certificaciones en seguridad de la información.

Por otro lado, a nivel académico, este trabajo aporta como referencia para futuras investigaciones relacionadas con la tecnología y la seguridad de la información.

2.4 Justificación del Estudio

La creación de este informe facilitará a IMEQSA obtener una perspectiva más precisa acerca del grado de seguridad de su sistema de información. De igual manera, contribuirá a evitar eventuales sanciones o multas que pudieran surgir de auditorías de verificación.

En el ámbito tecnológico, el proyecto facilitará la modernización y optimización del sistema de información, añadiendo características que busquen reforzar la protección de los datos. Con este objetivo, se pretende impedir que la información confidencial se encuentre al alcance de individuos no autorizados.

En el ámbito organizacional, la investigación contribuye al fortalecimiento de la gestión de la seguridad de la información dentro de la empresa, promoviendo la implementación de buenas prácticas y el cumplimiento de estándares como la NTP ISO/IEC 27002:2022 y la Norma Técnica de Salud 139-MINSA-2018.

Finalmente, desde un enfoque académico, mostrará la competencia profesional de los investigadores al tratar y solucionar problemas empresariales, además de contribuir con el informe que servirá de referencia para investigaciones futuras.

2.5 Limitaciones del Estudio

Entre las posibles limitaciones se encuentra la disponibilidad limitada de información interna debido a políticas de confidencialidad de la institución IMEQSA. Asimismo, podría haber resistencia del personal durante la recolección de datos, al momento de realizar las entrevistas, encuestas, etc., afectando la obtención de información necesaria y requerida, y quizá también otra limitación potencial es el acceso restringido a documentación técnica del sistema SIGAC, lo que podría dificultar una evaluación exhaustiva durante el desarrollo.

3 MARCO TEÓRICO

3.1 Marco Histórico

3.1.1 La Auditoría y la seguridad de la información

La auditoría de seguridad en sistemas se ha vuelto esencial, casi como una continuación de la seguridad de la información. Con el tiempo, a medida que las organizaciones han ido integrando más tecnología en sus procesos, se ha vuelto crucial tener formas más organizadas de evaluar qué tan bien están funcionando los controles. Esto ayuda a minimizar riesgos y garantiza que se cumplan los estándares internacionales (Bruce, 2023).

Con el paso del tiempo, la auditoría de seguridad se ha vuelto una práctica bastante formal, respaldada por estándares como el ISO/IEC 27001:2022. Este marco ofrece pautas para proteger lo que todos consideramos esencial: la confidencialidad, integridad y disponibilidad de la información. Y esos

mismos principios son clave, sobre todo en el ámbito de los sistemas de salud electrónicos.

Cuando hablamos de la auditoría de seguridad para historias clínicas electrónicas, nos referimos a un proceso que es más bien sistemático. Se trata de evaluar, verificar y validar qué tan bien se están protegiendo los datos sanitarios digitales (Ministerio de Salud, 2018). Esto incluye revisar controles de acceso, analizar registros de actividad, garantizar la integridad de los datos y comprobar que todo esté en línea con las regulaciones que correspondan. Su propósito es doble:

- Garantizar la protección de datos sensibles de los pacientes.
- Verificar cumplimiento de las obligaciones legales y normativas en materia de datos sanitarios.

Este enfoque hace que los sistemas de salud tengan que llevar a cabo auditorías periódicas, usando métodos que se adapten a las amenazas en constante cambio. Es clave incluir evaluaciones basadas en riesgos y técnicas automatizadas para detectar vulnerabilidades de forma temprana. (Mejía et al., 2025).

3.1.2 Auditoria de Sistema Informático de Historias Clínicas

La transformación digital en el sector salud ha hecho que cada vez más hospitales y centros médicos adopten sistemas electrónicos para gestionar las historias clínicas. Esto ha traído grandes ventajas, pero también ha generado una necesidad urgente: revisar a fondo esos sistemas para asegurarse de que sean seguros. Como señala (Herranz et al., 2024), si bien la digitalización agiliza la atención y permite acceder a la información médica al instante, también expone los datos a riesgos cibernéticos. Por eso, auditar los sistemas de historias clínicas se ha vuelto una prioridad para proteger la información de los pacientes.

En los últimos años, el uso de las Historias Clínicas Electrónicas (HCE) se ha institucionalizado cada vez más, y con ello, también los procesos de auditoría. En Perú, el Ministerio de Salud ha dado un paso importante al aprobar directivas y procesos de acreditación para estos sistemas, estableciendo criterios claros y medibles que garantizan un funcionamiento seguro. Estos criterios son clave para mantener la calidad del servicio y

resguardar los datos clínicos mediante auditorías periódicas (Directiva Administrativa N° 373-MINSA/OGTI-2025). En muchos países, la obligación de implementar Historias Clínicas Electrónicas ha hecho que las auditorías regulares a los sistemas informáticos sean más necesarias que nunca. Con una digitalización tan masiva, es imprescindible contar con mecanismos de control que permitan verificar si los equipos técnicos y organizativos realmente protegen la información clínica, ya sea de accesos indebidos o de pérdidas accidentales.

3.2 Antecedentes

3.2.1 Internacionales

Mallqui (2022) echa un vistazo al uso de las historias clínicas electrónicas (HCE) en el proceso de transformación digital del sector salud. Según su estudio, no se trata solo de implementar estas herramientas; hay que asegurar la privacidad, la confidencialidad y la seguridad de la información. Sin eso, los beneficios que se esperaban pueden quedarse cortos.

El autor también señala que digitalizar documentos por sí solo no garantiza una mejora en el sistema. Uno de los mayores problemas en la práctica es que muchos sistemas de salud no son interoperables. Cuando esto pasa, acceder a la información se vuelve un proceso lento y poco eficiente. Pero si los sistemas están bien integrados, consultar la información clínica se hace mucho más rápido y seguro, lo que realmente impacta en la atención médica y en cómo se toman las decisiones.

Azzolini y su equipo (2019) destacan lo crucial que es la auditoría interna para mejorar la calidad de la documentación en los hospitales. En un estudio que hicieron en un hospital de tercer nivel en Italia, revisaron historias clínicas de 2013 y 2015, analizando un total de 1,460 y 1,402 registros respectivamente. Lo interesante es que encontraron una mejora notable en esos registros; el puntaje de observación subió del 59.5% al 77.3%.

Sin embargo, con más observaciones documentadas, también viene una carga extra de datos, lo que puede aumentar el riesgo de cometer errores y poner en jaque la integridad de los registros. Ahí es donde entra la auditoría interna: es clave para mantener una mejora continua en la calidad de la

atención médica y para asegurar la confiabilidad y seguridad de los sistemas que manejan información sensible de los pacientes. Este estudio subraya lo necesario que es implementar auditorías internas periódicas como parte fundamental para proteger nuestros sistemas de registro y control médico. En su estudio, Mazorra (2019) se sumerge en cómo adaptar un Sistema de Gestión de Seguridad de la Información (SGSI) basado en la norma ISO/IEC 27001 en los hospitales públicos de Ecuador. Destaca lo crucial que son las tecnologías de la información y la comunicación (TICs) para respaldar los procesos hospitalarios, al mismo tiempo que menciona la falta de políticas y procedimientos informáticos que garanticen la seguridad de los recursos y la gestión de información, operaciones y sistemas, como las historias clínicas electrónicas. La metodología propuesta incluye mantener un inventario de activos, catalogar los procesos, gestionar amenazas y vulnerabilidades, evaluar riesgos y crear reportes para hacer seguimiento. Los resultados evidenciaron que la implementación del SGSI permitió reducir los riesgos asociados a la seguridad de la información, fortalecer las políticas institucionales y mejorar la protección de los datos clínicos, estableciendo una gestión más estructurada y alineada a los requisitos de la norma ISO/IEC 27001.

3.2.2 Nacionales

Baldera (2025) en investigación presentó un modelo de seguridad de la información bajo un enfoque de gestión de riesgos de tecnologías de información basado en los estándares ISO/IEC 27001, ISO/IEC 27002 aplicado a tres IPRESS de la ciudad de Chiclayo, Perú. El modelo de construyó bajo la normativa vigentes relacionadas con la gestión de historias clínicas electrónicas, integrando los procesos hospitalarios como ejes centrales. El método investigativo fue descriptivo propositivo y como conclusión demostró que las mayores exposiciones al riesgo para la confidencialidad provienen de los activos relacionados con el personal y los datos, mientras que los activos de sistemas presentan una exposición menor.

Dávila y Dextre (2021) presentaron en su tesis un modelo de gestión que se centra en analizar y evaluar las vulnerabilidades de los activos de información en la Policlínica de Salud AMC, basándose en los dominios del Anexo A de la NTP ISO 27001:2014. El enfoque del estudio era descriptivo y llegó a una conclusión bastante clara: es crucial implementar una estrategia de gestión de vulnerabilidades para manejar adecuadamente la infraestructura de TI de la policlínica. Los resultados evidenciaron que, mediante la aplicación de un enfoque de gestión de vulnerabilidades, se logró identificar y clasificar los activos de información, evaluar de manera continua las vulnerabilidades del sistema, priorizar los riesgos según su impacto en el negocio y aplicar medidas de corrección para su mitigación. Este proceso permitió reducir el nivel de exposición a amenazas y fortalecer la seguridad de la infraestructura tecnológica, evidenciando la importancia de una gestión continua y estructurada de la seguridad de la información.

En otra línea, Lara (2020) realizó una auditoría de seguridad informática en un hospital para identificar y corregir debilidades, utilizando el estándar ISO/IEC 27001. En este caso, aplicaron el marco Maigti para evaluar el centro de datos, y los resultados mostraron que las medidas de seguridad no eran las más robustas. Este estudio, que era descriptivo y no experimental, se apoyó en encuestas y entrevistas con un grupo pequeño de 10 empleados. Se encontró que el hospital carecía tanto de programas como de equipos informáticos adecuados para asegurar que sus sistemas funcionaran correctamente. Esto sugiere que deberían poner en marcha un plan de mantenimiento regular para resolver y prevenir futuros problemas. El equipo informático tiene algunos asuntos pendientes que deben abordar para mejorar los procesos de TI. Lo más destacado del estudio es la necesidad urgente de optimizar las operaciones y establecer pautas claras sobre seguridad; se sugiere un plan exhaustivo para solucionar los problemas identificados.

Siguiendo esa misma línea, Niquen (2019) desarrolló un modelo orientado a la protección de la información sensible del paciente basado en la Norma ISO/IEC 27001, en respuesta a la ausencia de políticas y controles de seguridad en entidades del sector salud. Para ello, se analizaron estándares internacionales y se propusieron controles de seguridad aplicables al entorno

clínico. Los resultados evidenciaron una mejora en la protección de los datos y en la gestión de la seguridad de la información, demostrando la utilidad del modelo en instituciones de salud.

3.2.3 Locales

En su tesis, Calixto y Gonzáles (2019) desarrollaron una metodología de auditoría orientada a la protección de los datos en sistemas de administración de historias clínicas en el ámbito de la salud ocupacional. Para ello, Integraron estándares de seguridad de la información y normativas del sector salud, específicamente la ISO 27001:2014 y NT MINSA N° 22-2005 para crear un modelo que se pueda aplicar específicamente en la clínica Lezama de Salud Ocupacional. Definieron nueve procesos clave como el control de acceso, la gestión de privilegios, la accesibilidad y la confidencialidad de la información.

Los resultados evidenciaron que la aplicación de esta metodología permitió fortalecer los controles de seguridad y mejorar la protección de los datos clínicos, contribuyendo al cumplimiento de normativas y a una gestión más segura de la información. Si bien el estudio se desarrolló en un contexto de salud ocupacional, su enfoque basado en auditoría de sistemas y control de la seguridad de la información resulta aplicable como referencia para la evaluación de sistemas clínicos.

Por otro lado, Armas (2020) propuso un modelo de auditoría basado en estándares como ISO 19011, ISO 25000 y COBIT, para evaluar sistemas de información en el ámbito administrativo. Su enfoque se centró en la evaluación mediante indicadores como el porcentaje de errores, el tiempo de paralizaciones y la integridad de los datos. Los resultados evidenciaron un nivel de desempeño del 52%, permitiendo identificar deficiencias en el funcionamiento del sistema y la necesidad de fortalecer aspectos relacionados con la calidad e integridad de la información. El estudio concluye que la aplicación de modelos de auditoría facilita la identificación de brechas en los sistemas de información, contribuyendo a su mejora continua. Aunque el estudio se enfoca en un entorno administrativo, su enfoque de evaluación mediante auditoría e indicadores resulta relevante para el análisis de sistemas de información.

Finalmente, Poma (2019) desarrolló un plan de seguridad de la información para el Hospital Víctor Lazarte Echegaray en Trujillo, basado en el estándar ISO/IEC 27001, abordando aspectos como la recuperación y respaldo de datos, la gestión de redes y la respuesta ante incidentes de seguridad. Para desarrollar su propuesta se basó en el estándar ISO/IEC 27001, que le permitió evaluar y fortalecer principios clave como confidencialidad, disponibilidad e integridad de la información. Los resultados evidenciaron mejoras en los niveles de seguridad de la información, reflejadas en un incremento del 17.59% en la confidencialidad, 30.51% en la disponibilidad y 14.66% en la integridad de los datos. Si bien el estudio se centra en la implementación de un plan de seguridad, sus resultados permiten evidenciar el impacto de la aplicación de controles de seguridad sobre los niveles de confidencialidad, integridad y disponibilidad, los cuales constituyen criterios fundamentales también evaluados en la presente investigación.

3.3 Base teórica

3.3.1 Seguridad de la información

La seguridad de la información se refiere a un conjunto de medidas y prácticas diseñadas para proteger nuestros datos contra accesos no autorizados, alteraciones, destrucción o extravío. En estos tiempos, se ha vuelto fundamental, especialmente con el uso tan extendido de las tecnologías de la información. Cualquiera puede darse cuenta de que nuestra información personal y sensible está siempre en riesgo; se ha incrementado debido a la constante exposición de los datos en diversos ámbitos como el laboral, educativo, financiero y de salud (Vega Briceño, 2021).

Según Vega Briceño (2021), el uso intensivo de tecnologías de la información incrementa la exposición a riesgos de seguridad, como accesos no autorizados y pérdida de datos. En este contexto, resulta fundamental implementar controles y mecanismos de seguridad que permitan proteger la información, especialmente en sistemas que gestionan datos sensibles, como las historias clínicas informatizadas, en concordancia con los

lineamientos establecidos por normativas como la ISO/IEC 27002 y la NTS 139-MINSA-2018.

3.3.2 Seguridad de la información en Sistemas de Salud

La seguridad de la información en sistemas de salud se define como el conjunto de políticas, controles, procesos y tecnologías orientados a proteger la información clínica frente a accesos no autorizados, alteraciones, pérdidas o divulgación indebida, garantizando los principios de confidencialidad, integridad y disponibilidad. En este contexto, los sistemas de información en salud deben asegurar la protección de datos sensibles de los pacientes, en cumplimiento de normativas y regulaciones vigentes que resguardan la privacidad y la seguridad de la información (Organización Panamericana de la Salud, 2023).

De acuerdo con la Organización Panamericana de la Salud (2023), los sistemas de información en salud deben contar con mecanismos que aseguren tanto la confianza como la seguridad de los datos, respetando siempre los derechos a la privacidad. Se trata de encontrar un equilibrio entre dar acceso rápido a la información y proteger los datos personales. Esto fomenta una cultura que prioriza el manejo seguro y confiable de la información.

En este marco, la Organización Panamericana de la Salud (2023) destaca que es crucial implementar políticas públicas y establecer controles sobre el flujo de información clínica. También menciona que deben existir sistemas de monitoreo para detectar incidentes de seguridad. Además, es fundamental contar con planes de seguridad que estén alineados con las leyes vigentes y que incluyan capacitación continua para quienes gestionan estos datos. En este contexto, la seguridad de la información se posiciona como un componente clave en los sistemas de salud, al garantizar el cumplimiento de las normativas vigentes y contribuir al fortalecimiento de la confianza en el manejo de los datos clínicos, especialmente en lo referente a su confidencialidad, integridad y disponibilidad.

Por otro lado, está la norma ISO/IEC 27002:2022, que proporciona pautas para implementar controles basados en un análisis de riesgos. Su fin es proteger los activos informativos frente a amenazas internas y externas,

asegurando su confidencialidad, integridad y disponibilidad (Dirección de Normalización – INACAL, 2022).

Para empezar, garantizar la confidencialidad significa que solo usuarios autorizados puedan acceder a cierta información; así se evita compartir datos sensibles sin autorización. Luego tenemos la integridad, que busca mantener precisa y consistente la información evitando cambios no permitidos que podrían afectar decisiones importantes. Y finalmente está la disponibilidad: asegurar que los sistemas e información estén accesibles cuando se necesiten es vital hoy en día donde dependemos tanto de tecnología (Organización Panamericana de la Salud, 2023).

Es importante notar que estos tres principios no funcionan aisladamente; deben gestionarse juntos para ofrecer una protección completa. Aplicar controles según esta norma ayuda a las organizaciones a adoptar un enfoque estructurado basado tanto en riesgos identificados como en requisitos normativos.

La Norma Técnica de Salud 139-MINSA-2018 establece pautas específicas para la protección de la información en el sector salud. Su objetivo principal es resguardar los datos clínicos mediante la implementación de medidas orientadas a garantizar su confidencialidad, integridad y disponibilidad (MINSA, 2018). Asimismo, promueve la protección de la privacidad del paciente y el adecuado manejo de la información sensible conforme a los lineamientos normativos vigentes.

En este contexto se definen varios requisitos relacionados con cómo gestionar esta información: desde el manejo documental hasta controles para prevenir accesos no autorizados. También se subraya la importancia de aplicar medidas tecnológicas y organizativas para reducir riesgos e incluso asegurar continuidad operativa ante adversidades.

En comparación con la ISO/IEC 27002:2022, que presenta un enfoque de carácter internacional, la Norma Técnica de Salud 139-MINSA-2018 establece lineamientos específicos adaptados al contexto del sector salud a nivel nacional. Ambas normativas comparten principios orientados a la protección de la información, complementándose para fortalecer la gestión de la seguridad de la información en entornos clínicos.

En este contexto, la adecuada gestión de la información resulta fundamental para garantizar la continuidad operativa de las organizaciones, siendo necesario no solo su tratamiento adecuado, sino también la implementación de medidas de protección frente a riesgos que puedan comprometer su confidencialidad, integridad y disponibilidad. En este sentido, las auditorías de seguridad de la información se constituyen como un mecanismo clave para evaluar los controles implementados y verificar el cumplimiento de las normativas aplicables (Dávalos, 2013).

Una auditoría es básicamente un proceso estructurado destinado a evaluar qué tan efectivas son las medidas implementadas para proteger información sensible dentro de una entidad (Dávalos, 2013). Pero esto no solo abarca identificar vulnerabilidades tecnológicas; también revisa políticas y procedimientos organizacionales diseñados para asegurar esa confidencialidad e integridad deseadas. Como dice Aillón (2021), estas auditorías buscan verificar si las medidas realmente cumplen con las normativas pertinentes y ayudan a identificar fallas proponiendo mejoras.

La auditoría no se centra solo en lo tecnológico; también mira cuestiones organizacionales como las directrices o mejores prácticas internacionales aplicables al sector —especialmente relevante en salud donde proteger datos clínicos es esencial. Su objetivo es garantizar que todo esté alineado con normas internacionales como ISO/IEC 27002:2022 y locales como Norma Técnica 139-MINSA-2018 (MINSA, 2018).

Así las auditorías tienen un rol fundamental al evaluar cuán efectivas son esas iniciativas en práctica comprobando si realmente se cumplen lineamientos establecidos por diversas normativas.

Según INACAL (2022), hacer auditorías internas permite detectar áreas donde mejorar garantizando efectividad adecuada respecto controles implementados lo cual va más allá del cumplimiento normativo pues ayuda gestionar riesgos vinculados directamente a nuestra valiosa información sensible.

3.3.3 Sistema de Información de Historias Clínicas

Cuando una Institución prestadora de servicio de salud usa un sistema informático para gestionar historias clínicas, debe cumplir al menos con cinco

requisitos básicos: seguridad, confidencialidad, disponibilidad, integridad y autenticidad. Esto está establecido en la normativa peruana. Gracias a estos sistemas, los profesionales pueden registrar las atenciones directamente en la computadora en el momento de la consulta, y no es necesario imprimir ni mantener una historia clínica en papel. Además, el médico o profesional de salud debe identificarse con su firma digital (o firma electrónica) para refrendar lo registrado, mientras que otros usuarios de salud pueden usar firma electrónica. También es obligatorio que el profesional se autentique con sus propias credenciales de acceso, lo que permite dejar trazabilidad de cada dato registrado, asegurando que se haga una sola vez por atención (MINSA, 2018).

3.3.4 Modelo de Madurez de Capacidades Integrado (CMMI V2.2)

El Capability Maturity Model Integration (CMMI) constituye el estándar internacional de referencia para evaluar y mejorar la capacidad y el rendimiento de los procesos organizacionales. Desarrollado originalmente para el Departamento de Defensa de los Estados Unidos con el propósito de evaluar la calidad y capacidad de sus contratistas de software, el modelo CMMI ha expandido su alcance más allá de la ingeniería de software y es reconocido globalmente como el método comprobado para que organizaciones de cualquier industria y tamaño comprendan su nivel actual de capacidades, al tiempo que ofrece una hoja de ruta para optimizar y mejorar el rendimiento. Actualmente es administrado por ISACA como parte de sus soluciones de mejora del rendimiento empresarial (ISACA, 2024).

El CMMI define cinco niveles de madurez:

- Inicial (1): Procesos impredecibles, mal controlados, reactivos.
- Gestionado (2): Proyectos gestionados, pero aún no estandarizados.
- Definido (3): Procesos organizacionales establecidos y documentados.
- Gestionado cuantitativamente (4): Procesos medidos y controlados con datos objetivos.
- En optimización (5): Mejora continua basada en métricas e innovación.

y provee prácticas y directrices para mejorar el rendimiento de los procesos; cuando se aplica al ámbito de la seguridad informática, facilita la identificación de áreas en las que los procesos de ciberseguridad presentan menor eficiencia, y traza un camino estructurado hacia su mejora (Gomes & Romão, 2025). Esta capacidad diagnóstica hace del CMMI V2.2 un marco adecuado para calificar el nivel de implementación de controles de seguridad dentro de un instrumento de auditoría diseñado para verificar el cumplimiento de normas técnicas en organizaciones del sector salud.

Finalmente, la evaluación CMMI se enfoca en identificar oportunidades de mejora y comparar los procesos de la organización con las mejores prácticas del modelo; los equipos evaluadores emplean el método conforme al documento Appraisal Requirements for CMMI (ARC) para guiar su evaluación y el reporte de conclusiones (Wikipedia, 2024). Esta rigurosidad metodológica, sumada a la flexibilidad del modelo para adaptarse a diferentes sectores y marcos normativos, sustenta su elección como metodología de calificación en el presente instrumento de auditoría de seguridad de la información y cumplimiento a la norma técnica de salud (CMMI Institute, 2020).

3.4 Definición de términos básicos

- **Auditor:**

En concordancia con Aillón (2021), a cabo una auditoría, verificando que las medidas de seguridad y control en los sistemas informáticos estén alineadas con las normativas de protección de datos.

- **Auditoría:**

Según Dávalos (2013), una auditoría se define como un proceso estructurado, independiente y debidamente documentado, cuya finalidad es recopilar evidencias y evaluarlas de manera objetiva para determinar el grado de cumplimiento de los criterios establecidos.

- **Conclusiones de la auditoría:**

En concordancia con Aillón (2021), las conclusiones de una auditoría se derivan tras considerar los objetivos de la auditoría y los hallazgos obtenidos.

- **Confidencialidad:**

De acuerdo con la Dirección de Normalización – INACAL (2022) y la MINSA (2018) la confidencialidad se define como la cualidad que garantiza que la información no sea accesible ni divulgada a personas, entidades o procesos sin autorización.

- **Criterio de auditoría:**

En base a Aillón (2021), los criterios de auditoría se definen como el conjunto de requisitos que sirven de referencia para comparar la evidencia obtenida durante la auditoría.

- **Disponibilidad:**

Según la Dirección de Normalización – INACAL (2022), la disponibilidad es la propiedad de que la información sea accesible y utilizable a demanda por una entidad autorizada.

- **Evidencia de la auditoría:**

En concordancia con Aillón (2021), menciona que la evidencia de auditoría incluye registros, declaraciones de hechos u otra información relevante para los criterios de auditoría y que son verificables.

- **Hallazgos de la auditoría:**

En concordancia Aillón (2021), los hallazgos de la auditoría son el resultado de la evaluación de la evidencia recopilada frente a los criterios de auditoría.

- **Integridad:**

Según la Dirección de Normalización – INACAL (2022) y MINSA (2018), la integridad es la propiedad de exactitud y completitud de la información.

- **Mejora continua:**

En base a los principios de la Dirección de Normalización – INACAL (2022), la mejora continua es una actividad recurrente destinada a mejorar el rendimiento de los sistemas y procesos.

- **Plan de auditoría:**

De acuerdo con Aillón (2021), un plan de auditoría es una descripción de las actividades y arreglos para llevar a cabo una auditoría de seguridad de la información.

- **Proceso:**

En el contexto de Dirección de Normalización – INACAL (2022), un proceso es un conjunto de actividades interrelacionadas o interactuantes que transforman los insumos en productos.

- **Seguridad de la información:**

Según Vega (2021) y la Dirección de Normalización – INACAL (2022), la seguridad de la información consiste en garantizar la confidencialidad, integridad y disponibilidad de la información.

- **Sistema de información:**

De acuerdo con la MINSA (2018), incluye aplicaciones, servicios y recursos tecnológicos que permiten gestionar la información de forma segura dentro de una organización.

4 MARCO METODOLÓGICO

4.1 Tipo de investigación

- De acuerdo a la orientación o finalidad: Aplicada.
- De acuerdo a la técnica de contrastación: No experimental.
- De acuerdo al nivel de investigación: Descriptiva.

4.2 Nivel de madurez tecnológica

La investigación aplicada busca resolver un problema real y concreto en un contexto específico. En este caso, el problema es la brecha entre el nivel 3 actual y un nivel 4 (gestionado y medido), del Sistema de Gestión de Análisis Clínicos (SIGAC) ha estado en funcionamiento en IMEQSA S.A.C. desde 2019. Lo han estado usando de manera continua para procesos como admisión, facturación y tanto en las etapas preanalíticas como post-analíticas. Aunque el sistema ha mostrado una buena estabilidad y se ha adaptado bastante bien a los flujos de trabajo internos, todavía depende de un tercero para su administración y actualizaciones. Eso limita un poco el control que tiene la institución sobre su evolución tecnológica.

Además, hay una necesidad bastante clara de mejorar la seguridad de la información y cumplir con las normativas pertinentes. Por ello la presente investigación es un diagnóstico y propone recomendaciones concretas para ayudar a alcanzar un nivel superior de madurez tecnológica que esté alineado

con estándares internacionales como la ISO/IEC 27002:2022 y las regulaciones nacionales en salud.

4.3 Método de investigación

El presente estudio emplea el método de estudio de caso, con un enfoque cualitativo y descriptivo, ya que se analiza en profundidad el sistema SIGAC implementado en IMEQSA S.A.C.

Para la calificación de la madurez de los dominios de seguridad se adaptó la escala de niveles de madurez del modelo CMMI V2.2. Esta adaptación permitió clasificar el grado de implementación de los controles de confidencialidad de la siguiente manera: Nivel 3 (Definido) cuando el control está estandarizado y documentado; Nivel 4 (Gestionado cuantitativamente) cuando además se mide su desempeño; y Nivel 5 (En optimización) cuando se mejora continuamente. Los niveles 1 y 2 (Inicial y Gestionado) se agruparon en la categoría Cumple (> 80%), Cumple parcialmente (60% - 80%), No cumple (< 60%). Esta adaptación metodológica se sustenta en que CMMI ha sido utilizado previamente en contextos de auditoría de sistemas de información para evaluar la consistencia de los controles implementados (CMMI Institute, 2020).

4.4 Diseño de Estudio

El diseño de esta investigación es no experimental y descriptivo de estudio de caso.

4.5 Población y Muestra

Dado que el presente estudio corresponde a una auditoría de sistema bajo el enfoque de estudio de caso, no se define una población ni una muestra. El objeto de estudio es el Sistema de Gestión de Análisis Clínicos (SIGAC) implementado en IMEQSA S.A.C.

4.6 Técnicas e instrumentos de recolección datos

- **Entrevista:**

Conversatorio sobre procedimientos de gestión relacionados a la seguridad del Sistema información de gestión de análisis clínicos con el auditado.

- **Observación:**

Se realizarán visitas a las instalaciones de la empresa para observar la forma de operar del personal.

- **Revisión de documentos:**

Verificación de la evidencia de los registros de acuerdo a procedimientos, en cumplimiento Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.

4.7 Procedimiento de ejecución del estudio

Tabla 1: *Procedimiento del diseño de investigación*

Fase	Actividad	Entregable
Planificación	● Definir el alcance de la investigación y los objetivos específicos. ● Identificar y seleccionar fuentes de información relevantes (normativas, documentos, estudios previos). ● Elaborar un cronograma de trabajo.	Documento de planificación y cronograma.
Ejecución	● Recolección de datos documentales a partir de la revisión de normativas ● Análisis de la información recopilada para identificar patrones y categorías relevantes en la seguridad del sistema de gestión de análisis clínicos. ● Comparación de las prácticas actuales del sistema mediante un checklist de auditoría, elaborados en base a los controles establecidos en la Norma Técnica de Salud 139-MINSA-2018 y la Norma Técnica Peruana ISO/IEC 27002:2022, con la finalidad de determinar el nivel o grado de cumplimiento del sistema.	Informe de Auditoria
Redacción de resultados	● Elaborar un informe que sintetice los hallazgos de la investigación. ● Presentar recomendaciones basadas en los resultados obtenidos y su relación con la seguridad de la información en los sistemas de salud. ● Incluir un análisis crítico de las implicaciones de los hallazgos en el contexto institucional y legal.	Conclusiones y recomendaciones

4.8 Técnicas de procesamiento y análisis de datos

- Se realizará una entrevista al jefe de operaciones y Responsable de TI para evaluar el nivel de cumplimiento de Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
- Mediante la técnica de observación, se registrará los hallazgos de auditoria con respecto a software, hardware, infraestructura de red, procedimientos y registros.
- Los resultados de la auditoria serán recopilados y clasificados en Oportunidades de Mejora, Fortalezas y observaciones por incumplimientos de Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
- Se aplicará estadística descriptiva en la cuantificación para la presentación de resultados.

5 PRESENTACIÓN DE RESULTADOS

5.1 Informe de Auditoría

La auditoría que se llevó a cabo en IMEQSA S.A.C., una institución de salud, tuvo como propósito determinar el nivel de cumplimiento de los controles de seguridad de la información y los sistemas informáticos que usan para atender a los pacientes. Para esto, se tomaron como referencia la Norma Técnica de Salud NTS N° 139-MINSA/2018/DIGESA y la ISO/IEC 27002:2022.

El enfoque de la auditoría se centró en el Sistema de Gestión de Análisis Clínicos. Para hacer esto, se utilizó una lista de verificación y se aplicó una metodología que incluyó entrevistas, observaciones y la revisión de documentos. Al final del proceso, se encontraron varios hallazgos; algunos reflejaban fortalezas, mientras que otros señalaban oportunidades para mejorar y algunas observaciones que valía la pena tener en cuenta.

a) Fortalezas

1. El SIGAC de IMEQSA S.A.C. se encuentra alojado en la nube de Microsoft Azure, cumplen los estándares del sector en materia de seguridad en confiabilidad, integridad y disponibilidad, como ISO/IEC 27001:2013 y NIST SP 800-53.
2. El personal responsable del SIGAC conoce acerca de la seguridad de la información y entiende los compromisos de la organización por cumplir las normas de salud.
3. Se siguen buenas prácticas de desarrollo y mantenimiento del SIGAC, realizando un control de calidad sobre la gestión de cambios antes de elevarlo a producción.

b) Oportunidades De Mejora

1. Considerar realizar la documentación de análisis y diseño del SIGAC, para garantizar el mantenimiento del software en el tiempo.

2. Considerar realizar los manuales de usuario del SIGAC, como control en el ingreso de datos por parte de los usuarios.
3. Considerar regularizar el derecho de propiedad intelectual de IMEQSA S.A.C. sobre el SIGAC ante INDECOPI.
4. Implementación de controles administrativos como cláusulas en los contratos sobre el acceso al código fuente, declaraciones de confidencialidad de la información; para el personal o proveedores que tienen acceso al código fuente del SIGAC.
5. Implementar declaraciones juradas sobre uso de firma digital en el SIGAC, del personal de salud.
6. Realizar inventario y tener un programa de mantenimiento de Equipos tecnológicos, para garantizar el correcto acceso al SIGAC.
7. Contar con un archivo de consentimientos, declaraciones y otros formatos físicos manuscritos de acuerdo a norma técnica de salud para acceso solo de personal de salud autorizado.

c) Observaciones

1. Uso de imágenes de firmas en historias clínicas:

➤ **Criterio:**

El numeral 5.3.3, ítem d) de la NTS N° 139-MINSA-2018 establece que se deben utilizar firmas electrónicas de acuerdo a la normativa legal vigente (Ley N° 27269 y su reglamento) para garantizar la validez y autenticidad de los registros.

➤ **Condición:**

Se verificó que el Sistema de Gestión de Análisis Clínicos (SIGAC) utiliza firmas escaneadas asociadas al usuario, mas no firmas electrónicas certificadas conforme a la normativa indicada.

➤ **Evidencia:**

En los documentos clínicos revisados dentro del SIGAC se observan imágenes escaneadas de las firmas, sin contar con respaldo de certificados digitales emitidos por un Proveedor de Servicios de Certificación acreditado por INDECOPI.

➤ **Causa:**

La situación se origina por la falta de implementación tecnológica para integrar certificados digitales, el desconocimiento del requisito legal y la ausencia de directivas internas que regulen el uso obligatorio de firmas electrónicas.

➤ **Efecto:**

Esta condición genera riesgo legal y regulatorio, posibilidad de observaciones por parte de la autoridad sanitaria o auditorías externas, y vulnerabilidad en la integridad y autenticidad de los documentos, al no contar con mecanismos que garanticen validez jurídica.

2. Identificación de la historia clínica:

➤ **Criterio:**

El numeral 4.2.23 de la NTS N° 139-MINSA-2018 establece que en la identificación de exámenes debe figurar como código de historia clínica el número de documento de identidad del paciente, a fin de permitir el acceso al historial completo de exámenes dentro de la IPRESS.

➤ **Condición:**

Se evidenció que el SIGAC utiliza un código de examen en barras para la identificación de las pruebas, pero no incorpora el número de documento de identidad del paciente como código de historia clínica, conforme al requisito normativo.

➤ **Evidencia:**

Durante la revisión de exámenes registrados en el SIGAC, se verificó que la etiqueta y el registro digital muestran únicamente el código interno en barras, sin el DNI del paciente asociado al historial clínico.

➤ **Causa:**

Esta situación se debe a limitaciones en la configuración del sistema para mostrar el DNI como código de historia clínica, así como a la falta de actualización del software y a la ausencia de un procedimiento que exija esta funcionalidad.

➤ **Efecto:**

La no inclusión del DNI como código de historia clínica impide garantizar la trazabilidad completa del historial de exámenes del

paciente en la IPRESS IMEQSA S.A.C., generando riesgo de duplicidad de información, retrasos en la atención y posibles incumplimientos normativos ante auditorías o supervisiones sanitarias.

5.2 Resultados

5.2.1 Nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C.

Se revisó el cumplimiento usando el CheckList de la Norma Técnica de Salud 139-MINSA-2018 y la Norma Técnica Peruana ISO/IEC 27002:2022 (Anexo 9.2.1). Los resultados se muestran en la tabla 2:

Tabla 2: Resultados del CheckList de Cumplimiento de NTS 139-2018 MINSA Y NTP ISO/IEC 27002:2022 (Anexo 9.2.1)

Calificación de la auditoría según NTS 139-2018 MINSA e ISO 27001:2022	Nivel de madurez (1-5) \ CMMI V2.2					Promedio Ponderado	Nivel de Cumplimiento
	Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)		
Gobernanza y Gestión de Seguridad de la Información	0	1	5	7	0	3.46	69%
Gestión de Incidentes de Seguridad	0	0	3	0	0	3.00	60%
Gestión de Activos de Información	0	1	0	2	0	3.33	67%
Evaluación de Cumplimiento Legal y Normativo	0	0	2	9	2	4.00	80%
Control de Acceso a la Información	0	2	2	9	1	3.64	73%
Continuidad del Servicio y Respaldo de Información	0	0	0	5	2	4.29	86%
Concientización y Capacitación	0	2	2	3	2	3.56	71%
TOTALES	0	6	14	35	7		72%
CALIFICACION GLOBAL DE LA AUDITORIA: Cumple (> 80%), Cumple parcialmente (60% - 80%), No cumple (< 60%)							

El sistema alcanzó un cumplimiento global del 72%. Esto lo coloca en la categoría de "Cumple parcialmente" según la escala que tenemos. En resumen, aunque hay controles en su lugar que ayudan a proteger la

información clínica en general, todavía hay algunas áreas donde se necesita mejorar, especialmente en la gestión de incidentes y en formalizar ciertos procedimientos.

5.2.2 Cumplimiento de confiabilidad de la gestión de las historias clínicas informatizadas

Para lograr el objetivo, se revisó cuánto se alineaba el SIGAC con las pautas de la NTP ISO/IEC 27002:2022 y la Norma Técnica de Salud 139-MINSA-2018. Hicimos esto utilizando una lista de verificación de auditoría bien estructurada.

Tabla 3: Resultados Confidencialidad del CheckList de Cumplimiento de NTS 139-2018 MINSA Y NTP ISO/IEC 27002:2022 (Anexo 9.2.1)

CALIFICACION DE LA AUDITORIA SEGUN NTS 139-2018 MINSA Y ISO 27001:2022	Nivel de madurez (1-5) \ CMMI V2.2						
	Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)	Promedio ponderado	Nivel de cumplimiento
Control de Acceso a la Información	0	2	2	9	1	3.64	73%
TOTAL							72%
CALIFICACION GLOBAL DE LA AUDITORIA: Cumple (> 80%), Cumple parcialmente (60% - 80%), No cumple (< 60%)							

Los resultados que se ven en la Tabla 3 muestran que el control de acceso a la información del sistema, que se relaciona con el pilar de seguridad y confidencialidad, tiene un cumplimiento global del 73%. Esto lo sitúa en la categoría de "Cumple parcialmente" según la escala de valoración que se utilizó. Según los controles 6.1, 6.5, 7.3, 7.1, 8.19, 5.18, 5.15 y 5.17 de la NTP ISO/IEC 27002:2022, junto con los puntos 4.2 y 5.3.3 de la NTS 139-2018 del MINSA, el SIGAC está protegido contra accesos no autorizados. Los usuarios tienen un acceso restringido; solo los profesionales de salud autorizados pueden registrar directamente la información. Además, esto garantiza la autenticación y trazabilidad de esos profesionales ya que está alojado en la nube de Microsoft Azure, cumpliendo con los estándares del sector en cuanto a seguridad, confiabilidad, integridad y disponibilidad, como son ISO/IEC 27001 y NIST SP 800-53. También refleja que se están gestionando los permisos adecuados mediante solicitudes por correo desde la gerencia general a los usuarios. Sin embargo, se identificó un

incumplimiento en el punto 5.3.4 de la NTS 139-2018 sobre el uso de firmas electrónicas y también en los controles 5.16 y 8.4 de la NTP ISO/IEC 27002:2022 relacionados con las cláusulas en contratos sobre el acceso al código fuente y declaraciones de confidencialidad para el personal o proveedores que tienen acceso a dicho código del SIGAC. Esto nos dice que, aunque el sistema cumple en términos generales con los requisitos normativos, todavía hay espacio para mejorar los controles operativos y así asegurar una gestión más confiable de las historias clínicas informatizadas para alcanzar niveles más altos de madurez en el futuro.

5.2.3 Cumplimiento de la Integridad en la gestión de las historias clínicas informatizadas

Para lograr este objetivo, revisamos los lineamientos de los controles de seguridad que se aplican en el SIGAC, basándonos en la NTP ISO/IEC 27002:2022 y la Norma Técnica de Salud 139-MINSA-2018. Aquí están los resultados que obtuvimos:

Tabla 4:
Resultados Integridad del CheckList de Cumplimiento de NTS 139-2018 MINSA Y ISO 27001:2022 (Anexo 9.2.1)

CALIFICACION DE LA AUDITORIA SEGUN NTS 139-2018 MINSA Y ISO 27001:2022	Nivel de madurez (1-5) \ CMMI V2.2						Promedio ponderado	Nivel de cumplimiento
	Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)			
Evaluación de Cumplimiento Legal y Normativo	0	0	2	9	2	4.00	80%	
TOTAL								80%
CALIFICACION GLOBAL DE LA AUDITORIA: Cumple (> 80%), Cumple parcialmente (60% - 80%), No cumple (< 60%)								

Los resultados que vemos en la Tabla 4 revelan que el nivel global de cumplimiento es del 80%. Esto se traduce en un "Cumple Parcialmente", lo que significa que el sistema tiene algunos controles de seguridad en su lugar que, en términos generales, cumplen con los estándares internacionales.

Según los controles 8.3 de la NTP ISO/IEC 27002:2022 y otros puntos específicos de la NTS 139-2018 MINSA, el SIGAC parece estar alineado con los criterios necesarios para garantizar la integridad de la historia clínica informatizada. Por ejemplo, hay una buena custodia de Backus y documentos almacenados en la nube. Además, está claro que el sistema es

propiedad de IMEQSA S.A.C., que se encarga de aplicar controles de seguridad en el código para evitar el repudio de la historia clínica.

Sin embargo, se encontraron fallos en dos aspectos: el 4.2.1 y el 4.2.6 de la NTS 139-2018 MINSA relacionados con la identificación del número de historia clínica. También hubo problemas con el control 5.12 de NTP ISO/IEC 27002:2022 sobre la clasificación de la información, lo que ha dificultado una trazabilidad rápida del historial clínico.

En resumen, aunque el SIGAC tiene controles de seguridad funcionales y está al límite superior del "Cumple Parcialmente", hay diferencias notables cuando se trata de completar la identificación en el sistema. Esto realmente pone de manifiesto la necesidad urgente de mejorar la gestión sobre la integridad y seguridad de la información.

5.2.4 Cumplimiento de la disponibilidad en la gestión de las historias clínicas informatizadas

Después de revisar cómo funciona el SIGAC en la gestión y protección de los datos sensibles de los pacientes, y teniendo en cuenta los requisitos de disponibilidad que marcan la NTS 139-MINSA-2018 y la NTP ISO/IEC 27002:2022, se llegaron a las siguientes conclusiones:

Tabla 5:
Resultados Disponibilidad del CheckList de Cumplimiento de NTS 139-2018 MINSA Y ISO 27001:2022 (Anexo 9.2.1)

CALIFICACION DE LA AUDITORIA SEGUN NTS 139-2018 MINSA Y ISO 27001:2022	Nivel de madurez (1-5) \ CMMI V2.2						Promedio ponderado	Nivel de cumplimiento
	Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)			
Gestión de Incidentes de Seguridad	0	0	3	0	0	3.00	60%	
Gestión de Activos de Información	0	1	0	2	0	3.33	67%	
Continuidad del Servicio y Respaldo de Información	0	0	0	5	2	4.29	86%	
TOTAL							71%	
CALIFICACION GLOBAL DE LA AUDITORIA: Cumple (> 80%), Cumple parcialmente (60% - 80%), No cumple (< 60%)								

Los resultados que se muestran en la Tabla 5 indican que el sistema tiene un cumplimiento global del 71%, lo que lo sitúa en la categoría de "Cumple

Parcialmente" según la escala de valoración. Esto sugiere que, aunque hay controles en su lugar para proteger la información clínica de forma general, los niveles de madurez varían entre los diferentes dominios evaluados.

El sistema cumple con varios controles como los 8.25, 8.13, 8.34 y 5.24 de la NTP ISO/IEC 27002:2022, así como con puntos específicos de la NTS 139-2018 MINSA relacionados con el SIGAC. Estos aseguran que la historia clínica informatizada esté disponible. Por ejemplo, el sistema tiene un plan de recuperación ante incidentes y asegura que toda la información sea trazable y auditable.

Sin embargo, se encontró un incumplimiento en el criterio del plan de recursos del SIGAC según el punto 4.2.2 de la NTS 139-2018 MINSA, además de algunos controles como el 5.27, 7.4 y 5.9 de la NTP ISO/IEC 27002:2022, donde no se tiene actualizado el inventario de activos de Tecnología de Información ni el procedimiento para actuar frente a incidentes detectados por videovigilancia.

Al analizar la disponibilidad por dimensiones, se observa que los dominios que mejor desempeño tienen son Continuidad del Servicio y Respaldo de Información, alcanzando un 86%. Esto muestra que hay mecanismos sólidos para garantizar la disponibilidad de información y cumplir con las normativas sobre manejo de datos clínicos. En cambio, los dominios Control de Gestión de Incidentes de Seguridad (60%) y Gestión de Activos de Información (67%) están en un nivel "Cumple Parcialmente". Estos aspectos necesitan más estructura, monitoreo y sistematización para fortalecer una cultura organizacional robusta en lo que respecta a la seguridad y disponibilidad de la información.

5.2.5 Recomendaciones en la gestión de historias clínicas informatizadas:

Según el análisis sobre cómo se está cumpliendo con el SIGAC y lo que dice la Norma Técnica de Salud 139-MINSA-2018, así como la Norma Técnica Peruana ISO/IEC 27002:2022, se hicieron algunas recomendaciones. Estas están enfocadas en reforzar los controles de seguridad de la información y en subir el nivel de madurez de tres indicadores clave: Confidencialidad, Integridad y Disponibilidad. También se evalúa el sistema en los diferentes

dominios. Los resultados se pueden ver en la tabla a continuación, donde se detallan las sugerencias para mejorar cada aspecto que se revisó durante la auditoría de seguridad.

Tabla 6:
Recomendaciones de acuerdo a aspectos de seguridad

CLASIFICACION DE LOS ASPECTOS DE LA AUDITORIA DE SEGURIDAD	RECOMENDACIONES
Gobernanza y Gestión de Seguridad de la Información	Uso de firma digital para los profesionales de salud en el sistema de Historias Clínicas Electrónicas en conformidad a ítem 5.3.4 de la NTS 139-2018/MINSA y 8.15 NTP ISO/IEC 27002:2022
Gestión de Incidentes de Seguridad	Mantener la realización de los procedimientos de acuerdo 4.2.2 NTS 139-2018/MINSA y 7.4 NTP ISO/IEC 27002:2022
Gestión de Activos de Información	Se recomienda mantener actualizado el inventario de equipos de acuerdo 5.9 NTP ISO/IEC 27002:2022 y 4.2.2 NTS 139-2018/MINSA
Evaluación de Cumplimiento Legal y Normativo	Se sugiere cumplir ítem 4.2.21 de la NTS 139-2018/MINSA y 5.12 9 NTP ISO/IEC 27002:2022 sobre el uso de DNI como Código de Historia Clínica
Control de Acceso a la Información	Integrar el SIGAC con un proveedor autorizado por Indecopi para firmas electrónicas de acuerdo ítem 5.3.4 de la NTS 139-2018/MINSA y 5.17 NTP ISO/IEC 27002:2022
Continuidad del Servicio y Respaldo de Información	Mantener las buenas prácticas implementadas
Concientización y Capacitación	Sugerimos la aplicación de controles 8.33 NTP ISO/IEC 27002:2022 administrativos en el personal freelance que participa en el mantenimiento del SIGAC.

6.3 Discusión de Resultados

➤ **Acerca del cumplimiento de confiabilidad de la gestión de las historias clínicas informatizadas:**

Al analizar cómo el SIGAC se está comportando en cuanto a la seguridad de la información, pudimos ver los resultados a través del indicador de confiabilidad de las historias clínicas informatizadas. Resulta que hay cuatro áreas donde no se cumple, lo que representa un 27% en términos de Control de Acceso a la Información. Por otro lado, hay cinco áreas que sí cumplen, lo que equivale al 73%. Así que, en general, podemos decir que está cumpliendo parcialmente con lo que establecen las normas NTP ISO/IEC 27002:2022 y la Norma Técnica de Salud 139-MINSA-2018.

Se evidencia que el SIGAC cuenta con una infraestructura tecnológica basada en servicios en la nube de Azure, la cual cumple con estándares internacionales de seguridad de la información, tales como ISO/IEC 27001, HIPAA, FedRAMP, SOC 1 y SOC 2. Esta afirmación se sustenta en las certificaciones y auditorías externas realizadas a dicho proveedor, lo que

garantiza la implementación de controles de seguridad orientados a la protección de la información. Este proveedor se encarga de diseñar y administrar su tecnología para cumplir con un montón de estándares internacionales y específicos del sector, como ISO 27001, HIPAA, FedRAMP, SOC 1 y SOC 2. Además, también sigue normas locales o regionales como IRAP en Australia, G-Cloud en el Reino Unido y MTCS en Singapur. Las auditorías llevadas a cabo por terceros, como las del Instituto Británico de Normalización, confirman que están cumpliendo con todos esos estrictos controles de seguridad.

Sin embargo, hay que mencionar que el SIGAC cumple parcialmente en términos de confidencialidad según lo que dicen las mismas normas. Aún presenta algunas brechas en los controles administrativos que IMEQSA S.A.C no ha establecido. Esto es preocupante porque se considera un riesgo medio cuando se analiza la frecuencia versus la probabilidad, especialmente con el personal que apoya el desarrollo del sistema. Esta situación puede poner en duda la confiabilidad del sistema. Y esto concuerda con lo que dice Baldera (2025), quien señala que las debilidades organizacionales aumentan el nivel de riesgo en los sistemas clínicos informatizados.

➤ **Acerca del cumplimiento de la Integridad en la gestión de las historias clínicas informatizadas:**

La evaluación de los controles de seguridad en el SIGAC, en línea con lo que recomienda la NTS 139-MINSA-2018 y la NTP ISO/IEC 27002:2022, nos permitió analizar cómo están funcionando las historias clínicas informatizadas. Al revisar los indicadores de cumplimiento, encontramos dos fallas, lo que equivale al 20% en la Evaluación de Cumplimiento Legal y Normativo sobre integridad. Por otro lado, hubo 11 casos que sí cumplieron, representando el 80%. Esto nos lleva a clasificar el resultado como "Cumple parcialmente" según los lineamientos de las normas mencionadas.

Lo bueno es que estos resultados sugieren que el SIGAC tiene un riesgo bajo cuando se trata de integridad, tanto en su ocurrencia como en su probabilidad. Sin embargo, coincido con lo que dice Mazorra (2019) en su estudio sobre la implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) ISO/IEC 27001 en hospitales públicos de Ecuador. Él destaca cómo un SGSI puede ayudar a reducir los riesgos relacionados con

la privacidad de los pacientes, además de modernizar las políticas de seguridad y fomentar una cultura institucional más fuerte en torno a este tema.

Pero hay un área donde podemos mejorar: la formalización documental y la actualización de manuales. Esto resalta la necesidad urgente de fortalecer la gobernanza normativa para asegurar que tengamos consistencia y trazabilidad en la gestión de datos sensibles.

➤ **Acerca del cumplimiento de la disponibilidad en la gestión de las historias clínicas informatizadas:**

La capacidad del SIGAC para manejar la disponibilidad de la historia clínica, según lo que marcan las normativas NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022, está apenas al 71%. Esto significa que hay un 29% de incumplimientos, lo que realmente subraya un riesgo medio en términos de ocurrencia y probabilidad. La verdad es que hace falta mejorar los mecanismos para asegurar que el sistema esté siempre disponible.

Coincido con lo que mencionan Dávila y Dextre (2021), que es clave implementar una estrategia sólida para gestionar vulnerabilidades en la infraestructura de TI de la policlínica. Resaltaron la importancia de contar con herramientas como Qualys Guard, contratar profesionales que sepan de seguridad de la información y, no menos importante, fomentar una cultura de conciencia sobre seguridad entre todo el personal.

➤ **Acerca de las recomendaciones en la gestión de historias clínicas informatizadas:**

Según el análisis y las recomendaciones para mejorar el SIGAC, que surgieron durante la auditoría de seguridad, se logró un 72% de cumplimiento parcial y un 28% de no cumplimiento con respecto a lo que establece la NTP ISO/IEC 27002:2022 y la Norma Técnica de Salud 139-MINSA-2018. Se observó que el sistema tiene condiciones técnicas adecuadas para proteger la información clínica en un entorno tecnológico confiable. Esto se debe, en gran parte, al uso de infraestructura en la nube que cumple con estándares internacionales de seguridad. Sin embargo, hay un punto crítico: la implementación incompleta de mecanismos normativos, como el uso obligatorio del DNI como identificador único para las historias clínicas. Esto limita el nivel de integridad y consistencia que se podría

alcanzar en los registros. En cuanto a la gestión de datos clínicos, se comprobó que el SIGAC tiene herramientas suficientes para almacenar, procesar y recuperar información médica. Eso demuestra que hay fortalezas en cuanto a la continuidad del servicio y el respaldo de datos. Este resultado sugiere que la parte del sistema relacionada con el indicador de integridad es la más sólida. Poma (2019) ya había señalado que implementar ISO 27001 no solo mejoró notablemente la gestión de seguridad en el hospital, sino que también generó propuestas para futuras mejoras y evaluaciones dentro de EsSalud. Esto reafirma lo importante que es tener una buena gestión de la seguridad de la información en nuestras instituciones de salud pública.

6.4 Conclusiones

1. Hablando de la confidencialidad en la gestión de historias clínicas digitalizadas, encontramos que hubo 4 incumplimientos, lo que representa un 27% del control de acceso a la información. Por otro lado, hay 5 casos que cumplen, que representan el 73%. Esto nos lleva a decir que se está cumpliendo parcialmente con los lineamientos de la NTP ISO/IEC 27002:2022 y la Norma Técnica de Salud 139-MINSA-2018. Sin embargo, hay algunas brechas importantes, como el hecho de no usar el número de documento de identidad como código para las historias clínicas y cuestiones sobre la validez legal de las firmas electrónicas. Estos son detalles que limitan la confianza total en los registros digitales.
2. En cuanto a la integridad en la gestión de estas historias clínicas informatizadas, se detectaron 2 incumplimientos, lo que representa un 20% en la evaluación legal y normativa sobre integridad. En contraste, hay 11 cumplimientos, o sea un 80%, lo que también indica un cumplimiento parcial según las normas mencionadas antes. Se notaron fortalezas técnicas al usar Microsoft Azure en la nube, ya que cumple con estándares internacionales como ISO/IEC 27001 y NIST SP 800-53. Pero también se vieron debilidades en los controles administrativos y de gestión. Por ejemplo, faltan políticas formales sobre el acceso al código fuente y no hay cláusulas de

confidencialidad en los contratos, además de que la documentación técnica es limitada, lo que genera un riesgo bajo en integridad.

3. Al revisar la disponibilidad de las historias clínicas según lo indicado en las normas NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022, encontramos que cumple parcialmente con un 71%. Aunque el sistema tiene mecanismos para respaldar datos y controlar accesos, todavía hay limitaciones en áreas como la segregación de funciones, gestión de identidades digitales y registro de validaciones. Estas fallas pueden impactar negativamente en cómo se cumple con los requisitos de disponibilidad establecidos por las normas.
4. Se hicieron varias recomendaciones para mejorar el nivel tecnológico y normativo del SIGAC. Se priorizaron acciones como implementar firmas electrónicas certificadas, crear documentación técnica y manuales para usuarios, formalizar políticas de seguridad y regularizar la propiedad intelectual del sistema. Estas medidas ayudarán a fortalecer la gobernanza sobre la seguridad de la información y facilitarán avanzar hacia una conformidad completa con las normativas aplicadas.

6.5 Recomendaciones

6.5.1 Recomendaciones dirigidas a la empresa IMEQSA S.A.C.

- Desarrollar e implementar un programa formal de auditorías internas periódicas de seguridad de la información en el sistema SIGAC que contemple cronogramas definidos responsables métricas de seguimiento; con la finalidad de evaluar la conformidad de los controles establecidos en la NTS 139-MINSA-2018 y la NTP ISO/IEC 27002:2022.
- Integrar en la estructura del sistema SIGAC mecanismos de firma digital certificada para los profesionales de salud que registran información en el sistema; según lineamientos normativos vigentes fortalecer la autenticidad la integridad y trazabilidad de las historias clínicas electrónicas.
- Realizar actualizaciones anuales en la documentación técnica del Sistema SIGAC, incluyendo manuales de usuario, políticas de seguridad y procedimientos operativos, a fin de reducir brechas de cumplimiento relacionadas con la gobernanza de la información.

- Definir controles administrativos y contractuales específicos para el personal externo o freelance que interviene en el mantenimiento del sistema, incluyendo niveles de acceso confidencialidad y responsabilidades sobre el tratamiento de datos sensibles.
- Elaborar e implementar un plan documentado de continuidad operativa y recuperación ante desastres para el sistema SIGAC; incluyendo escenarios de fallos tecnológicos incidentes de seguridad y pérdida de datos; además de realizar pruebas periódicas de verificación.

6.5.2 Recomendaciones dirigidas a futuras investigaciones

- Ampliar el alcance metodológico incorporando variables complementarias relacionadas con la gestión de riesgos, la cultura organizacional de seguridad y la madurez digital institucional, a fin de obtener análisis más integrales sobre la seguridad de sistemas clínicos informatizados.
- Incluir en futuros estudios la evaluación comparativa con otros sistemas de gestión clínica utilizados en el sector salud, lo que permitiría establecer niveles de referencia y modelos de buenas prácticas aplicables al contexto nacional.

7 REFERENCIAS BIBLIOGRAFICAS

- Aillón Carrasco, M. E. (2021). *Auditoria de seguridad de la información aplicando la Norma ISO/IEC 27001 en el gobierno autónomo descentralizado San Pedro de Pelileo*. [Tesis de título, Universidad Técnica de Ambato]. <https://repositorio.uta.edu.ec/items/ea04f954-942d-4bd9-8fc1-33148568bb0f>
- Arcentales Fernández, D., & Caycedo Casas, X. (2017). *Auditoría informática: un enfoque efectivo*. [Tesis de título, Universidad de Cuenca]. <https://repositorio.uta.edu.ec/bitstreams/b8c7abcf-4f26-4b1c-87dd-659ab55debc8/download>
- Armas Saldaña, L. A. (2020). *Modelo de auditoria para evaluar los sistemas de información del gobierno regional de la libertad para el año 2018*. [Tesis de título, Universidad Privada Antenor Orrego].

<https://repositorio.upao.edu.pe/item/409c542a-9803-4bba-bf1d-bd51a0364505>

Azzolini, E., Furia, G., Cambieri, A., W., R., M., V., & Poscia, A. (2019). Mejora de la calidad de las historias clínicas mediante auditoría interna: un análisis comparativo. *60*(3).

Baldera Bravo, A. (2025). Modelo de gestión de seguridad de información basado en un enfoque de Gestión de Riesgos para el Sector de Salud privado de Chiclayo. [Tesis de título, Universidad Nacional Pedro Ruiz Gallo].
<https://repositorio.unprg.edu.pe/handle/20.500.12893/14829?show=full>

Bruce, C. V. (2023). Auditoría de sistemas de información para la seguridad y eficiencia organizacional. Exterior.

Calixto Tello, J. E., & Gonzáles Mayanga, J. C. (2019). *Modelo de auditoria basado NT MINSA N° 22-2005 y NTP ISOIEC: 27001-2014 para evaluar los sistemas de información de gestión de historias clínicas en los centros de salud ocupacional de la provincia de Trujillo - 2019*. [Tesis de título, Universidad Privada Antenor Orrego].
<https://repositorio.upao.edu.pe/item/d334b362-0afc-4288-bad2-7ff12d95a956>

Carballo Barcos, M. (2015). Algunas consideraciones acerca de las variables en las investigaciones que se desarrollan en educación. *Revista Científica de la Universidad de Cienfuegos*, 11.
<https://rus.ucf.edu.cu/index.php/rus/article/view/317/>

Cauas, D. (2015). Definición de las variables, enfoque y tipo de investigación. *Biblioteca electrónica de la universidad*.

Corona Martínez, L. A., & Hernández Fonseca, M. (2022). Las hipótesis en el proyecto de investigación: ¿cuándo sí, ¿cuándo no? *METODO EN LA CIENCIA*, 21(1).

- Couto Lorenzo, L. (2019). *Auditoria del sistema APPCC*. España: Ediciones Díaz de Santos.
- CMMI Institute. (2020). *CMMI® V2.2 for Development (CMMI-DEV)*. ISACA.
- Dávalos Suñagua, Á. F. (2013). Auditoria De Seguridad De Información. 6(6).
- Dávila Angeles, A. A., & Dextre Alarcón, B. J. (2021). *Propuesta de una implementación de un programa de gestión de vulnerabilidades de seguridad informática para mitigar los siniestros de la información en el policlínico de salud AMC alineado a la NTP-ISO/IEC 27001:2014 en la ciudad de Lima - 2021*. [Tesis de título, Universidad Tecnológica del Perú]. <https://repositorio.utp.edu.pe/item/689a1733-2f98-459a-88f4-dc30469ba7ac>
- Dirección de Normalización - INACAL. (2022). *Norma Técnica Peruana NTP-ISO/IEC 27001:2022*. Lima: INACAL.
- Dirección de Normalización - INACAL. (2022). *Norma Técnica Peruana NTP-ISO/IEC 27002:2022*. Lima: INACAL.
- Gomero Sánchez, R. (2024). Ciberseguridad en servicios de apoyo al médico ocupacional de la ciudad de Lima. Estudio piloto. *Revista Médica Herediana* 35(1). <https://revistas.upch.edu.pe/index.php/RMH/article/view/5298>
- Gomes, J., & Romão, M. (2025). Evaluating maturity models in healthcare information systems: A comprehensive review. *Healthcare*, 13(15), 1847. <https://doi.org/10.3390/healthcare13151847>
- Guerrero Zapata, J. L. (2020). *Calidad del registro de historia clínica en consultorios externos, del establecimiento de Salud La Unión, Piura, 2020*. [Tesis de título, Universidad César Vallejo]. https://alicia.concytec.gob.pe/vufind/Record/UCVV_b0656e75544b510bb1c317180ad54020

- Herranz Marco, M., Clavería Blasco, V. M., Cortés Moros, I., Gálvez Chaverri, B., Nasarre Romero, E., Malo Montañés, A., et al. (2024). Privacidad y acceso en historias clínicas electrónicas. Ocronos.
- IBM Security. (08 de Octubre de 2024). *Informe sobre el coste de una filtración de datos en 2024*. (IBM) Obtenido de <https://www.ibm.com/reports/data-breach>
- ISACA. (2024). CMMI® performance solutions. <https://www.isaca.org/enterprise/cmmi-performance-solutions>
- Jareño Butron, M., & Arratibel Arrondo, J. A. (2024). Recomendaciones de la Agencia Europea de Ciberseguridad. (115).
- Lara Carreño, S. A. (2020). *Auditoria de seguridad informática para el Hospital Regional de Huacho - 2016*. [Tesis de título, Universidad San Pedro]. <https://repositorio.usanpedro.edu.pe/server/api/core/bitstreams/9d671ad3-f89b-41a7-b196-7bd4334c9123/content>
- Llanos Zavalaga, L. F., Navarro Chumbes, G. C., & Mayca Pérez, J. (2006). Auditoría médica de historias clínicas en consulta externa de cuatros hospitales públicos peruanos. *Revista Médica Herediana*, 17(4), 220–226. <https://revistas.upch.edu.pe/plugins/generic/pdfJsViewer/pdf.js/web/viewer.html?file=https%3A%2F%2Frevistas.upch.edu.pe%2Findex.php%2FRMH%2Farticle%2Fdownload%2F882%2F848%2F>
- Mallqui Espinoza, R. M. (2022). *Estudio de las Historias Clínicas Electrónicas como parte de una transformación digital en el sector de la salud*. [Tesis de maestría, Universidad de San Andrés. Escuela de Negocios]. Repositorio Digital San Andrés. <https://repositorio.udesa.edu.ar/items/5295e37c-ab27-4a16-bb30-8b36795d75bb>
- Marrero, M., Almeida, J., Garcia, D., & Herrera, L. (2024). ¿Qué Son? Los Sistemas de Información. Los sistemas de información - Uneg 2024. https://issuu.com/milagros18/docs/revista_digital_sig

- Mazorra Olmedo, E. R. (2019). *Metodología para la implementación de un sistema de gestión de seguridad de la información ISO/IEC 27001: para soporte de áreas de admisión y atención de un hospital público*. [Tesis de título, Universidad Espíritu Santo]. <https://repositorio.uees.edu.ec/items/fe1b23f1-e306-43ce-80f5-717da28d9815>
- Mejía-Granda, C. M., Fernández-Alemán, J. L., Carrillo de Gea, J. M., & García-Berná, J. A. (2025). A method and validation for auditing e-Health applications based on reusable software security requirements specifications. *International Journal of Medical Informatics*, 194, 105699. <https://doi.org/10.1016/j.ijmedinf.2024.105699>
- Meses Rojas, O. (2022). *Informe de auditoría de evaluación de la calidad de registro en el servicio de hospitalización "B" del Instituto Nacional Materno Perinatal, Marzo 2022*. Lima: Ministerio de Salud. https://www.inmp.gob.pe/uploads/INFORME_DE_AUDITORIA_DE_EVALUACION_DE_LA_CALIDAD_DE_REGISTRO_DE_SERV._HOSP._B_-_MARZO_2022.pdf
- Ministerio de Salud (2025). Directiva Administrativa N° 373-MINSA/OGTI-2025 sobre acreditación de SIHCE.
- Ministerio de Salud (2018). *Norma Técnica de Salud para la Gestión de la Historia Clínica*. Lima: Ministerio de Salud.
- Poma Rosales, L. A. (2019). *Plan de Mejora de la seguridad de la información del seguro social de salud-ESSALUD aplicando estándar ISO/IEC 27001*. [Tesis de título, Universidad Privada Antenor Orrego]. <https://repositorio.upao.edu.pe/item/5d637b03-ae0f-443e-93e5-1a46c875e3ab>
- Niquen Medianero, L. G. (2019). *Implementación de un modelo de gestión de la seguridad de la información para apoyar el proceso de atención al paciente en instituciones de salud*. [Tesis de maestría, Universidad Católica Santo Toribio de Mogrovejo]. Repositorio Institucional USAT.

<https://repositorio.usat.edu.pe/items/13314e21-755c-401a-894e-acbc490a88ff>

OpenStax. (2023). *Introductory Statistics 2e*. Rice University. <https://openstax.org/details/books/introductory-statistics-2e>

Organización Panamericana de la Salud (OPS). (2023). *Seguridad de la Información*. Washington, D.C.: Organización Panamericana de la Salud.

Organización Panamericana de la Salud. (2023). *Seguridad de la Información: 8 principios rectores de la transformación digital del sector salud*. Washington: Sinopsis de políticas. [Informe técnico institucional]. <https://iris.paho.org/handle/10665.2/53730>

Pichihua Vegas, S. (2024). ¡Pymes en la mira de la ciberdelincuencia! Modalidades de cibercrimen más frecuentes. *El Peruano*. <https://elperuano.pe/noticia/168541-pymes-en-la-mira-de-la-ciberdelincuencia-modalidades-de-cibercrimen-mas-frecuentes>

Reporte de Seguridad Latinoamérica 2024. (2024). *12 datos sobre el estado de la ciberseguridad de las empresas de América Latina*. Obtenido de https://eset-la.com/images/mailling/2024/ESET-Security-Report_2024_ESPA%C3%91OL.pdf?utm_campaign=latam-es-online-esr_2024&utm_medium=email&utm_source=eloqua&elqTrackId=df1f8ad7176c4e9d9f246cc8b2d1059f&elq=26d9dcc6c31249a6bb515f84026cf62a&elqaid=2834&elqat=

Solano Rodríguez, O. J. (2024). *La Auditoría de Sistemas de Información como elemento de control*. Universidad Del Valle. Cuadernos de Administración, 20(31). <https://doi.org/10.25100/cdea.v20i31.198>

Ullah, F., He, J., Zhu, N., Wajahat, A., Nazir, A., Qureshi, S., Pathan, M. S., & Dev, S. (2024). Blockchain-enabled EHR access auditing: Enhancing healthcare data security. *Heliyon*, 10(16), e34407. <https://doi.org/10.1016/j.heliyon.2024.e34407>

Vega Briceño, E. (2021). *Seguridad de la Información*. Lima: ÁREA DE INNOVACIÓN Y DESARROLLO, S.L.

Wikipedia. (2024, 4 de diciembre). Capability Maturity Model Integration.

Wikipedia, La Enciclopedia Libre.
https://es.wikipedia.org/wiki/Capability_Maturity_Model_Integration

8 ANEXOS

ANEXO N.º 1: MATRIZ DE CONSISTENCIA

Auditoría a la Seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024

Problema	Objetivo General	Variable	Definición Conceptual	Dimensiones	Indicadores	Tipo Indicador	Valores
¿Cómo determinar el nivel de cumplimiento del sistema de información de gestión de análisis clínicos de IMEQSA S.A.C. respecto a la Norma Técnica de Salud 139-MINSA-2018 y la Norma Técnica Peruana ISO/IEC 27002:2022?	Determinar el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.	Nivel de cumplimiento del SIGAC respecto a la seguridad de la información según la NTS 139-MINSA-2018 e ISO/IEC 27002:2022	Variable categórica nominal que clasifica a los sujetos en categorías sin orden jerárquico (OpenStax, 2023).	Seguridad de la información	Confiabilidad Integridad Disponibilidad	Cualitativo	Cumple (> 80%) Cumple parcialmente (60% - 80%) No cumple (< 60%)
Objetivos Específicos					Indicadores		
Determinar el grado de cumplimiento de los lineamientos establecidos en la NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022 en el SIGAC en cuanto a la confiabilidad de la gestión de las historias clínicas informatizadas.					Cumplimiento de confiabilidad de la gestión de las historias clínicas informatizadas		
Determinar los controles de seguridad implementados en el SIGAC respecto a las recomendaciones de la NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022, con especial énfasis en la protección de la integridad de las historias clínicas informatizadas.					Protección de la integridad de las historias clínicas informatizadas.		
Verificar la capacidad operativa del SIGAC para gestionar la disponibilidad de la historia clínica conforme a los requisitos indicados tanto en NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022.					Gestión de la disponibilidad de la historia clínica		

ANEXO N.º 2: INFORMACIÓN SOBRE IMEQSA S.A.C

EL SISTEMA DE INFORMACIÓN PARA LA GESTIÓN DE ANÁLISIS CLÍNICOS (SIGAC) DE LA EMPRESA IMEQSA S.A.C.

DESCRIPCIÓN GENERAL

El SIGAC de IMEQSA S.A.C., entro en funcionamiento en el inicio de actividades el 01 diciembre del 2019, permitiendo informatizar el proceso de venta, preanalítica, analítica y post-analitica del laboratorio clínico, permitiendo resultados confiables y inmediatos.

Organigrama

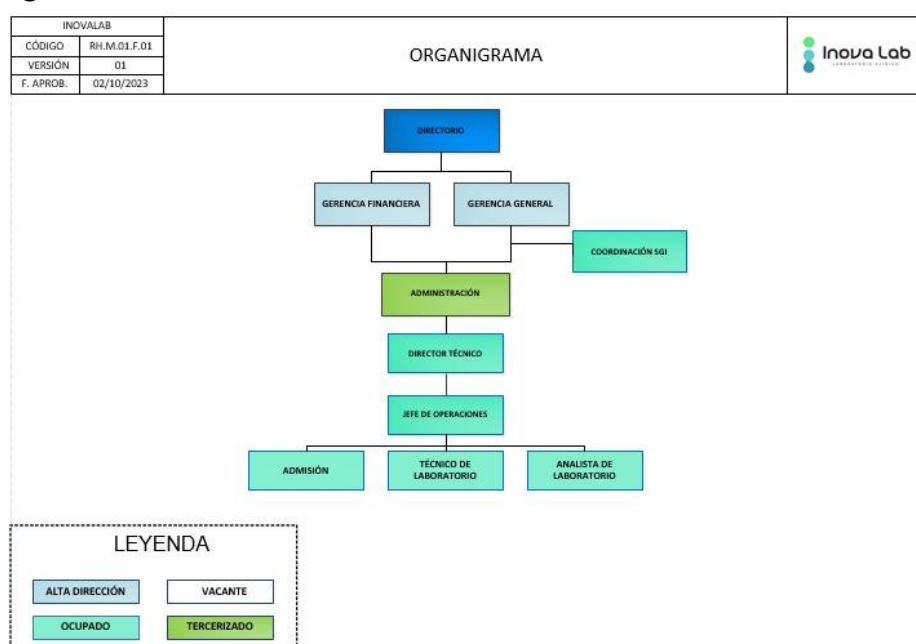


Ilustración 1: Organigrama de IMEQSA S.A.C.

Funciones

a. Gerente General

- Establecer políticas y procesos que contribuyan al crecimiento de la empresa.
- Encargado de la Planificación, organización y supervisión general de las actividades desempeñadas por la empresa.
- Supervisar la operación diaria de la empresa.
- Diseñar la estrategia y fijar objetivos para el crecimiento de la empresa.
- Mantener presupuestos y optimizar gastos.

- Evaluar y mejorar las operaciones y el desempeño financiero.
- Responsable de la administración de los recursos de la empresa, así como la coordinación entre las partes que la componen.
- Responsable de la conducción estratégica de la empresa.
- Responsable de la toma de Decisiones Críticas dentro de la Empresa.
- Velar que se cumplan con las metas, estableciendo los lineamientos generales para integrar los Recursos Humanos, Operaciones, Materiales, Técnicos y financieros; aplicando políticas y estrategias orientadas a la excelencia.
- Entender, cumplir y asegurarse de que el sistema de gestión de la calidad es conforme con los requisitos de la Norma Internacional;
- Asegurarse de que se promueva el enfoque al cliente en toda la organización;
- Contribuir con el correcto desarrollo del Sistema de Gestión Integrada.
- Asegurarse de que la integridad del sistema de gestión de la calidad se mantiene cuando se planifican e implementan cambios en el mismo.

b. Gerente Financiero

- Establecer políticas y procesos que contribuyan al crecimiento de la empresa.
- Encargado de la Planificación, organización y supervisión general de las actividades desempeñadas por la empresa.
- Supervisar la operación diaria de la empresa.
- Diseñar la estrategia y fijar objetivos para el crecimiento de la empresa.
- Mantener presupuestos y optimizar gastos.
- Evaluar y mejorar las operaciones y el desempeño financiero.
- Responsable de la administración de los recursos de la empresa, así como la coordinación entre las partes que la componen.
- Responsable de la conducción estratégica de la empresa.
- Responsable de la toma de Decisiones Críticas dentro de la empresa.
- Supervisar el cumplimiento de las metas estableciendo lineamientos que integren los recursos humanos, operativos, materiales, técnicos y

financieros, apoyados en políticas y estrategias enfocadas en la excelencia.

- Entender, cumplir y asegurarse de que el sistema de gestión de la calidad es conforme con los requisitos de la Norma Internacional;
- Asegurarse de que se promueva el enfoque al cliente en toda la organización;
- Contribuir con el correcto desarrollo del Sistema de Gestión Integrada.
- Asegurarse de que la integridad del sistema de gestión de la calidad se mantiene cuando se planifican e implementan cambios en el mismo.

c. Administrador

- Definir los objetivos y metas específicas para el proceso que administra en las diferentes áreas.
- Responsable de la gestión administrativa de la empresa, analizando los usos alternativos que se darán a los recursos disponibles.
- Crear y mantener buenas relaciones con las Instituciones financieras, proveedores y clientes.
- Liderar y presidir las reuniones generadas con las empresas clientes en forma periódica.
- Definir y establecer los cambios, adaptaciones y mejoras requeridas por los clientes o condiciones de mercado.
- Elaborar informes de apoyo al gerente de la empresa.
- Idea, desarrolla y propone nuevas formas de procesar productos y servicios.
- Gestionar y facilitar el desarrollo de actividades empresariales.
- Cumplir con las normas y procedimientos de seguridad y salud en el trabajo.
- Cumplir con los procedimientos y registros que se requieren para el desarrollo del Sistema Integrado de Gestión.
- Contribuir con el correcto desarrollo del Sistema de Gestión Integrada.
- Velar por que la integridad del sistema de gestión de la calidad se mantenga cuando se realicen procesos de planificación e implementación de cambios.

- Todas las funciones son enunciativas más no limitativas.

Equipamiento Tecnológico

a. Hardware

- Impresora, marca: Epson, modelo: l3110, cantidad de: 3 unidades.
- Anexo telefónico, marca: grandstream, modelo: gxp1630, cantidad de: 3 unidades.
- Mouse, marca: genius, modelo: genius, cantidad de: 7 unidades.
- Teclado, marca: teros, modelo:te-d8700, cantidad de: 7 unidades.
- Monitor 19.5", marca: teros, modelo:te-3020n, cantidad de: 7 unidades.
- Cpu, marca: teros, modelo: teros, cantidad de: 7 unidades.
- Tiquetera, marca:te200, modelo:m267d, cantidad de: 3 unidades.
- Impresora de stickert, marca: tsc, modelo:te200, cantidad de: 2 unidades.
- Ups (equipo automatizado de bioquímica), marca: apc, modelo: srv2ki, cantidad de: 1 unidad.
- Transformador de aislamiento, marca: romero, modelo: monofásico, cantidad de: 1 unidad.
- Ups (equipo automatizado de inmunología), marca: apc, modelo: srv2ki, cantidad de: 1 unidad.
- Transformador de aislamiento, marca: romero, modelo: monofásico, cantidad de: 1 unidad.
- Scanner, marca: kodak, modelo: scan mate i940, cantidad de: 3 unidades.
- Cámaras de videovigilancia, marca: dahua, modelo: s/m, cantidad de: 1 unidad.

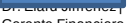
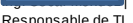
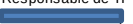
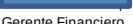
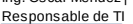
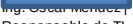
b. Software

El SIGAC de IMEQSA S.A.C. se encuentra alojado en la nube de Microsoft Azure, cumplen los estándares del sector en materia de seguridad y confiabilidad, como ISO/IEC 27001:2013 y NIST SP 800-53

PLANIFICACIÓN

INOVA LAB		FORMATO					
CÓDIGO:	SGI.PR.01.F.03	PLAN DE AUDITORÍA					
VERSIÓN:	1.0						
APROB.:	2/10/2023						

FECHA DE AUDITORÍA	23/08/2025	CRITERIOS DE AUDITORÍA	• Norma Técnica de Salud 139-MINSA-2018 • Norma Técnica Peruana ISO/IEC 27002:2022 • Información documentada de los procesos del SGC			
SITIOS A AUDITAR	Auditoría interna modalidad remota					
EQUIPO AUDITOR	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson					
ALCANCE	Sistema de Gestión de Análisis Clínicos (SIGAC) implementado en IMEQA S.A.C.					
OBJETIVO DE LA AUDITORÍA	a)Evaluar y determinar la conformidad del Sistema de Gestión de Análisis Clínicos (SIGAC) con los requisitos de la norma NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022. b)Dar conformidad a los criterios de auditoría, tipo de requisitos: por la de la norma NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022, contractuales, legales o reglamentarios relacionados al SIGAC. c)Evaluar la eficacia del SIGAC d)Identificar potenciales áreas para la mejora continua.					

FECHA	HORA	PROCESO	REQUISITO	AUDITOR	AUDITADOS	COMENTARIOS
23/08/2025	09:15 - 10:30	SGI	Punto de la NTS 139-2018 MINSA 5.3.3, 5.3.4, 4.2.2, 4.3.2, 4.2.1, 4.2.6,4.2.11,4.2.14,4.2.21,4.2.23, 4.3.3.c,4.3.3.p,4.2.7,9.5.3.4 5.3.1. 3),4.2.24, 5.1.1 ID Control ISO 27001:2022 5.1.5,2.5.4,5.23.5.32,8.29.8.32, 8.15.8.2,5.27.7,4.5.9.8.25,5.12.8.3, 5.16.6.1,6.5.7.3,7.1.8.4,8.19.5.18, 5.15.5.17.8.34,5.24.8.13.5.31.6.3, 6.6.7.13.8.33	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson	 Responsable de TI  Gerente Financiero  Gerente General	
23/08/2025	10:30 - 11:30	RR.HH	Punto de la NTS 139-2018 MINSA 5.3.3, 5.3.4, 4.2.2, 4.3.2, 4.2.1, 4.2.6,4.2.11,4.2.14,4.2.21,4.2.23, 4.3.3.c,4.3.3.p,4.2.7,9.5.3.4 5.3.1. 3),4.2.24, 5.1.1 ID Control ISO 27001:2022 5.1.5,2.5.4,5.23.5.32,8.29.8.32, 8.15.8.2,5.27.7,4.5.9.8.25,5.12.8.3, 5.16.6.1,6.5.7.3,7.1.8.4,8.19.5.18, 5.15.5.17.8.34,5.24.8.13.5.31.6.3, 6.6.7.13.8.34	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson	 Responsable de TI  Gerente Financiero  Gerente General	
23/08/2025	11:30 - 12:30	Gestión Comercial y atención	Punto de la NTS 139-2018 MINSA 5.3.3, 5.3.4, 4.2.2, 4.3.2, 4.2.1, 4.2.6,4.2.11,4.2.14,4.2.21,4.2.23, 4.3.3.c,4.3.3.p,4.2.7,9.5.3.4 5.3.1. 3),4.2.24, 5.1.1 ID Control ISO 27001:2022 5.1.5,2.5.4,5.23.5.32,8.29.8.32, 8.15.8.2,5.27.7,4.5.9.8.25,5.12.8.3, 5.16.6.1,6.5.7.3,7.1.8.4,8.19.5.18, 5.15.5.17.8.34,5.24.8.13.5.31.6.3, 6.6.7.13.8.35	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson	 Responsable de TI  Gerente Financiero  Gerente General	
23/08/2025	12:30 - 13:00	Gestión de mantenimiento y TI	Punto de la NTS 139-2018 MINSA 5.3.3, 5.3.4, 4.2.2, 4.3.2, 4.2.1, 4.2.6,4.2.11,4.2.14,4.2.21,4.2.23, 4.3.3.c,4.3.3.p,4.2.7,9.5.3.4 5.3.1. 3),4.2.24, 5.1.1 ID Control ISO 27001:2022 5.1.5,2.5.4,5.23.5.32,8.29.8.32, 8.15.8.2,5.27.7,4.5.9.8.25,5.12.8.3, 5.16.6.1,6.5.7.3,7.1.8.4,8.19.5.18, 5.15.5.17.8.34,5.24.8.13.5.31.6.3, 6.6.7.13.8.36	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson	 Ing. Oscar Mendez Responsable de TI  Gerente Financiero  Gerente General	
23/08/2025	14:00 - 15:00	Gestión de Operaciones y procesos	Punto de la NTS 139-2018 MINSA 5.3.3, 5.3.4, 4.2.2, 4.3.2, 4.2.1, 4.2.6,4.2.11,4.2.14,4.2.21,4.2.23, 4.3.3.c,4.3.3.p,4.2.7,9.5.3.4 5.3.1. 3),4.2.24, 5.1.1 ID Control ISO 27001:2022 5.1.5,2.5.4,5.23.5.32,8.29.8.32, 8.15.8.2,5.27.7,4.5.9.8.25,5.12.8.3, 5.16.6.1,6.5.7.3,7.1.8.4,8.19.5.18, 5.15.5.17.8.34,5.24.8.13.5.31.6.3, 6.6.7.13.8.37	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson	 Ing. Oscar Mendez Responsable de TI  Gerente Financiero  Gerente General	

FECHA	HORA	PROCESO	REQUISITO	AUDITOR	AUDITADOS	COMENTARIOS
23/08/2025	15:00 -16:00	Gestión estratégica	Punto de la NTS 139-2018 MINSA 5.3.3, 5.3.4, 4.2.2, 4.3.2, 4.2.1, 4.2.6, 4.2.11, 4.2.14, 4.2.21, 4.2.23, 4.3.3.c, 4.3.3.p, 4.2.7, 9.5.3.4 5.3.1. 3), 4.2.24, 5.1.1 ID Control ISO 27001:2022 5.1.5, 2.5.4, 5.23, 5.32, 8.29, 8.32, 8.15, 8.2, 5.27, 7.4, 5.9, 8.25, 5.12, 8.3, 5.16, 6.1, 6.5, 7.3, 7.1, 8.4, 8.19, 5.18, 5.15, 5.17, 8.34, 5.24, 8.13, 5.31, 6.3, 6.6, 7.13, 8.38	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson	 Responsable de TI  Gerente Financiero  Gerente General	
23/08/2025	16:00 - 17:00	Gestión de Compras y logística	Punto de la NTS 139-2018 MINSA 5.3.3, 5.3.4, 4.2.2, 4.3.2, 4.2.1, 4.2.6, 4.2.11, 4.2.14, 4.2.21, 4.2.23, 4.3.3.c, 4.3.3.p, 4.2.7, 9.5.3.4 5.3.1. 3), 4.2.24, 5.1.1 ID Control ISO 27001:2022 5.1.5, 2.5.4, 5.23, 5.32, 8.29, 8.32, 8.15, 8.2, 5.27, 7.4, 5.9, 8.25, 5.12, 8.3, 5.16, 6.1, 6.5, 7.3, 7.1, 8.4, 8.19, 5.18, 5.15, 5.17, 8.34, 5.24, 8.13, 5.31, 6.3, 6.6, 7.13, 8.39	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson	 Responsable de TI  Gerente Financiero  Gerente General	

Ilustración 2: Plan de Auditoria en formato de IMEQSA S.A.C.

EJECUCIÓN

CORRELACIÓN DE LA NORMA TÉCNICA DE SALUD 139-MINSA-2018 Y NORMA TÉCNICA PERUANA ISO/IEC 27002:2022

Tabla 7: Correlación de la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022

ID Control ISO 27001:2022	Punto de la NTS 139-2018 MINSA
5.1 Políticas para la seguridad de la información	4.2.2 Los recursos requeridos para el proceso de gestión HC deben estar programados en plan operativo
5.2 Roles y responsabilidades en seguridad de la información	
5.4 Responsabilidades de la Alta Dirección	
5.23 Seguridad de la información en el uso de servicios en la nube	
5.32 Derechos de propiedad intelectual	
8.29 Pruebas de seguridad en desarrollo y aceptación	
8.32 Gestión de cambios	
8.2 Derechos de acceso privilegiado	
5.27 Aprendizaje de los incidentes de seguridad de la información	
7.4 Supervisión de la seguridad física	
5.9 Inventario de información y otros activos asociados	
8.25 Ciclo de vida de desarrollo seguro	4.3.2 Archivo Activo - durante los últimos cinco (5) años Archivo Pasivo - por más de cinco (5) años; estas historias permanecerán por un periodo de quince (15) años
	4.2.1 fecha, hora, nombres, apellidos completos, firma y numero de colegiatura, registro especialidad (si corresponde) del profesional que brinda la atención
5.12 Clasificación de la información	4.2.6 Los formatos de atención que forman parte de la HC deben consignar nombres y apellidos completos, numero de HC

Tabla 7: Correlación de la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022

ID Control ISO 27001:2022	Punto de la NTS 139-2018 MINSA
	4.2.11 Las IPRESS están obligadas a organizar, mantener, custodiar y administrar el archivo de las Historias Clínicas en medios convencionales o electrónicos o en ambos, según corresponda el caso. 4.2.14 Cuando el usuario de salud o su representante legal lo solicite, las IPRESS están obligadas a entregar copia autenticada de la historia clínica y epicrisis, el costo de reproducción será asumido por el interesado (artículo 44 de la Ley N° 26842, Ley General de Salud). El plazo máximo de entrega es de cinco (5) días; en situaciones en los cuales se requiere en un plazo menor a cuarenta y ocho (48) horas, deberá sustentarse en el documento de solicitud. 4.2.21 El ordenamiento de los formatos de atención en la historia clínica debe realizarse cronológicamente considerando primero las últimas atenciones realizadas y las más antiguas al final de la carpeta, en concordancia con las fechas de atención, las cuales deben estar foliadas de manera correcta 4.2.23 El número de identificación de la historia clínica será el número del Documento Nacional de Identidad – DNI, emitido por el Registro Nacional de Identificación y Estado Civil – RENIEC, para el caso de las personas de nacionalidad peruana y el carnet de extranjería que emite el Ministerio del Interior para el caso de extranjeros residentes, y el pasaporte o el documento de identidad extranjera para el caso de personas extranjeras en tránsito. Para el caso de pacientes sin documento de identidad, las IPRESS asignan un número correlativo de historia clínica provisional, en tanto se determine y confirme la identidad del usuario de salud 4.3.3.c La firma electrónica del paciente no podrá ser usada para brindar el consentimiento informado. El consentimiento informado debe seguir el proceso señalado en la normatividad de la materia y en el numeral 16 del 5.2.2 Formatos Especiales de la presente Norma Técnica de Salud. 4.3.3.d En el caso de menores de edad o personas que requieran de un apoderado, tutor o representante legal, serán ellos quienes firmarán electrónicamente los formatos de atención. 7.7) Eliminación de Historias Clínicas a. En concordancia con la normatividad vigente 28, la eliminación de las historias clínicas es competencia del Archivo General de la Nación-AGN, ente rector del Sistema Nacional de Archivos y los Archivos Regionales; única entidad que autoriza la eliminación de documentos, con conocimiento del Comité Evaluador de Documentos de la DIRIS, DIRESA o GERESA que corresponda.

Tabla 7: Correlación de la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022

ID Control ISO 27001:2022	Punto de la NTS 139-2018 MINSA
8.3 Restricción de acceso a la información	9.9) Propiedad de la Historia Clínica
5.16 Gestión de identidades	a. La Historia Clínica y la base de datos es de propiedad física de la IPRESS.
6.1 Selección	b. La información clínica contenida en la historia clínica es propiedad del paciente o
6.5 Responsabilidades después del cese o cambio de empleo	usuario de salud, establecido en la Ley N° 26842, Ley General de Salud.
7.3 Asegurar oficinas, salas e instalaciones	c. En caso de cierre de una IPRESS, el titular de la Entidad en coordinación con el
7.1 Perímetros de seguridad física	Órgano de Administración de Archivos; tomará la decisión sobre el destino de todas
8.4 Acceso al código fuente	las Historias Clínicas, de ser el caso, de acuerdo con el marco legal vigente.
8.19 Instalación de software en sistemas operativos	
5.18 Uso de programas de utilidad privilegiados	4.2 DE LAS HISTORIAS CLÍNICAS
5.24 Planificación y preparación de la gestión de incidentes de seguridad de la información	
5.15 Control de acceso	5.3.3 r. La Historia Clínica Electrónica debe contar con:
8.13 Copia de seguridad de la información	• Base de datos. • Estructura de datos estandarizada. • Control de acceso restringido – Privilegio de accesos. • Sistema de copias de resguardo. • Registro informatizado de firmas de usuarios (ajustarse a lo establecido en la normatividad
8.15 Registro	41
	• Simultaneidad de accesibilidad. • Confidencialidad. • Recuperabilidad. • Inviolabilidad de los datos.
	Además:
	• Debe ser auditable. • Debe permitir la secuencialidad de las atenciones. • Debe permitir la impresión.
5.17 Información de autenticación	5.3.4 5.3.4. TRANSICIÓN A UNA HISTORIA CLÍNICA ELECTRÓNICA
	a) Todas las IPRESS que cuenten con Historias Clínicas Informatizadas deben implementar un Sistema de Información de Historias Clínicas Electrónicas, para lo cual deben iniciar con:
	- Cumplir mínimamente los aspectos de seguridad: confidencialidad, disponibilidad, integridad y autenticidad; y con lo establecido en la Directiva de Seguridad de la Información
	42
	del Ministerio de Justicia.
	- Implementar la firma digital para los profesionales de la salud según lo señalado en la normatividad vigente
	43
	, que autoriza el uso de firma digital en actos médicos y actos de salud.
	- Cuando se implemente la firma digital para los usuarios de salud; estará exonerado de imprimir los formatos de atención y de seguir usando la historia clínica manuscrita.
	- El registro de la atención debe ser realizado en el sistema de

Tabla 7: Correlación de la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022

ID Control ISO 27001:2022	Punto de la NTS 139-2018 MINSA
	información antes indicado, por el profesional de la salud que brindó la prestación y en el mismo momento. - La Institución Prestadora de Servicios de Salud debe garantizar que los profesionales de la salud se autenticuen en el sistema de información con sus credenciales de acceso, y que se asegure la trazabilidad de los datos registrados, los mismos que se realizan por única vez. - Para el caso de menores de edad o personas que requieran un apoderado, tutor o representante legal, serán quienes firmarán electrónicamente los formatos de atención.
8.34 Protección de los sistemas de información durante las pruebas de auditoría	4.3.3 Aquellas IPRESS que cuenten con un Sistema de Información de Historias Clínicas, deben cumplir mínimamente con los aspectos de seguridad, confidencialidad, disponibilidad, integridad y autenticidad, conforme a lo establecido en la normatividad⁸ y con el uso de la firma de los profesionales de la salud⁹ para el registro de los actos médicos y actos de salud; y, la firma digital (incluyendo a la firma electrónica) para los usuarios de salud; éstos podrán estar exonerados de imprimir los formatos de atención y de mantener la historia clínica manuscrita. 5.3.1. 3) a. La IPRESS debe contar con un sistema informático de registro, control, monitoreo y archivo de historias clínicas, con información periódicamente actualizada y acceso a recuperación por el número de identificación única del usuario, nombre y apellido, código de identificación de ubicación física de las historias clínicas; que cuente con los siguientes campos de ingreso: • Número de identificación única del usuario de historia clínica: DNI o carné de extranjería, pasaporte 20. • Organización de archivos: Ambientes, estantes, divisiones; Archivo Común: archivo activo y archivo pasivo; Archivo Especial, Eliminado. • Ubicación de la historia clínica en el archivo. • Historia clínica: manuscrita, informatizada, electrónica. • Áreas de circulación o préstamo de historia clínica: atención del paciente, trámite administrativo, investigación, docencia, usuario, autoridad judicial o Ministerio Público. • Control de préstamos, devoluciones, e Historia Clínica pendientes de devolución. • Datos de persona autorizada para el préstamo de Historia Clínica. • Resumen de información. • Registro en medios magnéticos. • Sistema de código de barras para las carpetas. • Opción de impresión de etiqueta de datos para pegar en las carpetas de Historia Clínica, con el código y documento de identidad respectivo.
5.31 Requisitos legales, estatutarios, regulatorios y contractuales	
6.3 Toma de conciencia, educación y entrenamiento sobre la seguridad de la información	
6.6 Acuerdos de confidencialidad o no divulgación	
7.13 Mantenimiento de equipos	
8.33 Información de las pruebas	

Tabla 7: Correlación de la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022

ID Control ISO 27001:2022	Punto de la NTS 139-2018 MINSA
	4.2.24 El personal encargado del archivo de las historias clínicas deberá ser capacitado de forma periódica (mínimo una vez al año)
	5.1.1 Estructura Básica: 1) Identificación del paciente 2) Registro de la atención 3) Información Complementaria

ANEXO N.º 3: CARTA N.º 01/AJBD-NAMS

"Año del Bicentenario, de la consolidación de nuestra Independencia, y de la conmemoración de las heroicas batallas de Junín y Ayacucho"

Trujillo, 04 de Julio de 2024.

Carta 01/AJBD-NAMS

Señores

REPRESENTANTE DE LA ALTA DIRECCION
JENNIER SILVERIO SALDIVAR MONDRAGON
GERENTE GENERAL – IMEQSA S.A.C. | INOVALAB

Presente. -

Referencia: Solicitud de facilidades de su organización para aplicación de tesis.

De mi mayor consideración:

Nosotros, Br. Briceño Diaz Anderson Junior, identificado con DNI N° 71424176; y Br. Moreno Sánchez Neisser Arilson, identificado con DNI N° 70369866, en calidad de egresados facultad de Ingeniería, Escuela de Ingeniería de Computación y Sistemas de la Universidad Privada Antenor Orrego

Nos presentamos ante usted y manifestamos:

Solicitar aplicación de un proyecto de tesis planteado **"Auditoria a la seguridad del sistema información de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024"** el objeto de la investigación es con fines académicos, por ello nos comprometemos a preservar la privacidad y confidencialidad de la información brindada, acudimos a su despacho para que dentro del plazo 4 meses puedan darnos facilidades para realizar coordinaciones y ejecutar la auditoria con los responsables del proceso de su empresa, al término de la investigación entregaremos un informe de auditoría interna y una copia del informe de tesis

Para tal efecto, adjunto oficio

Atentamente,



BR. ANDERSON JUNIOR BRICEÑO DIAZ
DNI: 71424176



BR. NEISSER ARILSON MORENO SÁNCHEZ
DNI: 70369866

ANEXO N.º 4: APROBACION DE APLICACIÓN DE TESIS



ANDERSON JUNIOR BRICENO DIAZ <abricenod@upao.edu.pe>

SOLICITUD DE APLICACION DE TESIS

gerencia imeqsa <gerencia.imeqsa@gmail.com>
Para: ANDERSON JUNIOR BRICENO DIAZ <abricenod@upao.edu.pe>
CC: "invalab.lab@gmail.com" <invalab.lab@gmail.com>

5 de julio de 2024, 5:25 p.m.

Buen día Anderson
Aprobado

Enviado desde Outlook para Android

From: ANDERSON JUNIOR BRICENO DIAZ <abricenod@upao.edu.pe>
Sent: Friday, July 5, 2024 2:45:22 PM
To: gerencia.imeqsa@gmail.com <gerencia.imeqsa@gmail.com>
Cc: invalab.lab@gmail.com <invalab.lab@gmail.com>
Subject: SOLICITUD DE APLICACION DE TESIS

[Texto citado oculto]

ANEXO N.º 5: VALIDACION DE INSTRUMENTO POR EXPERTOS

Evaluación por juicio de expertos

Respetado juez: Usted ha sido seleccionado para evaluar el instrumento de auditoría con código INST-ASG-01 elaborado en la investigación "Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024". La evaluación del presente instrumento es de gran relevancia para lograr que sea válido y que los resultados obtenidos a partir de éste sean utilizados eficientemente; aportando tanto a las ciencias de la información y sub línea de investigación sistemas de información organizacionales. Agradecemos su valiosa colaboración.

1. DATOS GENERALES DEL JUEZ

Nombre del juez:	Carlos Eduardo Ipanaqué Zapata
Grado profesional:	Titulado (X) Maestría () Doctor ()
Área de Formación	Desarrollo de software () Gestión de bases de datos () Redes y comunicaciones () Seguridad informática () Inteligencia artificial () Gestión de proyectos tecnológicos (X) Análisis de datos ()
Áreas de experiencia profesional:	TI
Institución donde labora:	Universidad Tecnológica del Perú
Tiempo de experiencia profesional en el área :	2 a 4 años () Más de 5 años (X)

2. PROPÓSITO DE LA EVALUACIÓN:

- a. Validar el contenido de instrumento, por juicio de expertos.

3. DATOS DEL INSTRUMENTO DE AUDITORIA

Título	Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024
Autores	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson
Año	Perú, 2025
Objetivo	Validar instrumento de Auditoría para poder describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C., respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Forma de aplicación	Individual
Forma de calificación	El cuestionario está conformado por 63 ítems que de acuerdo al nivel de gestión de riesgos de sistemas de información ISO/IEC 27005:2022, siendo aplicación de controles preventivos, detectivos y correctivos. Las puntuaciones por cada ítem son de acuerdo Nivel de madurez (1-5) \ CMMI V2.2 de: Inicial(1), Gestionado (2), Definido (3), Gestionado cuantitativamente (4), En optimización (5)
Estructura	Se perfila la creación de este instrumento de auditoría para describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C., respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Validez	Enmarcado a los criterios de Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Confiabilidad	Presenta confiabilidad por CMMI V2.2, lanzada en 2020

3. SOPORTE TEÓRICO

Nivel de madurez (1-5) \ CMMI V2.2	Definición
Inicial(1)	Procesos impredecibles, mal controlados, reactivos.
Gestionado (2)	Proyectos gestionados, pero aún no estandarizados.
Definido (3)	Procesos organizacionales establecidos y documentados.
Gestionado cuantitativamente (4)	Procesos medidos y controlados con datos objetivos.
En optimización (5)	Mejora continua basada en métricas e innovación.

4. PRESENTACIÓN DE INSTRUCCIONES PARA EL JUEZ:

A continuación, a usted le presento el instrumento de auditoría, elaborado por Anderson Junior Briceño Díaz y Neisser Arilson Moreno Sánchez. De acuerdo con los siguientes indicadores califique cada uno de los ítems según corresponda.

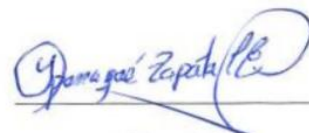
Categoría	Calificación	Indicador
CLARIDAD El ítem se comprende fácilmente, es decir, su sintáctica y semántica son adecuadas.	1. Totalmente Desacuerdo	El ítem no es claro.
	2. Desacuerdo	El ítem requiere bastantes modificaciones o una modificación muy grande en el uso de las palabras de acuerdo con su significado o por la ordenación de las mismas.
	3. Neutro	Se requiere una modificación muy específica de algunos de los términos del ítem.
	4. Acuerdo	El ítem es claro, tiene semántica y sintaxis adecuada.
	5. Totalmente de Acuerdo	El ítem es conforme
COHERENCIA El ítem tiene relación lógica con la dimensión o indicador que está midiendo.	1. Totalmente Desacuerdo	El ítem no tiene relación lógica
	2. Desacuerdo	El ítem tiene una relación tangencial/lejana
	3. Neutro	El ítem tiene una relación
	4. Acuerdo	El ítem se encuentra está relacionado
	5. Totalmente de Acuerdo	El ítem es conforme
RELEVANCIA El ítem es esencial o importante, es decir debe ser incluido.	1. Totalmente Desacuerdo	El ítem puede ser eliminado sin que se vea afectada la medición.
	2. Desacuerdo	El ítem tiene alguna relevancia, pero otro ítem puede estar incluyendo lo que mide éste.
	3. Neutro	El ítem es relativamente importante.
	4. Acuerdo	El ítem es muy relevante y debe ser incluido.
	5. Totalmente de Acuerdo	El ítem es conforme

Leer con detenimiento los ítems y calificar en una escala de 1 a 5 su valoración, así como solicitamos brinde sus observaciones que considere pertinente

1. Totalmente Desacuerdo
2. Desacuerdo
3. Neutro
4. Acuerdo
5. Totalmente de Acuerdo

VERSIÓN 1.0 FECHA ELABORACION: 03/08/2025														
N°	Punto de la NTS 139-2018 MINSA	ID Contro I ISO 27001: 2022	Preguntas de Auditoria	Nivel de madurez (1-5) \ CMMI V2.2					Observaciones	VALIDADOR:	Ing. Carlos Eduardo Ipanaqué Zapata			
				Inicial (1)	Gestio nado (2)	Defini do (3)	Gestionado cuantitativ amente (4)	En optimiza ción (5)			CLARIDAD	COHERENCIA	RELEVANCIA	OBSERVACIONES/ RECOMENDACION ES
Gobernanza y Gestión de Seguridad de la Información														
1		5.1	¿Existe una política formal de seguridad de la información aprobada por la alta dirección?							5	4	5	-	
2		5.2	¿Están definidos y documentados los roles y responsabilidades en seguridad de la información?							4	5	4	-	
3		5.4	¿Cómo demuestra la alta dirección su compromiso con la seguridad de la información?							4	4	4	-	
4		5.23	¿Se han evaluado los riesgos relacionados con los servicios en la nube?							4	5	5	-	
5		5.32	¿Existen controles para proteger los derechos de propiedad intelectual (DPI) de la organización y de terceros?							5	5	4	-	
6		8.29	¿Se corrigen las vulnerabilidades antes de la puesta en producción?							5	5	5	-	
7		8.32	¿Se sigue un proceso formal para la gestión de cambios en sistemas?							5	5	5	-	
8	5.3.3		¿La HCE cuenta con una base de datos implementada?							5	5	5	-	
9	5.3.3		¿Se ha estandarizado la estructura de los datos en la HCE?							4	5	4	-	
10	5.3.3		¿Se garantiza la confidencialidad, recuperabilidad e inviolabilidad de los datos en la HCE?							5	4	5	-	
11	5.3.3	8.15	¿La HCE permite la secuencialidad de las atenciones y la impresión de los registros?							5	5	5	-	
12	5.3.4		¿Se ha implementado la firma digital para los profesionales de salud, conforme a la normativa vigente?							5	5	5	-	
13		8.2	¿Se aplican políticas de acceso basadas en riesgo para los servicios de red?							4	4	4	-	
Gestión de Incidentes de Seguridad														
14		5.27	¿Se realiza una evaluación posterior a los incidentes para identificar causas raíz y lecciones aprendidas?							4	5	4	-	
15	4.2.2		¿Tienen planificado los recursos requeridos para el proceso de gestion HC en un plan operativo?							5	4	4	-	
16		7.4	¿Existen procedimientos para responder a incidentes detectados por los sistemas de vigilancia?							4	4	5	-	
Gestión de Activos de Información														
17		5.9	¿Existe un inventario actualizado de activos de información?							5	5	5	-	
18		8.25	¿Se realizan revisiones de seguridad durante todo el ciclo de vida?							5	5	5	-	
19	4.3.2		¿Se cuenta con un archivo activo (últimos 5 años) y un archivo pasivo (mayores a 5 años)?							4	4	4	-	
Evaluación de Cumplimiento Legal y Normativo														
20	4.2.1		¿El sistema registra fecha, hora, nombres, apellidos completos, firma y numero de colegiatura, registro especialidad(si corresponde) del profesional que brinda la atención?							4	4	5	-	
21	4.2.6	5.12	¿ El sistema tiene los formatos de atencion que forman parte de la HC y consignan nombres y apellidos completos, numero de HC?							4	4	4	-	
22	4.2.11		¿La IPRESS mantiene un sistema de archivo (físico o electrónico) para custodiar las historias clínicas?							4	4	5	-	
23	4.2.14		¿La IPRESS cuenta sistema que le permite entregar copia autenticada de la historia clínica y epicrisis cuando es solicitada por el usuario o su representante dentro del plazo maximo de 5dias habiles?							5	4	4	-	
24	4.2.21		¿Los formatos de atención en la historia clínica del sistema están ordenados cronológicamente, iniciando por los más recientes?							4	4	4	-	
25	4.2.23		¿El número de historia clínica coincide con el número de DNI, carné de extranjería o pasaporte del paciente?							5	4	4	-	
26	4.3.3.c		¿El consentimiento informado se realiza por el proceso indicado en la normativa, sin usar firma electrónica?							5	5	5	-	
27	4.3.3.p		¿ Se custodian las hojas de consentimiento informado?							5	4	5	-	
28	4.2		¿ El sistema permite la seguridad a los programas automatizados, equipos y soportes documentales de la Historia Clínica, que impidan modificarla?							5	5	5	-	
29	7		¿La IPRESS cuenta con un procedimiento documentado y actualizado para la eliminación de historias clínicas conforme a la normativa vigente?							5	4	5	-	
30	9		¿Está claramente establecido que la historia clínica fisica es propiedad de la IPRESS?							5	5	5	-	
31	5.3.4		¿Está previsto que menores de edad o personas con representante legal firmen electrónicamente mediante su apoderado o tutor?							5	5	4	-	
32		8.3	¿Están definidos los requerimientos de seguridad en los contratos con el proveedor de desarrollo?							5	5	5	-	

VERSION: 01 FECHA ELABORACION: 03/08/2025													
N°	Punto de la NTS 139-2018 MINSA	ID Contro I ISO 27001: 2022	Preguntas de Auditoría	Nivel de madurez (1-5) \ CMMI V2.2					Observaciones	Ing. Carlos Eduardo Ipanaque Zapata			
				Inicial(1)	Gestio nado (2)	Defini do (3)	Gestionado cuantitativ amente (4)	En optimiza ción (5)		VALIDADOR:			
										CLARIDAD	COHERENCIA	RELEVANCIA	OBSERVACIONES RECOMENDACIONES
Control de Acceso a la Información													
33		5.16	¿Está documentado el ciclo de vida de las identidades (alta, modificación, baja)?							5	5	5	-
34		6.1	¿Existen criterios definidos para la selección de personal que tendrá acceso a información sensible?							4	5	4	-
35		6.5	¿Se revocan oportunamente los accesos a sistemas y recursos tras la salida o cambio de puesto de un empleado?							5	5	5	-
36		7.3	¿Las áreas que manejan información confidencial están aseguradas contra accesos no autorizados?							4	5	4	-
37		7.1	¿Se han implementado medidas para proteger la información almacenada (como cifrado, control de acceso)?							4	4	4	-
38		8.4	¿Se permite el acceso al código solo al personal de desarrollo autorizado?							5	5	4	-
39		8.19	¿Solo personal autorizado puede instalar software en los sistemas?							5	4	4	-
40	4.2	5.18	¿Las historias clínicas están protegidas contra alteraciones, pérdidas o accesos no autorizados?							5	5	5	-
41	5.3.3	5.15	¿El sistema cuenta con control de acceso restringido (privilegios de acceso diferenciados)?							4	5	5	-
42	5.3.3		¿El sistema permite el acceso simultáneo a la historia clínica por múltiples usuarios autorizados?							5	5	4	-
43	5.3.4		En los casos en que se haya implementado la firma digital para los usuarios, ¿se ha exonerado el uso de formatos físicos y manuscritos?							5	5	4	-
44	5.3.4		¿El registro de la atención se realiza en el sistema electrónico y en el mismo momento por el profesional de salud que brinda la prestación?							5	4	4	-
45	5.3.4	5.17	¿El sistema de información garantiza la autenticación y trazabilidad de los profesionales de salud?							4	5	5	-
46	5.3.3		¿Está implementado el registro informatizado de firmas de usuarios conforme a la normativa?							5	5	5	-
Continuidad del Servicio y Respaldo de Información													
47		8.34	¿Se evalúa el impacto de las auditorías sobre la seguridad y la disponibilidad?							5	5	4	-
48	4.3.3		¿El sistema informático utilizado garantiza la seguridad, confidencialidad, integridad y disponibilidad de la historia clínica, cuentan con firma de los profesionales de salud y se utiliza firma digital o eletronica para validar la historia?							5	4	5	-
49	5.3.1. 3)		¿El sistema informático permite la recuperación de la historia clínica por DNI, nombre o código de ubicación? ¿Se emplea código de barras y etiquetas para identificar las carpetas?							5	4	4	-
50	5.3.4		¿El SIHCE cumple con los principios de seguridad: confidencialidad, disponibilidad, integridad y autenticidad?							5	4	5	-
51	4.2	5.24	¿Se cuenta con un plan de prevención y recuperación del sistema y base de datos ante contingencias?							5	5	5	-
52	5.3.3	8.13	¿Existe un sistema de copias de seguridad de la HCE?							5	5	5	-
53	5.3.3		¿El sistema es auditable y permite la trazabilidad de los registros?							5	5	5	-
Concientización y Capacitación													
54		5.31	¿La organización ha identificado todos los requisitos legales, estatutos, regulatorios y contractuales aplicables en materia de seguridad de la información y historias clínicas?							5	5	4	-
55		6.3	¿Se cuenta con un programa formal de concientización y capacitación en seguridad de la información para todos los empleados?							5	4	4	-
56		6.6	¿Los empleados y contratistas firman acuerdos de confidencialidad antes de acceder a información sensible?							5	5	5	-
57		7.13	¿Se realizan actividades de mantenimiento a los equipos de procesamiento de información?							5	5	5	-
58		8.33	¿Se protege la información utilizada en los entornos de prueba?							5	5	4	-
59	4.2.24		¿El personal responsable del archivo de historias clínicas ha recibido capacitación en lel ultimo año?							5	5	5	-
60	5.1.1		¿La historia clínica contiene correctamente los tres componentes: identificación del paciente, registro de atención e información complementaria?							5	4	5	-
61	9		¿Está garantizado que la información clínica contenida en la historia clínica es propiedad del paciente, conforme a la Ley N.º 26842?							4	4	4	-
62	5.3.4		¿La IPRESS ha iniciado la implementación de un Sistema de Información de Historias Clínicas Electrónicas (SIHCE)?							4	4	4	-



Evaluación por juicio de expertos

Respetado juez: Usted ha sido seleccionado para evaluar el instrumento de auditoría con código INST-ASG-01 elaborado en la investigación "Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024". La evaluación del presente instrumento es de gran relevancia para lograr que sea válido y que los resultados obtenidos a partir de éste sean utilizados eficientemente; aportando tanto a las ciencias de la información y sub línea de investigación sistemas de información organizacionales. Agradecemos su valiosa colaboración.

1. DATOS GENERALES DEL JUEZ

Nombre del juez:	Ing. Esp. MARLON CORREA LEON
Grado profesional:	Titulado (x) Maestría () Doctor ()
Área de Formación	Desarrollo de software (x) Gestión de bases de datos (x) Redes y comunicaciones () Seguridad informática (x) Inteligencia artificial (x) Gestión de proyectos tecnológicos (x) Análisis de datos (x)
Áreas de experiencia profesional:	
Institución donde labora:	UNIVERSIDAD PRIVADA ANTENOR ORREGO
Tiempo de experiencia profesional en el área :	2 a 4 años () Más de 5 años (x)

2. PROPÓSITO DE LA EVALUACIÓN:

- Validar el contenido de instrumento, por juicio de expertos.

3. DATOS DEL INSTRUMENTO DE AUDITORIA

Título	Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024
Autores	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson
Año	Perú, 2025
Objetivo	Validar instrumento de Auditoría para poder describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Forma de aplicación	Individual
Forma de calificación	El cuestionario está conformado por 63 ítems que de acuerdo al nivel de gestión de riesgos de sistemas de información ISO/IEC 27005:2022, siendo aplicación de controles preventivos, detectivos y correctivos. Las puntuaciones por cada ítem son de acuerdo Nivel de madurez (1-5) \ CMMI V2.2 de: Inicial(1), Gestionado (2), Definido (3), Gestionado cuantitativamente (4), En optimización (5)
Estructura	Se perfila la creación de este instrumento de auditoría para describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Validez	Enmarcado a los criterios de Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Confiabilidad	Presenta confiabilidad por CMMI V2.2, lanzada en 2020

3. SOPORTE TEÓRICO

Nivel de madurez (1-5) \ CMMI V2.2	Definición
Inicial(1)	Procesos impredecibles, mal controlados, reactivos.
Gestionado (2)	Proyectos gestionados, pero aún no estandarizados.
Definido (3)	Procesos organizacionales establecidos y documentados.
Gestionado cuantitativamente (4)	Procesos medidos y controlados con datos objetivos.
En optimización (5)	Mejora continua basada en métricas e innovación.

4. PRESENTACIÓN DE INSTRUCCIONES PARA EL JUEZ:

A continuación, a usted le presento el instrumento de auditoría, elaborado por Anderson Junior Briceño Díaz y Neisser Arilson Moreno Sánchez. De acuerdo con los siguientes indicadores califique cada uno de los ítems según corresponda.

Categoría	Calificación	Indicador
CLARIDAD El ítem se comprende fácilmente, es decir, su sintáctica y semántica son adecuadas.	1. Totalmente Desacuerdo	El ítem no es claro.
	2. Desacuerdo	El ítem requiere bastantes modificaciones o una modificación muy grande en el uso de las palabras de acuerdo con su significado o por la ordenación de las mismas.
	3. Neutro	Se requiere una modificación muy específica de algunos de los términos del ítem.
	4. Acuerdo	El ítem es claro, tiene semántica y sintaxis adecuada.
	5. Totalmente de Acuerdo	El ítem es conforme
COHERENCIA El ítem tiene relación lógica con la dimensión o indicador que está midiendo.	1. Totalmente Desacuerdo	El ítem no tiene relación lógica
	2. Desacuerdo	El ítem tiene una relación tangencial/lejana
	3. Neutro	El ítem tiene una relación
	4. Acuerdo	El ítem se encuentra está relacionado
	5. Totalmente de Acuerdo	El ítem es conforme
RELEVANCIA El ítem es esencial o importante, es decir debe ser incluido.	1. Totalmente Desacuerdo	El ítem puede ser eliminado sin que se vea afectada la medición.
	2. Desacuerdo	El ítem tiene alguna relevancia, pero otro ítem puede estar incluyendo lo que mide éste.
	3. Neutro	El ítem es relativamente importante.
	4. Acuerdo	El ítem es muy relevante y debe ser incluido.
	5. Totalmente de Acuerdo	El ítem es conforme

Leer con detenimiento los ítems y calificar en una escala de 1 a 5 su valoración, así como solicitamos brinde sus observaciones que considere pertinente

1. Totalmente Desacuerdo
2. Desacuerdo
3. Neutro
4. Acuerdo
5. Totalmente de Acuerdo

Nº	Punto de la NTS 139-2018 MINSA	ID Contro l ISO 27001: 2022	Preguntas de Auditoría	Nivel de madurez (1-5) \ CMMI V2.2					Observaciones						
				Inicial (1)	Gestio nado (2)	Defini do (3)	Gestionado cuantitativ amente (4)	En optimiza ción (5)							
VALIDADOR:													Ing. Esp. MARLON CORREA LEON		
CLARIDAD													COHERENCIA	RELEVANCIA	OBSERVACIONES/REC OMENDACIONES
Gobernanza y Gestión de Seguridad de la Información															
1		5.1	¿Existe una política formal de seguridad de la información aprobada por la alta dirección?								5	5	4	Asegurar trazabilidad y registro completo.	
2		5.2	¿Están definidos y documentados los roles y responsabilidades en seguridad de la información?								4	5	5	Revisar polí-tica y alineaci³n con normativa.	
3		5.4	¿Cómo demuestra la alta dirección su compromiso con la seguridad de la información?								5	5	5	Confirmar definici³n y comunicaci³n de roles.	
4		5.23	¿Se han evaluado los riesgos relacionados con los servicios en la nube?								5	5	4	Verificar controles y accesos implementados.	
5		5.32	¿Existen controles para proteger los derechos de propiedad intelectual (DPI) de la organización y de terceros?								5	4	4	Evaluar y documentar riesgos identificados.	
6		8.29	¿Se corrigen las vulnerabilidades antes de la puesta en producción?								5	4	5	Confirmar definici³n y comunicaci³n de roles.	
7		8.32	¿Se sigue un proceso formal para la gestión de cambios en sistemas?								5	5	4	Verificar evidencia documental y operativa.	
8	5.3.3		¿La HCE cuenta con una base de datos implementada?								4	5	5	Verificar evidencia documental y operativa.	
9	5.3.3		¿Se ha estandarizado la estructura de los datos en la HCE?								4	4	4	Verificar evidencia documental y operativa.	
10	5.3.3		¿Se garantiza la confidencialidad, recuperabilidad e inviolabilidad de los datos en la HCE?								4	5	4	Revisar estandarizaci³n y consistencia de formatos.	
11	5.3.3	8.15	¿La HCE permite la secuencialidad de las atenciones y la impresión de los registros?								4	5	4	Verificar evidencia documental y operativa.	
12	5.3.4		¿Se ha implementado la firma digital para los profesionales de salud, conforme a la normativa vigente?								4	5	4	Verificar evidencia documental y operativa.	
13		8.2	¿Se aplican políticas de acceso basadas en riesgo para los servicios de red?								5	5	4	Revisar polí-tica y alineaci³n con normativa.	
Gestión de Incidentes de Seguridad															
14		5.27	¿Se realiza una evaluación posterior a los incidentes para identificar causas raíz y lecciones aprendidas?								4	5	4	Revisar polí-tica y alineaci³n con normativa.	
15	4.2.2		¿Tienen planificado los recursos requeridos para el proceso de gestion HC en un plan operativo?								5	5	5	Verificar evidencia documental y operativa.	
16		7.4	¿Existen procedimientos para responder a incidentes detectados por los sistemas de vigilancia?								4	5	4	Verificar evidencia documental y operativa.	
Gestión de Activos de Información															
17		5.9	¿Existe un inventario actualizado de activos de información?								4	4	4	Verificar evidencia documental y operativa.	
18		8.25	¿Se realizan revisiones de seguridad durante todo el ciclo de vida?								4	5	4	Verificar evidencia documental y operativa.	
19	4.3.2		¿Se cuenta con un archivo activo (últimos 5 años) y un archivo pasivo (mayores a 5 años)?								5	5	5	Verificar controles y accesos implementados.	
Evaluación de Cumplimiento Legal y Normativo															
20	4.2.1		¿El sistema registra fecha, hora, nombres, apellidos completos, firma y numero de colegiatura, registro especialidad(si corresponde) del profesional que brinda la atencion?								5	5	4	Verificar integridad y custodia de registros.	
21	4.2.6	5.12	¿ El sistema tiene los formatos de atencion que forman parte de la HC y consignan nombres y apellidos completos, numero de HC?								4	4	5	Comprobar uso y validez de firmas digitales.	
22	4.2.11		¿La IPRESS mantiene un sistema de archivo (físico o electrónico) para custodiar las historias clínicas?								5	4	5	Revisar estandarizaci³n y consistencia de formatos.	
23	4.2.14		¿La IPRESS cuenta sistema que le permite entregar copia autenticada de la historia clínica y epicrisis cuando es solicitada por el usuario o su representante dentro del plazo maximo de 5días hábiles?								5	4	4	Verificar integridad y custodia de registros.	
24	4.2.21		¿Los formatos de atención en la historia clínica del sistema están ordenados cronológicamente, iniciando por los más recientes?								4	4	5	Verificar integridad y custodia de registros.	
25	4.2.23		¿El número de historia clínica coincide con el número de DNI, carné de extranjería o pasaporte del paciente?								5	5	4	Verificar integridad y custodia de registros.	
26	4.3.3.c		¿El consentimiento informado se realiza por el proceso indicado en la normativa, sin usar firma electrónica?								4	4	5	Verificar integridad y custodia de registros.	
27	4.3.3.p		¿ Se custodian las hojas de consentimiento informado?								5	5	4	Revisar polí-tica y alineaci³n con normativa.	
28	4.2		¿ El sistema permite la seguridad a los programas automatizados, equipos y soportes documentales de la Historia Clínica, que impidan modificarla?								4	5	5	Verificar evidencia documental y operativa.	
29	7		¿La IPRESS cuenta con un procedimiento documentado y actualizado para la eliminación de historias clínicas conforme a la normativa vigente?								5	4	4	Verificar controles y accesos implementados.	
30	9		¿Está claramente establecido que la historia clínica física es propiedad de la IPRESS?								5	4	5	Revisar polí-tica y alineaci³n con normativa.	
31	5.3.4		¿Está previsto que menores de edad o personas con representante legal firmen electrónicamente mediante su apoderado o tutor?								5	4	5	Verificar integridad y custodia de registros.	
32		8.3	¿Están definidos los requerimientos de seguridad en los contratos con el proveedor de desarrollo?								5	4	4	Comprobar uso y validez de firmas digitales.	

FECHA ELABORACION: 03/08/2025														
N°	Punto de la NTS 139-2018 MINSA	ID Contro I ISO 27001: 2022	Preguntas de Auditoría	Nivel de madurez (1-5) \ CMMI V2.2					Observaciones					
				Inicial(1)	Gestio nado (2)	Defini do (3)	Gestionado cuantitativ amente (4)	En optimiza ción (5)						
Ing. Esp. MARLON CORREA LEON														
VALIDADOR:														
CLARIDAD COHERENCIA RELEVANCIA OBSERVACIONES/REC OMENDACIONES														
Control de Acceso a la Información														
33		5.16	¿Está documentado el ciclo de vida de las identidades (alta, modificación, baja)?								5	5	5	Verificar controles y accesos implementados.
34		6.1	¿Existen criterios definidos para la selección de personal que tendrá acceso a información sensible?								5	4	4	Verificar evidencia documental y operativa.
35		6.5	¿Se revocan oportunamente los accesos a sistemas y recursos tras la salida o cambio de puesto de un empleado?								5	5	5	Confirmar definiciÃn y comunicaciÃn de roles.
36		7.3	¿Las áreas que manejan información confidencial están aseguradas contra accesos no autorizados?								5	5	5	Verificar controles y accesos implementados.
37		7.1	¿Se han implementado medidas para proteger la información almacenada (como cifrado, control de acceso)?								4	5	4	Verificar controles y accesos implementados.
38		8.4	¿Se permite el acceso al código solo al personal de desarrollo autorizado?								4	4	5	Verificar controles y accesos implementados.
39		8.19	¿Solo personal autorizado puede instalar software en los sistemas?								5	5	5	Confirmar definiciÃn y comunicaciÃn de roles.
40	4.2	5.18	¿Las historias clínicas están protegidas contra alteraciones, pérdidas o accesos no autorizados?								5	5	4	Confirmar definiciÃn y comunicaciÃn de roles.
41	5.3.3	5.15	¿El sistema cuenta con control de acceso restringido (privilegios de acceso diferenciados)?								5	5	5	Verificar controles y accesos implementados.
42	5.3.3		¿El sistema permite el acceso simultáneo a la historia clínica por múltiples usuarios autorizados?								5	4	4	Verificar controles y accesos implementados.
43	5.3.4		En los casos en que se haya implementado la firma digital para los usuarios, ¿se ha exonerado el uso de formatos físicos y manuscritos?								4	4	5	Verificar controles y accesos implementados.
44	5.3.4		¿El registro de la atención se realiza en el sistema electrónico y en el mismo momento por el profesional de salud que brinda la prestación?								5	4	5	Comprobar uso y validez de firmas digitales.
45	5.3.4	5.17	¿El sistema de información garantiza la autenticación y trazabilidad de los profesionales de salud?								4	4	5	Verificar evidencia documental y operativa.
46	5.3.3		¿Está implementado el registro informatizado de firmas de usuarios conforme a la normativa?								4	5	5	Asegurar trazabilidad y registro completo.
Continuidad del Servicio y Respaldo de Información														
47		8.34	¿Se evalúa el impacto de las auditorías sobre la seguridad y la disponibilidad?								4	4	5	Revisar polÃtica y alineaciÃn con normativa.
48	4.3.3		¿El sistema informático utilizado garantiza la seguridad, confidencialidad, integridad y disponibilidad de la historia clínica, cuentan con firma de los profesionales de salud y se utiliza firma digital o eletronica para validar la historia?								5	4	4	Evaluar y documentar riesgos identificados.
49	5.3.1. 3)		¿El sistema informático permite la recuperación de la historia clínica por DNI, nombre o código de ubicación? ¿Se emplea código de barras y etiquetas para identificar las carpetas?								5	5	5	Verificar controles y accesos implementados.
50	5.3.4		¿El SIHCE cumple con los principios de seguridad: confidencialidad, disponibilidad, integridad y autenticidad?								4	5	5	Verificar integridad y custodia de registros.
51	4.2	5.24	¿Se cuenta con un plan de prevención y recuperación del sistema y base de datos ante contingencias?								5	4	4	Verificar controles y accesos implementados.
52	5.3.3	8.13	¿Existe un sistema de copias de seguridad de la HCE?								5	5	5	Verificar evidencia documental y operativa.
53	5.3.3		¿El sistema es auditable y permite la trazabilidad de los registros?								4	4	5	Verificar controles y accesos implementados.
Concientización y Capacitación														
54		5.31	¿La organización ha identificado todos los requisitos legales, estatutos, regulatorios y contractuales aplicables en materia de seguridad de la información y historias clínicas?								5	4	5	Asegurar trazabilidad y registro completo.
55		6.3	¿Se cuenta con un programa formal de concientización y capacitación en seguridad de la información para todos los empleados?								5	4	5	Verificar controles y accesos implementados.
56		6.6	¿Los empleados y contratistas firman acuerdos de confidencialidad antes de acceder a información sensible?								4	5	5	Verificar controles y accesos implementados.
57		7.13	¿Se realizan actividades de mantenimiento a los equipos de procesamiento de información?								5	5	5	Comprobar uso y validez de firmas digitales.
58		8.33	¿Se protege la información utilizada en los entornos de prueba?								5	5	4	Confirmar mantenimiento preventivo realizado.
59	4.2.24		¿El personal responsable del archivo de historias clínicas ha recibido capacitación en lel ultimo año?								5	4	4	Proteger datos y aislar entornos de prueba.
60	5.1.1		¿La historia clínica contiene correctamente los tres componentes: identificación del paciente, registro de atención e información complementaria?								5	4	4	Confirmar definiciÃn y comunicaciÃn de roles.
61	9		¿Está garantizado que la información clínica contenida en la historia clínica es propiedad del paciente, conforme a la Ley N.º 26842?								4	4	5	Verificar integridad y custodia de registros.
62	5.3.4		¿La IPRESS ha iniciado la implementación de un Sistema de Información de Historias Clínicas Electrónicas (SIHCE)?								5	5	4	Revisar polÃtica y alineaciÃn con normativa.

Evaluación por juicio de expertos

Respetado juez: Usted ha sido seleccionado para evaluar el instrumento de auditoría con código INST-ASG-01 elaborado en la investigación "Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024". La evaluación del presente instrumento es de gran relevancia para lograr que sea válido y que los resultados obtenidos a partir de éste sean utilizados eficientemente; aportando tanto a las ciencias de la información y sub línea de investigación sistemas de información organizacionales. Agradecemos su valiosa colaboración.

1. DATOS GENERALES DEL JUEZ

Nombre del juez:	ING.DAVID RICARDO OLAZABAL FARIAS
Grado profesional:	Maestría () Doctor () Titulado (x)
Área de Formación	Desarrollo de software () Gestión de bases de datos (x) Redes y comunicaciones () Seguridad informática () Inteligencia artificial () Gestión de proyectos tecnológicos (x) Análisis de datos (x)
Áreas de experiencia profesional:	CONSULTOR DE DATOS Y GESTOR DE PROYECTOS
Institución donde labora:	BLUETAB SOLUTIONS PERU S.A.C.
Tiempo de experiencia profesional en el área :	2 a 4 años () Más de 5 años (x)

2. PROPÓSITO DE LA EVALUACIÓN:

- a. Validar el contenido de instrumento, por juicio de expertos.

3. DATOS DEL INSTRUMENTO DE AUDITORIA

Título	Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024
Autores	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson
Año	Perú, 2025
Objetivo	Validar instrumento de Auditoría para poder describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Forma de aplicación	Individual
Forma de calificación	El cuestionario está conformado por 63 ítems que de acuerdo al nivel de gestión de riesgos de sistemas de información ISO/IEC 27005:2022, siendo aplicación de controles preventivos, detectivos y correctivos. Las puntuaciones por cada ítem son de acuerdo Nivel de madurez (1-5) \ CMMI V2.2 de: Inicial(1), Gestionado (2), Definido (3), Gestionado cuantitativamente (4), En optimización (5)
Estructura	Se perfila la creación de este instrumento de auditoría para describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Validez	Enmarcado a los criterios de Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Confiabilidad	Presenta confiabilidad por CMMI V2.2, lanzada en 2020

3. SOPORTE TEÓRICO

Nivel de madurez (1-5) \ CMMI V2.2	Definición
Inicial(1)	Procesos impredecibles, mal controlados, reactivos.
Gestionado (2)	Proyectos gestionados, pero aún no estandarizados.
Definido (3)	Procesos organizacionales establecidos y documentados.
Gestionado cuantitativamente (4)	Procesos medidos y controlados con datos objetivos.
En optimización (5)	Mejora continua basada en métricas e innovación.

4. PRESENTACIÓN DE INSTRUCCIONES PARA EL JUEZ:

A continuación, a usted le presento el instrumento de auditoría, elaborado por Anderson Junior Briceño Díaz y Neisser Arilson Moreno Sánchez. De acuerdo con los siguientes indicadores califique cada uno de los ítems según corresponda.

Categoría	Calificación	Indicador
CLARIDAD El ítem se comprende fácilmente, es decir, su sintáctica y semántica son adecuadas.	1. Totalmente Desacuerdo	El ítem no es claro.
	2. Desacuerdo	El ítem requiere bastantes modificaciones o una modificación muy grande en el uso de las palabras de
	3. Neutro	Se requiere una modificación muy específica de algunos de los términos del ítem.
	4. Acuerdo	El ítem es claro, tiene semántica y sintaxis adecuada.
	5. Totalmente de Acuerdo	El ítem es conforme
COHERENCIA El ítem tiene relación lógica con la dimensión o indicador que está midiendo.	1. Totalmente Desacuerdo	El ítem no tiene relación lógica
	2. Desacuerdo	El ítem tiene una relación tangencial/lejana
	3. Neutro	El ítem tiene una relación
	4. Acuerdo	El ítem se encuentra está relacionado
	5. Totalmente de Acuerdo	El ítem es conforme
RELEVANCIA El ítem es esencial o importante, es decir debe ser incluido.	1. Totalmente Desacuerdo	El ítem puede ser eliminado sin que se vea afectada la medición.
	2. Desacuerdo	El ítem tiene alguna relevancia, pero otro ítem puede estar incluyendo lo que mide éste.
	3. Neutro	El ítem es relativamente importante.
	4. Acuerdo	El ítem es muy relevante y debe ser incluido.
	5. Totalmente de Acuerdo	El ítem es conforme

Leer con detenimiento los ítems y calificar en una escala de 1 a 5 su valoración, así como solicitamos brinde sus observaciones que considere pertinente

1. Totalmente Desacuerdo
2. Desacuerdo
3. Neutro
4. Acuerdo
5. Totalmente de Acuerdo


OLAZABAL FARIAS DAVID RICARDO

ELABORADO: AJBD-NAMS
 CODIGO: INST-ASG-01
 VERSION: 01
 FECHA ELABORACION: 03/08/2025

N°	Punto de la NTS 139-2018 MINSA	ID Contro I ISO 27001: 2022	Preguntas de Auditoría	Nivel de madurez (1-5) \ CMMI V2.2					Observaciones	VALIDADOR: ING.DAVID RICARDO OLAZABAL FARIAS			
				Inicial(1)	Gestio nado (2)	Defini do (3)	Gestionado cuantitativ amente (4)	En optimiza ción (5)		CLARIDAD	COHERENCIA	RELEVANCIA	OBSERVACIONES/ RECOMENDACION ES
Gobernanza y Gestión de Seguridad de la Información													
1		5.1	¿Existe una política formal de seguridad de la información aprobada por la alta dirección?							5	5	5	-
2		5.2	¿Están definidos y documentados los roles y responsabilidades en seguridad de la información?							5	5	5	-
3		5.4	¿Cómo demuestra la alta dirección su compromiso con la seguridad de la información?							5	5	5	-
4		5.23	¿Se han evaluado los riesgos relacionados con los servicios en la nube?							5	5	5	-
5		5.32	¿Existen controles para proteger los derechos de propiedad intelectual (DPI) de la organización y de terceros?							5	5	5	-
6		8.29	¿Se corrigen las vulnerabilidades antes de la puesta en producción?							5	5	5	-
7		8.32	¿Se sigue un proceso formal para la gestión de cambios en sistemas?							5	5	5	-
8	5.3.3		¿La HCE cuenta con una base de datos implementada?							5	5	5	-
9	5.3.3		¿Se ha estandarizado la estructura de los datos en la HCE?							5	5	5	-
10	5.3.3		¿Se garantiza la confidencialidad, recuperabilidad e inviolabilidad de los datos en la HCE?							5	5	5	-
11	5.3.3	8.15	¿La HCE permite la secuencialidad de las atenciones y la impresión de los registros?							5	5	5	-
12	5.3.4		¿Se ha implementado la firma digital para los profesionales de salud, conforme a la normativa vigente?							5	5	5	-
13		8.2	¿Se aplican políticas de acceso basadas en riesgo para los servicios de red?							5	5	5	-
Gestión de Incidentes de Seguridad													
14		5.27	¿Se realiza una evaluación posterior a los incidentes para identificar causas raíz y lecciones aprendidas?							5	5	5	-
15	4.2.2		¿Tienen planificado los recursos requeridos para el proceso de gestion HC en un plan operativo?							5	5	5	-
16		7.4	¿Existen procedimientos para responder a incidentes							5	5	5	-
Gestión de Activos de Información													
17		5.9	¿Existe un inventario actualizado de activos de							5	5	5	-
18		8.25	¿Se realizan revisiones de seguridad durante todo el ciclo							5	5	5	-
19	4.3.2		¿Se cuenta con un archivo activo (últimos 5 años) y un							5	5	5	-
Evaluación de Cumplimiento Legal y Normativo													
20	4.2.1		¿El sistema registra fecha, hora, nombres, apellidos							5	5	5	-
21	4.2.6	5.12	¿ El sistema tiene los formatos de atencion que forman							5	5	5	-
22	4.2.11		¿La IPRESS mantiene un sistema de archivo (físico o							5	5	5	-
23	4.2.14		¿La IPRESS cuenta sistema que le permite entregar copia							5	5	5	-
24	4.2.21		¿Los formatos de atención en la historia clínica del							5	5	5	-
25	4.2.23		¿El número de historia clínica coincide con el numero de							5	5	5	-
26	4.3.3.c		¿El consentimiento informado se realiza por el proceso							5	5	5	-
27	4.3.3.p									5	5	5	-
28	4.2									5	5	5	-
29	7		¿La IPRESS cuenta con un procedimiento documentado y							5	5	5	-
30	9		¿Está claramente establecido que la historia clinica fisica							5	5	5	-
31	5.3.4									5	5	5	-
32		8.3	¿Están definidos los requerimientos de seguridad en los							5	5	5	-

ELABORADO: AJBD-NAMS ANEXO N° 01 A LA NTS 139-2018 ELABORADO: AJBD-NAMS CODIGO: INST-ASG-01 VERSION: 01 FECHA ELABORACION: 03/08/2025															
N°	Punto de la NTS 139-2018 MINSA	ID Contro ISO 27001: 2022	Preguntas de Auditoria	Nivel de madurez (1-5) \ CMMI V2.2					Observaciones	VALIDADOR: ING.DAVID RICARDO OLAZABAL FARIAS					
				Inicial(1)	Gestio nado (2)	Defini do (3)	Gestionado cuantitativ amente (4)	En optimiza ción (5)		CLARIDAD	COHERENCIA	RELEVANCIA	OBSERVACIONES/ RECOMENDACIONES		
Gobernanza y Gestión de Seguridad de la Información															
Control de Acceso a la Información															
33		5.16	¿Está documentado el ciclo de vida de las identidades							5	5	5	-		
34		6.1	¿Existen criterios definidos para la selección de personal							4	4	4	-		
35		6.5	¿Se revocan oportunamente los accesos a sistemas y							5	5	5	-		
36		7.3	¿Las áreas que manejan información confidencial están							4	4	4	-		
37		7.1	¿Se han implementado medidas para proteger la							5	5	5	-		
38		8.4	¿Se permite el acceso al código solo al personal de							5	5	5	-		
39		8.19	¿Solo personal autorizado puede instalar software en los							5	5	5	-		
40	4.2	5.18	¿Las historias clinicas están protegidas contra							5	5	5	-		
41	5.3.3	5.15	¿El sistema cuenta con control de acceso restringido							5	5	5	-		
42	5.3.3		¿El sistema permite el acceso simultáneo a la historia							5	5	5	-		
43	5.3.4									5	5	5	-		
44	5.3.4		¿El registro de la atención se realiza en el sistema							5	5	5	-		
45	5.3.4	5.17								5	5	5	-		
46	5.3.3		¿Está implementado el registro informatizado de firmas de							5	5	5	-		
Continuidad del Servicio y Respaldo de Información															
47		8.34	¿Se evalúa el impacto de las auditorías sobre la seguridad							4	4	4	-		
48	4.3.3		¿El sistema informático utilizado garantiza la seguridad,							4	4	4	-		
49	5.3.1.3		¿El sistema informático permite la recuperación de la							5	5	5	-		
50	5.3.4									5	5	5	-		
51	4.2	5.24	¿Se cuenta con un plan de prevención y recuperación del							5	5	5	-		
52	5.3.3	8.13	¿Existe un sistema de copias de seguridad de la HCE?							5	5	5	-		
53	5.3.3		¿El sistema es auditable y permite la trazabilidad de los							5	5	5	-		
Concientización y Capacitación															
54		5.31	¿La organización ha identificado todos los requisitos							5	5	5	-		
55		6.3	¿Se cuenta con un programa formal de concientización y							5	5	5	-		
56		6.6	¿Los empleados y contratistas firman acuerdos de							5	5	5	-		
57		7.13	¿Se realizan actividades de mantenimiento a los equipos							5	5	5	-		
58		8.33	¿Se protege la información utilizada en los entornos de							5	5	5	-		
59	4.2.24		¿El personal responsable del archivo de historias clinicas							5	5	5	-		
60	5.1.1		¿La historia clinica contiene correctamente los tres							5	5	5	-		
61	9		¿Está garantizado que la información clinica contenida en							5	5	5	-		
62	5.3.4		¿La IPRESS ha iniciado la implementación de un Sistema							5	5	5	-		



Evaluación por juicio de expertos

Respetado juez: Usted ha sido seleccionado para evaluar el instrumento de auditoría con código INST-ASG-01 elaborado en la investigación "Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQA S.A.C. en el periodo 2024". La evaluación del presente instrumento es de gran relevancia para lograr que sea válido y que los resultados obtenidos a partir de éste sean utilizados eficientemente; aportando tanto a las ciencias de la información y sub línea de investigación sistemas de información organizacionales. Agradecemos su valiosa colaboración.

1. DATOS GENERALES DEL JUEZ

Nombre del juez:	ING. GIANCARLO MARIN GAITAN
Grado profesional:	Titulado (x) Maestría () Doctor ()
Área de Formación	Desarrollo de software (x) Gestión de bases de datos (x) Redes y comunicaciones () Seguridad informática () Inteligencia artificial () Gestión de proyectos tecnológicos () Análisis de datos ()
Áreas de experiencia profesional:	
Institución donde labora:	UPAO
Tiempo de experiencia profesional en el área :	2 a 4 años () Más de 5 años (x)

2. PROPÓSITO DE LA EVALUACIÓN:

- Validar el contenido de instrumento, por juicio de expertos.

3. DATOS DEL INSTRUMENTO DE AUDITORIA

Título	Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQA S.A.C. en el periodo 2024
Autores	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson
Año	Perú, 2025
Objetivo	Validar instrumento de Auditoría para poder describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Forma de aplicación	Individual
Forma de calificación	El cuestionario está conformado por 63 ítems que de acuerdo al nivel de gestión de riesgos de sistemas de información ISO/IEC 27005:2022, siendo aplicación de controles preventivos, detectivos y correctivos. Las puntuaciones por cada ítem son de acuerdo Nivel de madurez (1-5) \ CMMI V2.2 de: Inicial(1), Gestionado (2), Definido (3), Gestionado cuantitativamente (4), En optimización (5)
Estructura	Se perfila la creación de este instrumento de auditoría para describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Validez	Enmarcado a los criterios de Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Confiabilidad	Presenta confiabilidad por CMMI V2.2, lanzada en 2020

3. SOPORTE TEÓRICO

Nivel de madurez (1-5) \ CMMI V2.2	Definición
Inicial(1)	Procesos impredecibles, mal controlados, reactivos.
Gestionado (2)	Proyectos gestionados, pero aún no estandarizados.
Definido (3)	Procesos organizacionales establecidos y documentados.
Gestionado cuantitativamente (4)	Procesos medidos y controlados con datos objetivos.
En optimización (5)	Mejora continua basada en métricas e innovación.

4. PRESENTACIÓN DE INSTRUCCIONES PARA EL JUEZ:

A continuación, a usted le presento el instrumento de auditoría, elaborado por Anderson Junior Briceño Díaz y Neisser Arilson Moreno Sánchez. De acuerdo con los siguientes indicadores califique cada uno de los ítems según corresponda.

Categoría	Calificación	Indicador
CLARIDAD El ítem se comprende fácilmente, es decir, su sintáctica y semántica son adecuadas.	1. Totalmente Desacuerdo	El ítem no es claro.
	2. Desacuerdo	El ítem requiere bastantes modificaciones o una modificación muy grande en el uso de las palabras de acuerdo con su significado o por la ordenación de las mismas.
	3. Neutro	Se requiere una modificación muy específica de algunos de los términos del ítem.
	4. Acuerdo	El ítem es claro, tiene semántica y sintaxis adecuada.
	5. Totalmente de Acuerdo	El ítem es conforme
COHERENCIA El ítem tiene relación lógica con la dimensión o indicador que está midiendo.	1. Totalmente Desacuerdo	El ítem no tiene relación lógica
	2. Desacuerdo	El ítem tiene una relación tangencial/lejana
	3. Neutro	El ítem tiene una relación
	4. Acuerdo	El ítem se encuentra está relacionado
	5. Totalmente de Acuerdo	El ítem es conforme
RELEVANCIA El ítem es esencial o importante, es decir debe ser incluido.	1. Totalmente Desacuerdo	El ítem puede ser eliminado sin que se vea afectada la medición.
	2. Desacuerdo	El ítem tiene alguna relevancia, pero otro ítem puede estar incluyendo lo que mide éste.
	3. Neutro	El ítem es relativamente importante.
	4. Acuerdo	El ítem es muy relevante y debe ser incluido.
	5. Totalmente de Acuerdo	El ítem es conforme

Leer con detenimiento los ítems y calificar en una escala de 1 a 5 su valoración, así como solicitamos brinde sus observaciones que considere pertinente

1. Totalmente Desacuerdo
2. Desacuerdo
3. Neutro
4. Acuerdo
5. Totalmente de Acuerdo

CURSOS N°1-ASG-01 VERSION: 01 FECHA ELABORACION: 03/08/2025														
N°	Punto de la NTS 139-2018 MINSA	ID Contro I ISO 27001: 2022	Preguntas de Auditoria	Nivel de madurez (1-5) 1 CMMI V2.2					Observaciones	VALIDADOR:	ING. GIANCARLO MARIN GAITAN			
				Inicial (1)	Gestio nado (2)	Defini do (3)	Gestionado cuantitativ amente (4)	En optimiza ción (5)			CLARIDAD	COHERENCIA	RELEVANCIA	OBSERVACIONES/RECOMENDACIONES
Gobernanza y Gestión de Seguridad de la Información														
1		5.1	¿Existe una política formal de seguridad de la información aprobada por la alta dirección?							5	5	5		
2		5.2	¿Están definidos y documentados los roles y responsabilidades en seguridad de la información?							5	5	5		
3		5.4	¿Cómo demuestra la alta dirección su compromiso con la seguridad de la información?							4	4	5		
4		5.23	¿Se han evaluado los riesgos relacionados con los servicios en la nube?							4	4	5		
5		5.32	¿Existen controles para proteger los derechos de propiedad intelectual (DPI) de la organización y de terceros?							5	5	5		
6		8.29	¿Se corrigen las vulnerabilidades antes de la puesta en producción?							5	5	5		
7		8.32	¿Se sigue un proceso formal para la gestión de cambios en sistemas?							5	5	5		
8	5.3.3		¿La HCE cuenta con una base de datos implementada?							5	5	5		
9	5.3.3		¿Se ha estandarizado la estructura de los datos en la HCE?							5	5	5		
10	5.3.3		¿Se garantiza la confidencialidad, recuperabilidad e inviolabilidad de los datos en la HCE?							5	5	5		
11	5.3.3	8.15	¿La HCE permite la secuencialidad de las atenciones y la impresión de los registros?							5	5	5		
12	5.3.4		¿Se ha implementado la firma digital para los profesionales de salud, conforme a la normativa vigente?							5	5	5		
13		8.2	¿Se aplican políticas de acceso basadas en riesgo para los servicios de red?							4	4	5		
Gestión de Incidentes de Seguridad														
14		5.27	¿Se realiza una evaluación posterior a los incidentes para identificar causas raíz y lecciones aprendidas?							5	5	5		
15	4.2.2		¿Tienen planificado los recursos requeridos para el proceso de gestion HC en un plan operativo?							4	4	4	un plan operativo va de la mano con presupuesto. Se puede re-formular por : ¿Tienen planificados los recursos requeridos para el proceso de gestión HC en un plan operativo, incluyendo la estimación de costos y asignación de presupuesto aprobado?	
16		7.4	¿Existen procedimientos para responder a incidentes detectados por los sistemas de vigilancia?							5	5	5		
Gestión de Activos de Información														
17		5.9	¿Existe un inventario actualizado de activos de información?							5	5	5		
18		8.25	¿Se realizan revisiones de seguridad durante todo el ciclo de vida?							5	5	5		
19	4.3.2		¿Se cuenta con un archivo activo (últimos 5 años) y un archivo pasivo (mayores a 5 años)?							5	5	5		
Evaluación de Cumplimiento Legal y Normativo														
20	4.2.1		¿El sistema registra fecha, hora, nombres, apellidos completos, firma y numero de colegiatura, registro especialidad(si corresponde) del profesional que brinda la atencion?							5	5	5		
21	4.2.6	5.12	¿ El sistema tiene los formatos de atencion que forman parte de la HC y consignan nombres y apellidos completos, numero de HC?							5	5	5		
22	4.2.11		¿La IPRESS mantiene un sistema de archivo (físico o electrónico) para custodiar las historias clínicas?							5	5	5		
23	4.2.14		¿La IPRESS cuenta sistema que le permite entregar copia autenticada de la historia clínica y epicrisis cuando es solicitada por el usuario o su representante dentro del plazo maximo de 5días hábiles?							5	5	5		
24	4.2.21		¿Los formatos de atención en la historia clínica del sistema están ordenados cronológicamente, iniciando por los más recientes?							5	5	5		
25	4.2.23		¿El número de historia clínica coincide con el número de DNI, carné de extranjería o pasaporte del paciente?							5	5	4		
26	4.3.3.c		¿El consentimiento informado se realiza por el proceso indicado en la normativa, sin usar firma electrónica?							5	5	5		
27	4.3.3.p		¿ Se custodian las hojas de consentimiento informado?							5	5	5		
28	4.2		¿ El sistema permite la seguridad a los programas automatizados, equipos y soportes documentales de la Historia Clínica, que impidan modificarla?							5	5	5		
29	7		¿La IPRESS cuenta con un procedimiento documentado y actualizado para la eliminación de historias clínicas conforme a la normativa vigente?							5	5	5		
30	9		¿Está claramente establecido que la historia clínica física es propiedad de la IPRESS?							5	5	5		
31	5.3.4		¿Está previsto que menores de edad o personas con representante legal firmen electrónicamente mediante su apoderado o tutor?							5	5	5		
32		8.3	¿Están definidos los requerimientos de seguridad en los contratos con el proveedor de desarrollo?							5	5	5		

CÓDIGO: INST-ASG-01 VERSIÓN: 01 FECHA ELABORACIÓN: 03/08/2025														
N°	Punto de la NTS 139-2018 MINSA	ID Contro I ISO 27001: 2022	Preguntas de Auditoría	Nivel de madurez (1-5) \ CMMI V2.2					Observaciones	VALIDADOR:				OBSERVACIONES/RECOMENDACIONES
				Inicial(1)	Gestio nado (2)	Defini do (3)	Gestionado cuantitativ amente (4)	En optimiza ción (5)		CLARIDAD	COHERENCIA	RELEVANCIA		
ING. GIANCARLO MARIN GAITAN														
Control de Acceso a la Información														
33		5.16	¿Está documentado el ciclo de vida de las identidades (alta, modificación, baja)?							5	5	5		
34		6.1	¿Existen criterios definidos para la selección de personal que tendrá acceso a información sensible?							5	5	5		
35		6.5	¿Se revocan oportunamente los accesos a sistemas y recursos tras la salida o cambio de puesto de un empleado?							5	5	5		
36		7.3	¿Las áreas que manejan información confidencial están aseguradas contra accesos no autorizados?							5	5	5		
37		7.1	¿Se han implementado medidas para proteger la información almacenada (como cifrado, control de acceso)?							5	5	5		
38		8.4	¿Se permite el acceso al código solo al personal de desarrollo autorizado?							5	5	5		
39		8.19	¿Solo personal autorizado puede instalar software en los sistemas?							5	5	5		
40	4.2	5.18	¿Las historias clínicas están protegidas contra alteraciones, pérdidas o accesos no autorizados?							5	5	5		
41	5.3.3	5.15	¿El sistema cuenta con control de acceso restringido (privilegios de acceso diferenciados)?							5	5	5		
42	5.3.3		¿El sistema permite el acceso simultáneo a la historia clínica por múltiples usuarios autorizados?							5	5	5		
43	5.3.4		En los casos en que se haya implementado la firma digital para los usuarios, ¿se ha exonerado el uso de formatos físicos y manuscritos?							5	5	5		
44	5.3.4		¿El registro de la atención se realiza en el sistema electrónico y en el mismo momento por el profesional de salud que brinda la prestación?							5	5	5		
45	5.3.4	5.17	¿El sistema de información garantiza la autenticación y trazabilidad de los profesionales de salud?							5	5	5		
46	5.3.3		¿Está implementado el registro informatizado de firmas de usuarios conforme a la normativa?							5	5	5		
Continuidad del Servicio y Respaldo de Información														
47		8.34	¿Se evalúa el impacto de las auditorías sobre la seguridad y la disponibilidad?							4	4	5		Bajo que metodo o frecuencia se evaluaria el impacto?
48	4.3.3		¿El sistema informático utilizado garantiza la seguridad, confidencialidad, integridad y disponibilidad de la historia clínica, cuentan con firma de los profesionales de salud y se utiliza firma digital o electronica para validar la historia?							5	5	5		
49	5.3.1. 3)		¿El sistema informático permite la recuperación de la historia clínica por DNI, nombre o código de ubicación? ¿Se emplea código de barras y etiquetas para identificar las carpetas?							5	5	5		
50	5.3.4		¿El SIHCE cumple con los principios de seguridad: confidencialidad, disponibilidad, integridad y autenticidad?							5	5	5		
51	4.2	5.24	¿Se cuenta con un plan de prevención y recuperación del sistema y base de datos ante contingencias?							5	5	5		
52	5.3.3	8.13	¿Existe un sistema de copias de seguridad de la HCE?							5	5	5		
53	5.3.3		¿El sistema es auditable y permite la trazabilidad de los registros?							5	5	5		
Concientización y Capacitación														
54		5.31	¿La organización ha identificado todos los requisitos legales, estatutos, regulatorios y contractuales aplicables en materia de seguridad de la información y historias clínicas?							5	5	5		
55		6.3	¿Se cuenta con un programa formal de concientización y capacitación en seguridad de la información para todos los empleados?							5	5	5		
56		6.6	¿Los empleados y contratistas firman acuerdos de confidencialidad antes de acceder a información sensible?							5	5	5		
57		7.13	¿Se realizan actividades de mantenimiento a los equipos de procesamiento de información?							5	4	4		Este ítem parece estar mas vinculado en planes de TI (continuidad del servicio y respaldo de informacion)
58		8.33	¿Se protege la información utilizada en los entornos de prueba?							5	5	5		
59	4.2.24		¿El personal responsable del archivo de historias clínicas ha recibido capacitación en lel ultimo año?							5	5	5		
60	5.1.1		¿La historia clínica contiene correctamente los tres componentes: identificación del paciente, registro de atención e información complementaria?							5	5	5		
61	9		¿Está garantizado que la información clínica contenida en la historia clínica es propiedad del paciente, conforme a la Ley N° 26842?							4	5	5		
62	5.3.4		¿La IPRESS ha iniciado la implementación de un Sistema de Información de Historias Clínicas Electrónicas (SIHCE)?							5	5	5		

Evaluación por juicio de expertos

Respetado juez: Usted ha sido seleccionado para evaluar el instrumento de auditoría con código INST-ASG-01 elaborado en la investigación "Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el período 2024". La evaluación del presente instrumento es de gran relevancia para lograr que sea válido y que los resultados obtenidos a partir de éste sean utilizados eficientemente; aportando tanto a las ciencias de la información y sub línea de investigación sistemas de información organizacionales. Agradecemos su valiosa colaboración.

1. DATOS GENERALES DEL JUEZ

Nombre del juez:	Ing. Carlos Enrique Lopez Gonzalez
Grado profesional:	Titulado (X) Maestría () Doctor ()
Área de Formación	Desarrollo de software () Gestión de bases de datos () Redes y comunicaciones () Seguridad informática () Inteligencia artificial () Gestión de proyectos tecnológicos (X) Análisis de datos ()
Áreas de experiencia profesional:	TI
Institución donde labora:	Banco de Credito del Peru
Tiempo de experiencia profesional en el área :	2 a 4 años () Más de 5 años (X)

2. PROPÓSITO DE LA EVALUACIÓN:

- a. Validar el contenido de instrumento, por juicio de expertos.

3. DATOS DEL INSTRUMENTO DE AUDITORIA

Título	Auditoría a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el período 2024
Autores	Briceño Diaz, Anderson Junior Moreno Sánchez, Neisser Arilson
Año	Perú, 2025
Objetivo	Validar instrumento de Auditoría para poder describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Forma de aplicación	Individual
Forma de calificación	El cuestionario está conformado por 63 ítems que de acuerdo al nivel de gestión de riesgos de sistemas de información ISO/IEC 27005:2022, siendo aplicación de controles preventivos, detectivos y correctivos. Las puntuaciones por cada ítem son de acuerdo Nivel de madurez (1-5) \ CMMI V2.2 de: Inicial(1), Gestionado (2), Definido (3), Gestionado cuantitativamente (4), En optimización (5)
Estructura	Se perfila la creación de este instrumento de auditoría para describir el nivel de cumplimiento del Sistema de información para la Gestión de Análisis Clínicos (SIGAC) del laboratorio IMEQSA S.A.C, respecto a la Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Validez	Enmarcado a los criterios de Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022.
Confiabilidad	Presenta confiabilidad por CMMI V2.2, lanzada en 2020

3. SOPORTE TEÓRICO

Nivel de madurez (1-5) \ CMMI V2.2	Definición
Inicial(1)	Procesos impredecibles, mal controlados, reactivos.
Gestionado (2)	Proyectos gestionados, pero aún no estandarizados.
Definido (3)	Procesos organizacionales establecidos y documentados.
Gestionado cuantitativamente (4)	Procesos medidos y controlados con datos objetivos.
En optimización (5)	Mejora continua basada en métricas e innovación.

4. PRESENTACIÓN DE INSTRUCCIONES PARA EL JUEZ:

A continuación, a usted le presento el instrumento de auditoría, elaborado por Anderson Junior Briceño Diaz y Neisser Arilson Moreno Sánchez. De acuerdo con los siguientes indicadores califique cada uno de los ítems según corresponda.

Categoría	Calificación	Indicador
CLARIDAD El ítem se comprende fácilmente, es decir, su sintáctica y semántica son adecuadas.	1 Totalmente Desacuerdo	El ítem no es claro.
	2. Desacuerdo	El ítem requiere bastantes modificaciones o una modificación muy grande en el uso de las palabras de acuerdo con su significado o por la ordenación de las mismas.
	3. Neutro	Se requiere una modificación muy específica de algunos de los términos del ítem.
	4. Acuerdo	El ítem es claro, tiene semántica y sintaxis adecuada.
	5. Totalmente de Acuerdo	El ítem es conforme
COHERENCIA El ítem tiene relación lógica con la dimensión o indicador que está midiendo.	1 Totalmente Desacuerdo	El ítem no tiene relación lógica
	2. Desacuerdo	El ítem tiene una relación tangencial/lejana
	3. Neutro	El ítem tiene una relación
	4. Acuerdo	El ítem se encuentra está relacionado
	5. Totalmente de Acuerdo	El ítem es conforme
RELEVANCIA El ítem es esencial o importante, es decir debe ser incluido.	1 Totalmente Desacuerdo	El ítem puede ser eliminado sin que se vea afectada la medición.
	2. Desacuerdo	El ítem tiene alguna relevancia, pero otro ítem puede estar incluyendo lo que mide éste.
	3. Neutro	El ítem es relativamente importante.
	4. Acuerdo	El ítem es muy relevante y debe ser incluido.
	5. Totalmente de Acuerdo	El ítem es conforme

Leer con detenimiento los ítems y calificar en una escala de 1 a 5 su valoración, así como solicitamos brinde sus observaciones que considere pertinente

1 Totalmente Desacuerdo
2. Desacuerdo
3. Neutro
4. Acuerdo
5. Totalmente de Acuerdo

				ELABORADO: AJBD-NAMS CODIGO: INST-ASG-01 VERSION: 01 FECHA ELABORACION: 03/08/2025									
N°	Punto de la NTS 139-	ID Contro I ISO 27001:	Preguntas de Auditoría	Nivel de madurez					Observaciones	VALIDADOR:	Ing. Carlos Enrique Lopez Gonzalez		
				Inicial(1)	Gestio nado (2)	Definid o (3)	Gestionado cuantitativa mente (4)	En optimiza ción (5)			CLARIDAD	COHERENCIA	RELEVANCIA
Gobernanza y Gestión de Seguridad de la Información													
1		5.1	¿Existe una política formal de seguridad de la información aprobada por la alta dirección?							5	4	5	-
2		5.2	¿Están definidos y documentados los roles y responsabilidades en seguridad de la información?							4	5	4	-
3		5.4	¿Cómo demuestra la alta dirección su compromiso con la seguridad de la información?							4	4	4	-
4		5.23	¿Se han evaluado los riesgos relacionados con los servicios en la nube?							4	5	5	-
5		5.32	¿Existen controles para proteger los derechos de propiedad intelectual (DPI) de la organización y de terceros?							5	5	4	-
6		8.29	¿Se corrigen las vulnerabilidades antes de la puesta en producción?							5	5	5	-
7		8.32	¿Se sigue un proceso formal para la gestión de cambios en sistemas?							5	5	5	-
8	5.3.3		¿La HCE cuenta con una base de datos implementada?							5	5	5	-
9	5.3.3		¿Se ha estandarizado la estructura de los datos en la HCE?							4	5	4	-
10	5.3.3		¿Se garantiza la confidencialidad, recuperabilidad e inviolabilidad de los datos en la HCE?							5	4	5	-
11	5.3.3	8.15	¿La HCE permite la secuencialidad de las atenciones y la impresión de los registros?							5	5	5	-
12	5.3.4		¿Se ha implementado la firma digital para los profesionales de salud, conforme a la normativa vigente?							5	5	5	-
13		8.2	¿Se aplican políticas de acceso basadas en riesgo para los servicios de red?							4	4	4	-
Gestión de Incidentes de Seguridad													
14		5.27	¿Se realiza una evaluación posterior a los incidentes para identificar causas raíz y lecciones aprendidas?							4	5	4	-
15	4.2.2		¿Tienen planificado los recursos requeridos para el proceso de gestion HC en un plan operativo?							5	4	4	-
16		7.4	¿Existen procedimientos para responder a incidentes detectados por los sistemas de vigilancia?							4	4	5	-
Gestión de Activos de Información													
17		5.9	¿Existe un inventario actualizado de activos de información?							5	5	5	-
18		8.25	¿Se realizan revisiones de seguridad durante todo el ciclo de vida?							5	5	5	-
19	4.3.2		¿Se cuenta con un archivo activo (últimos 5 años) y un archivo pasivo (mayores a 5 años)?							4	4	4	-
Evaluación de Cumplimiento Legal y Normativo													
20	4.2.1		¿El sistema registra fecha, hora, nombres, apellidos completos, firma y numero de colegiatura, registro especialidad(si corresponde) del profesional que brinda la atencion?							4	4	5	-
21	4.2.6	5.12	¿ El sistema tiene los formatos de atencion que forman parte de la HC y consignan nombres y apellidos completos, numero de HC?							4	4	4	-
22	4.2.11		¿La IPRESS mantiene un sistema de archivo (físico o electrónico) para custodiar las historias clínicas?							4	4	5	-
23	4.2.14		¿La IPRESS cuenta sistema que le permite entregar copia autenticada de la historia clínica y epicrisis cuando es solicitada por el usuario o su representante dentro del plazo maximo de 5días hábiles?							5	4	4	-
24	4.2.21		¿Los formatos de atención en la historia clínica del sistema están ordenados cronológicamente, iniciando por los más recientes?							4	4	4	-
25	4.2.23		¿El número de historia clínica coincide con el número de DNI, carné de extranjería o pasaporte del paciente?							5	4	4	-
26	4.3.3.c		¿El consentimiento informado se realiza por el proceso indicado en la normativa, sin usar firma electrónica?							5	5	5	-
27	4.3.3.p		¿ Se custodian las hojas de consentimiento informado?							5	4	5	-
28	4.2		¿ El sistema permite la seguridad a los programas automatizados, equipos y soportes documentales de la Historia Clínica, que impidan modificarla?							5	5	5	-
29	7		¿La IPRESS cuenta con un procedimiento documentado y actualizado para la eliminación de historias clínicas conforme a la normativa vigente?							5	4	5	-
30	9		¿Está claramente establecido que la historia clínica física es propiedad de la IPRESS?							5	5	5	-
31	5.3.4		¿Está previsto que menores de edad o personas con representante legal firmen electrónicamente mediante su apoderado o tutor?							5	5	4	-
32		8.3	¿Están definidos los requerimientos de seguridad en los contratos con el proveedor de desarrollo?							5	5	5	-

ELABORADO: AJBD-NAMS CODIGO: INST-ASG-01 VERSION: 01 FECHA ELABORACION: 03/08/2025													
N°	Punto de la NTS 139-	ID Contro I ISO 27001:	Preguntas de Auditoría	Nivel de madurez (1-5) \ CMMI V2.2					Observaciones	VALIDADOR:	Ing. Carlos Enrique Lopez Gonzalez		
				Inicial(1)	Gestio nado (2)	Definid o (3)	Gestionado cuantitativa mente (4)	En optimiza ción (5)			CLARIDAD	COHERENCIA	RELEVANCIA
Control de Acceso a la Información													
33		5.16	¿Está documentado el ciclo de vida de las identidades (alta, modificación, baja)?							5	5	5	-
34		6.1	¿Existen criterios definidos para la selección de personal que tendrá acceso a información sensible?							4	5	4	-
35		6.5	¿Se revocan oportunamente los accesos a sistemas y recursos tras la salida o cambio de puesto de un empleado?							5	5	5	-
36		7.3	¿Las áreas que manejan información confidencial están aseguradas contra accesos no autorizados?							4	5	4	-
37		7.1	¿Se han implementado medidas para proteger la información almacenada (como cifrado, control de acceso)?							4	4	4	-
38		8.4	¿Se permite el acceso al código solo al personal de desarrollo autorizado?							5	5	4	-
39		8.19	¿Solo personal autorizado puede instalar software en los sistemas?							5	4	4	-
40	4.2	5.18	¿Las historias clínicas están protegidas contra alteraciones, pérdidas o accesos no autorizados?							5	5	5	-
41	5.3.3	5.15	¿El sistema cuenta con control de acceso restringido (privilegios de acceso diferenciados)?							4	5	5	-
42	5.3.3		¿El sistema permite el acceso simultáneo a la historia clínica por múltiples usuarios autorizados?							5	5	4	-
43	5.3.4		En los casos en que se haya implementado la firma digital para los usuarios, ¿se ha exonerado el uso de formatos físicos y manuscritos?							5	5	4	-
44	5.3.4		¿El registro de la atención se realiza en el sistema electrónico y en el mismo momento por el profesional de salud que brinda la prestación?							5	4	4	-
45	5.3.4	5.17	¿El sistema de información garantiza la autenticación y trazabilidad de los profesionales de salud?							4	5	5	-
46	5.3.3		¿Está implementado el registro informatizado de firmas de usuarios conforme a la normativa?							5	5	5	-
Continuidad del Servicio y Respaldo de Información													
47		8.34	¿Se evalúa el impacto de las auditorías sobre la seguridad y la disponibilidad?							5	5	4	-
48	4.3.3		¿El sistema informático utilizado garantiza la seguridad, confidencialidad, integridad y disponibilidad de la historia clínica, cuentan con firma de los profesionales de salud y se utiliza firma digital o eletronica para validar la historia?							5	4	5	-
49	5.3.1. 3)		¿El sistema informático permite la recuperación de la historia clínica por DNI, nombre o código de ubicación? ¿Se emplea código de barras y etiquetas para identificar las carpetas?							5	4	4	-
50	5.3.4		¿El SIHCE cumple con los principios de seguridad: confidencialidad, disponibilidad, integridad y autenticidad?							5	4	5	-
51	4.2	5.24	¿Se cuenta con un plan de prevención y recuperación del sistema y base de datos ante contingencias?							5	5	5	-
52	5.3.3	8.13	¿Existe un sistema de copias de seguridad de la HCE?							5	5	5	-
53	5.3.3		¿El sistema es auditable y permite la trazabilidad de los registros?							5	5	5	-
Concientización y Capacitación													
54		5.31	¿La organización ha identificado todos los requisitos legales, estatutos, regulatorios y contractuales aplicables en materia de seguridad de la información y historias clínicas?							5	5	4	-
55		6.3	¿Se cuenta con un programa formal de concienciación y capacitación en seguridad de la información para todos los empleados?							5	4	4	-
56		6.6	¿Los empleados y contratistas firman acuerdos de confidencialidad antes de acceder a información sensible?							5	5	5	-
57		7.13	¿Se realizan actividades de mantenimiento a los equipos de procesamiento de información?							5	5	5	-
58		8.33	¿Se protege la información utilizada en los entornos de prueba?							5	5	4	-
59	4.2.24		¿El personal responsable del archivo de historias clínicas ha recibido capacitación en lel ultimo año?							5	5	5	-
60	5.1.1		¿La historia clínica contiene correctamente los tres componentes: identificación del paciente, registro de atención e información complementaria?							5	4	5	-
61	9		¿Está garantizado que la información clínica contenida en la historia clínica es propiedad del paciente, conforme a la Ley N.º 26842?							4	4	4	-
62	5.3.4		¿La IPRESS ha iniciado la implementación de un Sistema de Información de Historias Clínicas Electrónicas (SIHCE)?							4	4	4	-

ANEXO N.º 6: ACTA DE REUNION DE AUDITORIA

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-03	
VERSIÓN:	01	
FECHA:	03/08/2025	
PÁGINA	1 de 1	ACTA DE REUNION DE AUDITORIA INTERNA

En la ciudad de Trujillo, a las 10:00 am horas del sábado, 23 de agosto del 2025 se reunieron por videoconferencia con el objeto de IMEQSA S.A.C ubicada en Calle los Rubies Nro. 225 Int. 103, Urbanización Santa Inés, Distrito Y Provincia De Trujillo, Región De La Libertad, los siguientes:

EQUIPO AUDITOR:

Br. Briceño Díaz, Anderson Junior
Br. Moreno Sánchez, Neisser Arilson

RESPOSANBLES DE IMEQSA S.A.C.:

[REDACTED] Responsable de TI
[REDACTED] Gerente Financiero
[REDACTED] Gerente General

APLICACIÓN DEL PROYECTO DE TESIS:

Auditoria a la seguridad del sistema de gestión de análisis clínicos de IMEQSA S.A.C. en el periodo 2024.

CRITERIOS DE AUDITORÍA:

Norma Técnica de Salud N° 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022

DESARROLLO DE LA REUNIÓN

La reunión se realizó de acuerdo con el programa establecido y participaron los auditores designados, quienes verificaron la información necesaria para el desarrollo de la auditoría.

Se deja constancia mediante la presente acta de que la auditoria interna fue realizada conforme a lo planificado.

Siendo las 12:00pm horas, se dio por concluida la reunión, firmando los presentes en señal de conformidad.

FIRMAS:



Br. Briceño Díaz, Anderson Junior
Auditor Interno



Br. Moreno Sánchez, Neisser Arilson
Auditor Interno



.. Toda impresión o fotocopia no autorizada del documento se considera como COPIA NO CONTROLADA

DOCUMENTO REVISADO Y APROBADO

ANEXO N.º 7: INFORME DE AUDITORIA

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-02	
VERSIÓN:	01	INFORME DE AUDITORÍA
FECHA:	03/08/2025	
PÁGINA	1 de 8	

EMPRESA	IMEQSA S.A.C.
DIRECCIÓN	Cal. los Rubies Nro. 225 Int. 103 Urb. Santa Inés - Trujillo
FECHAS:	23/08/2025
EQUIPO AUDITOR:	Briceño Díaz, Anderson Junior Moreno Sánchez, Neisser Arilson
CRITERIOS DE AUDITORIA	Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022
TIPO Y MODO DE AUDITORIA	Auditoría interna modalidad remota

1. OBJETIVO:

- Evaluar y determinar la conformidad del Sistema de Gestión de Análisis Clínicos (SIGAC) con los requisitos de la norma NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022.
- Dar conformidad a los criterios de auditoría, tipo de requisitos: por la de la norma NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022, contractuales, legales o reglamentarios relacionados al SIGAC.
- Evaluar la eficacia del SIGAC
- Identificar potenciales áreas para la mejora continua.

2. ALCANCE:

Sistema de Gestión de Análisis Clínicos (SIGAC) implementado en IMEQSA S.A.C.

3. CLASIFICACIÓN DE HALLAZGOS

- Conformidad:** Cumplimiento de requisitos, ya sean legales, reglamentarios, requisitos de las normas ISO, contractuales, de la organización.
- Fortaleza:** Aspectos sobresalientes positivos del sistema de gestión.
- Observación:** Hallazgo con tendencia al incumplimiento de un requisito o potencial no conformidad, el cual puede ser tratada con una acción inmediata.
- Oportunidad de Mejora:** Recomendaciones y/o buenas prácticas que la organización puede evaluar su implementación con el fin de la mejora continua.

4. RESULTADOS

4.1 FORTALEZAS

- F1.** El SIGAC de IMEQSA S.A.C. se encuentra alojado en la nube de Microsoft Azure, cumplen los estándares del sector en materia de seguridad y confiabilidad, como ISO/IEC 27001:2013 y NIST SP 800-53.
- F2.** El personal responsable del SIGAC conoce acerca de la seguridad de la información y entiende los compromisos de la organización por cumplir las normas de salud.
- F3.** Se siguen buenas prácticas de desarrollo y mantenimiento del SIGAC, realizando un control de calidad sobre la gestión de cambios antes de elevarlo a producción.

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-02	
VERSION:	01	INFORME DE AUDITORÍA
FECHA:	03/08/2025	
PÁGINA	2 de 8	

4.2 OPORTUNIDADES DE MEJORA

- OM1.** Considerar realizar la documentación de análisis y diseño del SIGAC, para garantizar el mantenimiento del software en el tiempo.
- OM2.** Considerar realizar los manuales de usuario del SIGAC, como control en el ingreso de datos por parte de los usuarios.
- OM3.** Considerar regularizar el derecho de propiedad intelectual de IMEQSA S.A.C. sobre el SIGAC ante INDECOPI.
- OM3.** Implementación de controles administrativos como cláusulas en los contratos sobre el acceso al código fuente, declaraciones de confidencialidad de la información; para el personal o proveedores que tienen acceso al código fuente del SIGAC.
- OM4.** Implementar declaraciones juradas sobre uso de firma digital en el SIGAC, del personal de salud.
- OM5.** Realizar inventario y tener un programa de mantenimiento de Equipos tecnológicos, para garantizar el correcto acceso al SIGAC.
- OM6.** Contar con un archivo de consentimientos, declaraciones y otros formatos físicos manuscritos de acuerdo a norma técnica de salud para acceso solo de personal de salud autorizado.

4.3 OBSERVACIONES

OBS1:

Criterio: El numeral 5.3.3, ítem d) de la NTS N° 139-MINSA-2018 establece que se deben utilizar firmas electrónicas de acuerdo a la normativa legal vigente (Ley N° 27269 y su reglamento) para garantizar la validez y autenticidad de los registros.

Condición: Se verificó que el Sistema de Gestión de Análisis Clínicos (SIGAC) utiliza firmas escaneadas asociadas al usuario, mas no firmas electrónicas certificadas conforme a la normativa indicada.

Evidencia: En los documentos clínicos revisados dentro del SIGAC se observan imágenes escaneadas de las firmas, sin contar con respaldo de certificados digitales emitidos por un Proveedor de Servicios de Certificación acreditado por INDECOPI.

Causa: La situación se origina por la falta de implementación tecnológica para integrar certificados digitales, el desconocimiento del requisito legal y la ausencia de directivas internas que regulen el uso obligatorio de firmas electrónicas.

Efecto: Esta condición genera riesgo legal y regulatorio, posibilidad de observaciones por parte de la autoridad sanitaria o auditorías externas, y vulnerabilidad en la integridad y autenticidad de los documentos, al no contar con mecanismos que garanticen validez jurídica.

OBS2:

Criterio: El numeral 4.2.23 de la NTS N° 139-MINSA-2018 establece que en la identificación de exámenes debe figurar como código de historia clínica el número de documento de identidad del paciente, a fin de permitir el acceso al historial completo de exámenes dentro de la IPRESS.

Condición: Se evidenció que el SIGAC utiliza un código de examen en barras para la identificación de las pruebas, pero no incorpora el número de documento de identidad del paciente como código de historia clínica, conforme al requisito normativo.

Evidencia: Durante la revisión de exámenes registrados en el SIGAC, se verificó que la etiqueta y el registro digital muestran únicamente el código interno en barras, sin el DNI del paciente asociado al historial clínico.

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-02	
VERSIÓN:	01	INFORME DE AUDITORÍA
FECHA:	03/08/2025	
PÁGINA	3 de 8	

Causa: Esta situación se debe a limitaciones en la configuración del sistema para mostrar el DNI como código de historia clínica, así como a la falta de actualización del software y a la ausencia de un procedimiento que exija esta funcionalidad.

Efecto: La no inclusión del DNI como código de historia clínica impide garantizar la trazabilidad completa del historial de exámenes del paciente en la IPRESS IMEQSA S.A.C., generando riesgo de duplicidad de información, retrasos en la atención y posibles incumplimientos normativos ante auditorías o supervisiones sanitarias.

4.4 CONCLUSIONES CON RESPECTO A AUDITORÍA

- 1) La Empresa mantiene un Sistema de Gestión de Análisis Clínicos (SIGAC) basado en la norma NTS 139-MINSA-2018 y NTP ISO/IEC 27002:2022.
- 2) La empresa IMEQSA S.A.C. en el aspecto de Gobernanza y Gestión de Seguridad de la Información se encuentra Gestionado cuantitativamente al 53.85%, Definido al 38.46%; Gestión de Incidentes de Seguridad se encuentra Definido al 100%; Gestión de Activos de Información está Gestionado cuantitativamente al 66.67%; Evaluación de Cumplimiento Legal y Normativo está En optimización al 15.38% y Gestionado cuantitativamente al 69.23%; Control de Acceso a la Información se encuentra En optimización al 7.14% y Gestionado cuantitativamente al 64.29%; Continuidad del Servicio y Respaldo de Información esta En optimización al 28.57% y Gestionado cuantitativamente al 71.43%; y Concientización y Capacitación está En optimización al 22.22% y Gestionado cuantitativamente al 33.33%.
- 3) El nivel de cumplimiento de Norma Técnica de Salud 139-MINSA-2018 y Norma Técnica Peruana ISO/IEC 27002:2022 según CMMI V2.2 esta Inicial al 0%, Gestionado en 9.68%, Definido al 22.58%, Gestionado cuantitativamente al 56.45% y En optimización al 11.29%.
- 4) Se deja constancia que esta auditoría ha sido realizada con carácter aleatorio, haciendo uso del instrumento con código INST-ASG-01 validado por juicio de expertos de modo que puede haber desviaciones que durante la auditoría que no se detectaron, lo cual no exime a los responsables de los procesos de la responsabilidad y la verificación permanente del cumplimiento y una constante atención a las exigencias de la normativa.


 Jennier Saldívar Mondragón
 GERENTE GENERAL
 IMEQSA S.A.C.

Representante de la Empresa
 Cargo: Gerente General

5. ANEXOS:

Toda impresión o fotocopia no autorizada del documento se considera como COPIA NO CONTROLADA
DOCUMENTO REVISADO Y APROBADO

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-02	
VERSION:	01	
FECHA:	03/08/2025	
PAGINA	1 de 8	

ANEXO I: REGISTRO DE INSTRUMENTO:

ELABORADO: AJBD-NAMS
CÓDIGO: INT-ASG-01
VERSION: 01
FECHA ELABORACIÓN: 03/08/2025

Nº	Punto c) de la NTS 139: 2018 MINSA	ID Contr.: ISO 27001:2022	Preguntas de Auditoría	Nivel de madurez (1-5) CMMI V2.2					Observaciones
				Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)	
Gobernanza y Gestión de Seguridad de la Información									
1		5.1	¿Existe una política formal de seguridad de la información aprobada por la alta dirección?			X			
2		5.2	¿Están definidos y documentados los roles y responsabilidades en seguridad de la información?			X			
3		5.4	¿Cómo demuestra la alta dirección su compromiso con la seguridad de la información?			X			
4		5.23	¿Se han evaluado los riesgos relacionados con los servicios en la nube?				X		
5		5.32	¿Existen controles para proteger los derechos de propiedad intelectual (DPI) de la organización y de terceros?			X			
6		6.29	¿Se corrigen las vulnerabilidades antes de la puesta en producción?				X		
7		8.32	¿Se sigue un proceso formal para la gestión de cambios en sistemas?			X			
8	5.3.3		¿La HCE cuenta con una base de datos implementada?				X		
9	5.3.3		¿Se ha estandarizado la estructura de los datos en la HCE?				X		
10	5.3.3		¿Se garantiza la confidencialidad, recuperación e integridad de los datos en la HCE?				X		
11	5.3.3	8.15	¿La HCE permite la secuencialidad de las atenciones y la impresión de los registros?				X		
12	5.3.4		¿Se ha implementado la firma digital para los profesionales de salud, conforme a la normativa vigente?		X				Actualmente se mandan firmas escaneadas asociadas al usuario de salud
13		8.2	¿Se aplican políticas de acceso basadas en riesgo para los servicios de red?				X		

ELABORADO: AJBD-NAMS
CÓDIGO: INT-ASG-01
VERSION: 01
FECHA ELABORACIÓN: 03/08/2025

FECHA ELABORACIÓN: 03/05/2025									
N°	Punto de la NTS 139: 2018 MINSA	ID Contr.: ISO 27001:2022	Preguntas de Auditoría	Nivel de madurez (1-5) CMMI V2.2					Observaciones
				Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)	
Gestión de Incidentes de Seguridad									
14		5.27	¿Se realiza una evaluación posterior a los incidentes para identificar causas raíz y lecciones aprendidas?			X			
15	4.2.2		¿Tienen planificado los recursos requeridos para el proceso de gestión HC en un plan operativo?			X			
16		7.4	¿Existen procedimientos para responder a incidentes detectados por los sistemas de vigilancia?			X			
Gestión de Activos de Información									
17		5.9	¿Existe un inventario actualizado de activos de información?		X				Se recomienda tener un inventario de los equipos
18		8.25	¿Se realizan revisiones de seguridad durante todo el ciclo de vida?				X		
19	4.3.2		¿Se cuenta con un archivo activo (últimos 5 años) y un archivo pasivo (mayores a 5 años)?				X		

Toda impresión o fotocopia no autorizada del documento se considera como COPIA NO CONTROLADA
DOCUMENTO REVISADO Y APROBADO

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-02	
VERSION:	01	
FECHA:	03/08/2025	
PAGINA	2 de 8	

ELABORADO: AJBD-NAMS
CÓDIGO: INT-ASG-01
VERSION: 01
FECHA ELABORACIÓN: 03/08/2025

Nº	Punto c – la NTS 139: 2018 MINSA	ID Conte – ISO 27001:2022	Preguntas de Auditoría	Nivel de madurez (1-5) CMMI V2.2					Observaciones
				Inicial(1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)	
Evaluación de Cumplimiento Legal y Normativo									
20	4.2.1		¿El sistema registra fecha, hora, nombres, apellidos completos, firma y número de colegiatura, registro especializado (si corresponde) del profesional que brinda la atención?			X			
21	4.2.6	5.12	¿El sistema tiene los formatos de atención que forman parte de la HC y consignan nombres y apellidos completos, número de HC?			X			
22	4.2.11		¿La PRESS mantiene un sistema de archivo (físico o electrónico) para custodiar las historias clínicas?				X		
23	4.2.14		¿La PRESS cuenta sistema que le permite entregar copia autenticada de la historia clínica y epícrisis cuando es solicitada por el usuario o su representante dentro del plazo máximo de 5 días hábiles?				X		
24	4.2.21		¿Los formatos de atención en la historia clínica del sistema están ordenados cronológicamente, iniciando por los más recientes?				X		
25	4.2.23		¿El número de historia clínica coincide con el número de DNI, carné de extranjería o pasaporte del paciente?				X		
26	4.3.3.c		¿El consentimiento informado se realiza por el proceso indicado en la normativa, sin usar firma electrónica?				X		
27	4.3.3.p		¿Se custodian las hojas de consentimiento informado?				X		
28	4.2		¿El sistema permite la seguridad a los programas automatizados, equipos y soportes documentales de la Historia Clínica, que impidan modificarla?					X	
29	7		¿La PRESS cuenta con un procedimiento documentado y actualizado para la eliminación de historias clínicas conforme a la normativa vigente?				X		
30	9		¿Está claramente establecido que la historia clínica física es propiedad de la PRESS?				X		
31	5.3.4		¿Está previsto que menores de edad o personas con representante legal firmen electrónicamente mediante su apoderado o tutor?					X	
32		8.3	¿Están definidos los requerimientos de seguridad en los contratos con el proveedor de desarrollo?				X		

Toda impresión o fotocopia no autorizada del documento se considera como COPIA NO CONTROLADA
DOCUMENTO REVISADO Y APROBADO

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-02	
VERSION:	01	
FECHA:	03/08/2025	
PÁGINA:	3 de 8	INFORME DE AUDITORÍA

ELABORADO: AJBD-NAMS
CÓDIGO: INF-ASG-01
VERSION: 01
FECHA ELABORACIÓN: 03/08/2025

Nº	Punto c) de la NTS 139-2018 MINSA	ID Control ISO 27001:2022	Preguntas de Auditoría	Nivel de madurez (1-5) CMMI V2.2					Observaciones
				Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)	
Control de Acceso a la Información									
33		5.16	¿Está documentado el ciclo de vida de las identidades (alta, modificación, baja)?		X				Se recomienda documentar el flujo de procesos con sus autorizaciones
34		6.1	¿Existen criterios definidos para la selección de personal que tendrá acceso a información sensible?				X		
35		6.5	¿Se revocan oportunamente los accesos a sistemas y recursos tras la salida o cambio de puesto de un empleado?				X		
36		7.3	¿Las áreas que manejan información confidencial están aseguradas contra accesos no autorizados?				X		
37		7.1	¿Se han implementado medidas para proteger la información almacenada (como cifrado, control de acceso)?				X		Se recomienda hacer la integración con un proveedor autorizado por INDECOPI
38		8.4	¿Se permite el acceso al código solo al personal de desarrollo autorizado?			X			
39		8.19	¿Solo personal autorizado puede instalar software en los sistemas?					X	
40	4.2	5.18	¿Las historias clínicas están protegidas contra alteraciones, pérdidas o accesos no autorizados?				X		
41	5.3.3	5.15	¿El sistema cuenta con control de acceso restringido (privilegios de acceso diferenciados)?				X		
42	5.3.3		¿El sistema permite el acceso simultáneo a la historia clínica por múltiples usuarios autorizados?				X		
43	5.3.4		En los casos en que se haya implementado la firma digital para los usuarios, ¿se ha exonerado el uso de formatos físicos y manuscritos?		X				
44	5.3.4		¿El registro de la atención se realiza en el sistema electrónico y en el mismo momento por el profesional de salud que brinda la prestación?				X		
45	5.3.4	5.17	¿El sistema de información garantiza la autenticación y trazabilidad de los profesionales de salud?				X		
46	5.3.3		¿Está implementado el registro informatizado de firmas de usuarios conforme a la normativa?			X			

Toda impresión o fotocopia no autorizada del documento se considera como COPIA NO CONTROLADA
DOCUMENTO REVISADO Y APROBADO

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-02	
VERSION:	01	
FECHA:	03/08/2025	
PÁGINA:	4 de 8	INFORME DE AUDITORÍA

ELABORADO: AJBD-NAMS
CÓDIGO: INF-ASG-01
VERSION: 01
FECHA ELABORACIÓN: 03/08/2025

Nº	Punto c) de la NTS 139-2018 MINSA	ID Control ISO 27001:2002	Preguntas de Auditoría	Nivel de madurez (1-5) CMMI V2.2					Observaciones
				Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)	
Continuidad del Servicio y Respaldo de Información									
47		6.34	¿Se evalúa el impacto de las auditorías sobre la seguridad y la disponibilidad?				X		
48	4.3.3		¿El sistema informático utilizado garantiza la seguridad, confidencialidad, integridad y disponibilidad de la historia clínica, cuentan con firma de los profesionales de salud y se utiliza firma digital o electrónica para validar la historia?				X		
49	5.3.1.3)		¿El sistema informático permite la recuperación de la historia clínica por DNI, nombre o código de ubicación?				X		
50	5.3.4		¿Se emplea código de barras y etiquetas para identificar las carpetas?				X		
51	4.2	5.24	¿El SHCE cumple con los principios de seguridad: confidencialidad, disponibilidad, integridad y autenticidad?				X		
52	5.3.3	6.13	¿Se cuenta con un plan de prevención y recuperación del sistema y base de datos ante contingencias?				X		
53	5.3.3		¿Existe un sistema de copias de seguridad de la HICE?					X	
			¿El sistema es auditable y permite la trazabilidad de los registros?					X	
Concientización y Capacitación									
54		5.31	¿La organización ha identificado todos los requisitos legales, estatutos, regulatorios y contractuales aplicables en materia de seguridad de la información y historias clínicas?				X		
55		6.3	¿Se cuenta con un programa formal de concientización y capacitación en seguridad de la información para todos los empleados?				X		
56		6.6	¿Los empleados y contratistas firman acuerdos de confidencialidad antes de acceder a información sensible?			X			
57		7.13	¿Se realizan actividades de mantenimiento a los equipos de procesamiento de información?			X			
58		8.33	¿Se protege la información utilizada en los entornos de prueba?		X				Se recomienda implementar controles administrativos para los freelances. Realizar capacitaciones y sensibilización en la toma de conciencia a todo su personal
59	4.2.24		¿El personal responsable del archivo de historias clínicas ha recibido capacitación en el último año?		X				
60	5.1.1		¿La historia clínica contiene correctamente los tres componentes: identificación del paciente, registro de atención e información complementaria?					X	
61	9		¿Está garantizado que la información clínica contenida en la historia clínica es propiedad del paciente, conforme a la Ley N.º 26542?					X	
62	5.3.4		¿La IPRESS ha iniciado la implementación de un Sistema de Información de Historias Clínicas Electrónicas (SHICE)?				X		

Toda impresión o fotocopia no autorizada del documento se considera como COPIA NO CONTROLADA
DOCUMENTO REVISADO Y APROBADO

AJBD-NAMS		FORMATO
CÓDIGO:	INF-ASG-02	
VERSIÓN:	01	INFORME DE AUDITORÍA
FECHA:	03/08/2025	
PÁGINA	1 de 8	

CALIFICACION DE LA AUDITORIA	Nivel de madurez (1-5) CMMI V2.2				
	Inicial (1)	Gestionado (2)	Definido (3)	Gestionado cuantitativamente (4)	En optimización (5)
Gobernanza y Gestión de Seguridad de la Información	0	1	5	1	0
Gestión de Incidentes de Seguridad	0	0	0	0	0
Gestión de Activos de Información	0	1	0	0	0
Evaluación de Cumplimiento Legal y Normativo	0	0	0	0	0
Control de Acceso a la Información	0	0	0	0	0
Continuidad del Servicio y Respaldo de Información	0	0	0	0	0
Concientización y Capacitación	0	0	0	0	0
TOTALES	0	0	0	0	0

CALIFICACION GLOBAL DE LA AUDITORIA SEGUN CMMI V2.2, lanzada en 2020		
Inicial (1)	0	Procesos impredecibles, mal controlados, reactivos.
Gestionado (2)	5	Procesos gestionados, pero aún no estandarizados.
Definido (3)	14	Procesos organizacionales establecidos y documentados.
Gestionado cuantitativamente (4)	35	Procesos medibles y controlados con datos objetivos.
En optimización (5)	7	Mejora continua basada en métricas e innovación.


 Jennier Saldívar Mondragón
 GERENTE GENERAL
 IMEQSA S.A.C.

Toda impresión o fotocopia no autorizada del documento se considera como COPIA NO CONTROLADA
DOCUMENTO REVISADO Y APROBADO